



Evaluating ChatGPT for Security, Performance, and Code-Quality Improvement of a Financial Accounting REST API: A Branch-Isolated Baseline Study

By

ZAW YE HTUT KO

Master Thesis Report

**Submitted in Partial Fulfilment of the Requirements for the
Degree of Master of Science in Information Technology,
Assumption University**

September 2026

Vincent Mary School of Engineering, Science and Technology
Thesis Approval

Thesis Title: Evaluating ChatGPT for Security, Performance, and Code-Quality Improvement of a Financial Accounting REST API: A Branch-Isolated Baseline Study By: Zaw Ye Htut Ko

Thesis Advisor: Dr. Darun Kesrarat

Academic Year: 2026

The Vincent Mary School of Engineering, Science and Technology of Assumption University has approved this proposal as the partial fulfillment of the requirements for the degree of Master of Science in Computer Science.

Approval Committee:

(Dr. Darun Kesrarat)
Advisor

()
Committee

()
Committee

()
Committee

September 2026

Abstract

This full report evaluates how ChatGPT (Codex 5.4), used as an AI-assisted code improvement advisor, can improve the security, performance, and code quality of a financial accounting RESTful API implemented in ASP.NET Core. The study uses one existing API codebase and compares a common baseline branch with isolated SonarQube, OWASP ZAP, and JMeter remediation branches. Fresh reproduction runs executed on September 22, 2026 provide the primary results. SonarQube 26.7 reduced 17 unique baseline issues to 0 while the Quality Gate remained OK; legacy Code Smells fell from 17 to 0, and coverage changed slightly from 74.4% to 74.3%. OWASP ZAP 2.17 passed the configured rules: the passive scan changed from 3 Medium and 6 Low alerts to 0 Medium and 0 Low, while the authenticated API scan retained one Medium HTTP Only Site observation and reduced Low alerts from 3 to 0. Apache JMeter 5.5 produced mixed results. Soak and spike aggregate p95 improved, but the remediation core gate failed because p100 p95 reached 1146.9 ms and p500 p95 reached 1547.95 ms. The evidence therefore supports a strong code-quality result, a configured-scope security improvement with a disclosed transport observation, and an unsuccessful core-performance outcome under the fresh host run. Historical measurements are retained separately in the appendices for provenance rather than used as the current result.

Table of Contents

Abstract	3
Table of Figures	7
List of Tables	8
List of Acronyms	9
Chapter 1 - Introduction.....	12
1.1 Introduction	12
1.2 Challenges	13
1.3 Problem Statement	14
1.5 Objectives, Measurements, and Outcomes	15
1.5.1 Objectives:	15
1.5.2 Measured Outcomes:	16
1.6 Limitations	16
2.1 The Impact of AI-generated Code on Web Development A Comparative Study of ChatGPT and GitHub Copilot ..	17
2.2 Methodology for Code Synthesis Evaluation of LLMs Presented by a Case Study of ChatGPT and Copilot	18
2.3 Artificial Intelligence-Based Tools	19
2.4 GPTutor	20
2.5 Web APIs Features, Issues, and Expectations – A Large-Scale Empirical Study of Web	21
2.6 An Investigation into Misuse of Java Security APIs by Large Language Models.....	22
2.7 A New Approach to Web Application Security Utilizing GPT Language Models for Source Code Inspection	23
2.8 Evaluating the Code Quality of AI-Assisted Code Generation Tools	24
2.9 Evaluation of Common Security Vulnerabilities of State Universities and Colleges Websites Based on OWASP ..	25
2.10 The Impact of AI on Developer Productivity Evidence from GitHub Copilot.....	26
2.11 Asleep at the Keyboard? Assessing the Security of GitHub Copilot's Code Contributions	27
2.12 How Secure is Code Generated by ChatGPT?	28
2.13 Lost at C: A User Study on the Security Implications of Large Language Model Code Assistants	29
2.14 Large Language Models for Software Engineering: A Systematic Literature Review	31
2.15 Are SonarQube Rules Inducing Bugs?.....	32
3.1.1 Testing Environment and Reproducibility	36
3.1.2 Selected Source-Code Evidence	48
3.1.3 Prompt-Template Evidence and Reproducibility	51
3.1.4 Human-Effort Traceability	52
3.2 Dataset Description and Preparation	53
3.3 Model and Tool Selection	58
3.4 Implementation of ChatGPT-Guided Improvements	61
3.5 Testing Phases	62
3.6 How is it different from others research?	62
3.7 Security Evaluation Plan	64
3.8 Performance Evaluation Plan	65
3.9 Code Quality Evaluation Plan	66
Chapter 4: Results and Discussion	67
4.1 Evaluation Criteria and Decision Rules	67
4.2 Code-Quality Outcome	68
4.3 Security Outcome	71
4.4 Performance Outcome	72
4.5 Overall Assessment and Trade-offs	73
4.6 Web Application Evidence for Current APIs.....	74
Chapter 5: Conclusion	82
5.1 Summary of the Completed Study	82
5.2 Main Findings	82
5.3 Contributions	83
5.4 Limitations and Future Work	83
REFERENCES	106

APPENDICES	87
Appendix A - Environment and Repository Provenance	88
Appendix B - Authentication, JWT, and RBAC Source Code	89
B.1 JWT Authentication Configuration	89
B.2 Controller-Level Role Enforcement	90
Appendix C - Journal-Entry Accounting Source Code	91
C.1 Balanced Journal-Entry Posting	91
C.2 Journal-Entry Reversal	92
Appendix D - Audit Logging and Traceability Source Code	94
D.1 Structured Audit-Log Writer	94
D.2 Auditor-Role Read Boundary	95
Appendix E - SonarQube Remediation Source Code	96
E.1 S107 Controller-Parameter Remediation	96
E.2 S6966 Asynchronous Host Shutdown	97
Appendix F - OWASP ZAP Security-Hardening Source Code	98
F.1 Response Security-Headers Middleware	98
F.2 Middleware Ordering and Swagger Exposure	99
Appendix G - JMeter Performance and Query-Optimization Source Code	101
G.1 Concurrency-Safe Account-Ledger Cache	101
G.2 Read-Only Ledger Query and Running Balance	102
G.3 Idempotent SQL Server Performance Indexes	104
Appendix H - Database Schema and Deterministic Seed Source Code	105
H.1 Deterministic Dataset Parameters	105
H.2 Double-Entry Schema Constraints and Indexes	106
Appendix I - Automated Test Source Code	108
I.1 Role-by-Endpoint Integration Matrix	108
I.2 Security and Performance Configuration Defaults Test	109
Appendix J - React Web Application and API Integration Source Code	110
J.1 Authenticated API Client	110
J.2 Role-Aware Navigation and Mutation Rules	111
Appendix K - Reproduction and Evidence-Automation Source Code	112
K.1 Exact-Commit Research Verification	112
K.2 Environment and Tool Readiness Checks	114
K.3 Reproduction Command Sequence	115
Appendix L - SonarQube, OWASP ZAP, and JMeter Dashboards	116
L.1 SonarQube baseline overview	116
L.2 SonarQube baseline issues	117
L.3 SonarQube remediation overview	118
L.4 SonarQube remediation issues	119
L.5 OWASP ZAP passive baseline before remediation	120
L.6 OWASP ZAP passive baseline after remediation	121
L.7 OWASP ZAP authenticated API before remediation	122
L.8 OWASP ZAP authenticated API after remediation	123
L.9 Apache JMeter baseline p50	124
L.10 Apache JMeter baseline p100	125
L.11 Apache JMeter baseline p500	126
L.12 Apache JMeter baseline soak	127
L.13 Apache JMeter baseline spike	128
L.14 Apache JMeter remediation p50	129
L.15 Apache JMeter remediation p100	130
L.16 Apache JMeter remediation p500	131
L.17 Apache JMeter remediation soak	132
L.18 Apache JMeter remediation spike	133
Appendix M - Result Traceability	134

Appendix N - Limitations and Complete Source Index	135
--	-----

Table of Figures

Figure 3.1. Phase 1 - Baseline analysis workflow.	39
Figure 3.2. Phase 2 - LLM-guided improvements workflow.	41
Figure 3.3. Phase 3 - Post-improvement testing workflow.....	45
Figure 3.4. Phase 4 - Comparative analysis and reporting workflow.....	46
Figure 3.5. Representative chart-of-accounts rows from the live seeded database.	56
Figure 3.6. Representative users and role assignments from the live seeded database.	56
Figure 3.7. Representative journal entries and balanced debit-credit lines.	57
Figure 3.8. Representative accounting-period rows from the live seeded database.....	57
Figure 3.9. Trial-balance sample derived from posted journal-entry lines.	58
Figure 3.10. Representative audit-log rows from report-generation workflows.	58
Figure 4.1. Web application login screen with demo role credentials.....	75
Figure 4.2. Admin dashboard showing live API counts and report summary.	76
Figure 4.3. Trial balance report generated from the live reports API.	77
Figure 4.4. Audit-log screen available to Admin and Auditor roles.....	78
Figure 4.5. Auditor role view with restricted navigation.	79
Figure 4.6. Research-evidence page mapping screens to API coverage.	80
Figure 4.7. Expanded journal-entry lines showing account-level debit and credit evidence.	81
Figure L.1. SonarQube baseline overview dashboard.	116
Figure L.2. SonarQube baseline issues dashboard.	117
Figure L.3. SonarQube remediation overview dashboard.	118
Figure L.4. SonarQube remediation issues dashboard.	119
Figure L.5. OWASP ZAP passive baseline before remediation dashboard.	120
Figure L.6. OWASP ZAP passive baseline after remediation dashboard.	121
Figure L.7. OWASP ZAP authenticated API before remediation dashboard.	122
Figure L.8. OWASP ZAP authenticated API after remediation dashboard.	123
Figure L.9. Apache JMeter baseline p50 dashboard.....	124
Figure L.10. Apache JMeter baseline p100 dashboard.	125
Figure L.11. Apache JMeter baseline p500 dashboard.	126
Figure L.12. Apache JMeter baseline soak dashboard.	127
Figure L.13. Apache JMeter baseline spike dashboard.	128
Figure L.14. Apache JMeter remediation p50 dashboard.....	129
Figure L.15. Apache JMeter remediation p100 dashboard.	130
Figure L.16. Apache JMeter remediation p500 dashboard.	131
Figure L.17. Apache JMeter remediation soak dashboard.	132
Figure L.18. Apache JMeter remediation spike dashboard.....	133

List of Tables

Table 3.1. Four-phase workflow for baseline capture and branch-isolated remediation evidence.	35
Table 3.2. Testing environment and reproducibility configuration.	36
Table 3.3. API endpoint coverage used for side-by-side security and performance evidence.	42
Table 3.4. SonarQube code-quality remediation evidence by rule, file, and fix.	43
Table 3.5. OWASP ZAP before-and-after security evidence.	46
Table 3.6. JMeter before-and-after performance profile comparison.	47
Table 3.7. Selected before-and-after code evidence linked to reviewer comments.	47
Table 3.8. Prompt-template traceability used in remediation runs.	51
Table 3.9. Human-effort traceability for accepted remediation fixes.	52
Table 3.10. Repo-seeded test-data configuration.	53
Table 3.11. Seeded entity coverage for the API behavior under test.	54
Table 4.1. Evaluation criteria used to judge full-report remediation success.	68
Table 4.2. SonarQube before-and-after quality metrics.	69
Table 4.3. Maintainability-focused code-quality comparison.	70
Table 4.4. Performance hotspot comparison for reviewer-visible report endpoints.	72
Table 4.5. Overall outcome and closure matrix.	73

List of Acronyms

AI - Artificial Intelligence

API - Application Programming Interface

ARM - Azure Resource Manager

ASP.NET - Active Server Pages .NET

BAL - Business Access Layer

CI/CD - Continuous Integration / Continuous Delivery

COEP - Cross-Origin Embedder Policy

COOP - Cross-Origin Opener Policy

CORP - Cross-Origin Resource Policy

CORS - Cross-Origin Resource Sharing

CPU - Central Processing Unit

CRUD - Create, Read, Update, Delete

CSRF - Cross-Site Request Forgery

CSP - Content Security Policy

CWE - Common Weakness Enumeration

DAST - Dynamic Application Security Testing

DTO - Data Transfer Object

EF - Entity Framework

GPT - Generative Pre-trained Transformer

GUID - Globally Unique Identifier

HTTP - Hypertext Transfer Protocol

IDE - Integrated Development Environment

IEEE - Institute of Electrical and Electronics Engineers

JSON - JavaScript Object Notation

JWT - JSON Web Token

LINQ - Language Integrated Query

LLM - Large Language Model

ML - Machine Learning

MVC - Model-View-Controller

NCLOC - Non-Comment Lines of Code

NER - Named Entity Recognition

NLP - Natural Language Processing

OWASP - Open Worldwide Application Security Project

p50 - 50th-percentile latency (median)

p95 - 95th-percentile latency

p99 - 99th-percentile latency

RBAC - Role-Based Access Control

REST - Representational State Transfer

SDK - Software Development Kit

SE - Software Engineering

SLA - Service-Level Agreement

SLR - Systematic Literature Review

SQL - Structured Query Language

SZZ - Sliwerski-Zimmermann-Zeller algorithm

TSV - Tab-Separated Values

UI - User Interface

URL - Uniform Resource Locator

VU - Virtual User

XSS - Cross-Site Scripting

ZAP - Zed Attack Proxy

Chapter 1 - Introduction

1.1 Introduction

RESTful APIs are web interfaces that expose resources through standard HTTP methods such as GET, POST, PUT, and DELETE. They are widely used in financial systems because they let client applications, reporting tools, and back-office services exchange account, journal-entry, period, report, and audit-log data through a predictable contract. Prior Web API research emphasizes that API reliability, documentation, security, and performance are central adoption concerns (Zhang et al., 2023). In a financial accounting context, weak authentication, unsafe input handling, slow reporting endpoints, or unclear access-control rules can directly affect confidentiality, integrity, and system availability.

ChatGPT (Codex 5.4), accessed through OpenAI's Codex coding environment, is used in this study as an advisory tool rather than as an autonomous developer. The model receives scanner output, error traces, and code context, then suggests code changes. A human developer reviews those suggestions, applies selected changes on isolated Git branches, and verifies them with the same tool that produced the baseline finding. This distinction matters because prior studies show that LLM-generated code can introduce security weaknesses if it is accepted without review (Pearce et al., 2022; Khoury et al., 2023; Sandoval et al., 2023).

Why this work matters. Production REST APIs in regulated domains such as finance fail in three distinct ways: a static-analysis violation (a code smell that creeps in over time), a security alert (a missing security header, a vulnerable bundled dependency, an unprotected route), and a performance hotspot (a response that breaks an SLA under load). The three failures are caught by three different tools, demand three different remediation styles, and are usually owned by three

different teams. If a general-purpose LLM such as ChatGPT can give correct, framework-aware advice across all three at once, using only the structured tool report and the relevant code excerpt, it materially shortens the audit-to-fix cycle that is the bottleneck of modern API quality work. Establishing whether and where this works requires the kind of branch-isolated empirical evidence that this thesis proposes to collect, and the answer is directly actionable for practitioners deciding whether to embed LLMs in their CI/CD review loop.

Expected outcomes summary. On the financial-accounting ASP.NET Core API used as the unit of analysis, the study expects ChatGPT (Codex 5.4) acting purely as an advisor on tool output to (i) substantially reduce SonarQube findings while preserving test coverage and quality-gate status; (ii) clear gated High, Medium, and Low alerts in OWASP ZAP baseline and authenticated API scans on business endpoints; and (iii) achieve double-digit percentage reductions in p95 latency under JMeter load profiles at 50, 100, and 500 virtual users while keeping error rate at 0%. The study further expects to surface at least one honest limitation: structural metrics that depend on global workload composition, rather than on per-endpoint latency, are not expected to move under per-finding LLM patches. Section 1.5.2 elaborates the per-dimension expected outcomes in concrete numerical terms.

1.2 Challenges

APIs are crucial for modern web and mobile applications because they allow independent systems to exchange data and trigger business operations. In finance, this includes authentication, account management, journal-entry posting, financial reporting, and audit-log retrieval. Because these operations handle sensitive records, API failures can expose user identity

data, financial balances, and operational audit trails. Security and performance therefore need to be evaluated together: an API that is secure but too slow can fail operational requirements, while a fast API with weak access control can create unacceptable risk.

APIs that handle sensitive data are frequent targets for attack. SQL injections occur when untrusted input is allowed to alter a database query; Cross-Site Scripting (XSS) occurs when unsafe content can be executed by a client; and Cross-Site Request Forgery (CSRF) abuses an authenticated user session to submit unintended actions. RESTful APIs also require strong authentication, role-based authorization, input validation, secure headers, and careful error handling. In this study, OWASP ZAP is used to detect web/API security weaknesses, while role-based tests verify that Admin, FinanceManager, User, and Auditor permissions are enforced correctly.

1.3 Problem Statement

The problem addressed in this report is that traditional API improvement work is fragmented. Static analysis identifies maintainability issues, security scanners identify missing headers or vulnerability patterns, and load tests identify slow endpoints, but these findings are often handled separately. For the financial accounting API used in this study, the current challenge is to determine whether ChatGPT (Codex 5.4) can convert those tool findings into practical code improvements without introducing regressions. The report therefore compares common baseline branch with three isolated post-improvement branches and asks whether the same tools show measurable gains after the ChatGPT-guided changes.

1.4 Motivational Statement

The motivation behind this research is practical. Manual API hardening is time-consuming because a developer must read scanner output, identify the affected code path, understand the security or performance implication, implement a fix, run regression tests, and repeat the measurement. This loop is especially slow when the issue crosses layers such as controller authorization, service logic, Entity Framework queries, response headers, and test setup. ChatGPT may reduce this time by helping interpret tool findings and proposing fix candidates, but its output must still be validated because incorrect advice can create new security, performance, or maintainability problems.

1.5 Objectives, Measurements, and Outcomes

1.5.1 Objectives:

- To evaluate the impact of ChatGPT on the quality of ASP.NET Core API projects.
- To assess the performance impacts of AI-generated code through speed tests.
- To measure improvements in code security, reliability, and maintainability using **SonarQube**.
- To demonstrate how ChatGPT can solve security problems like **authentication** and **authorization** in RESTful APIs using AI-generated guidelines.

1.5.2 Measured Outcomes:

- A side-by-side before-and-after comparison of the API project following ChatGPT-guided code recommendations, using branch names, tool outputs, and measurement units for each comparison.
 - Code quality evidence from SonarQube, including C# finding count, Bugs, Vulnerabilities, Code Smells, Security Hotspots, coverage percentage, duplicated-line density percentage, and Quality Gate status.
 - Security evidence from OWASP ZAP, including High, Medium, Low, and Informational alert counts before and after improvements, plus role-based access-control checks for Admin, FinanceManager, User, and Auditor.
 - Performance evidence from Apache JMeter, including average response time, p95 and p99 latency in milliseconds, throughput in transactions per second, error rate percentage, and soak/spike drift percentage.
-

1.6 Limitations

The scope of this full report is limited to one ASP.NET Core financial accounting RESTful API and to ChatGPT (Codex 5.4) accessed through OpenAI's Codex coding environment. The study does not compare multiple AI assistants. The analysis focuses on automated static analysis, security scanning, and load testing; it does not evaluate user experience or developer productivity through a human-subject study. The findings therefore support conclusions about this API and this measurement workflow, not universal claims about all APIs or all LLMs.

Chapter 2 - Literature Review

Recent systematic reviews of LLMs in software engineering (Hou et al., 2024) show that existing research is dominated by code-generation studies, while the use of LLMs as advisors acting on reports from static analysers, security scanners, and load-testing tools is comparatively under-explored. This positions the present study within an under-represented quadrant of the LLM-for-SE literature.

2.1 The Impact of AI-generated Code on Web Development A Comparative Study of ChatGPT and GitHub Copilot

This study focuses on using ChatGPT and GitHub Copilot to generate complete websites. It reviews machine learning advancements in code generation. It highlights the limited prior studies on comparing AI tools for complete web applications involving multiple programming languages. The principal themes are: Generative AI models and their application in code synthesis; Key aspects of code quality: ease of use, accuracy, and maintainability; Ethical implications and societal impact of AI in web development. The methods are described as follows: Static analysis tools like SonarQube, ESLint, and Pylint for code evaluation; Experiments involved recreating wireframes for comparison. The reported findings are: Both tools can generate functional websites, though ChatGPT was rated as more user-friendly; The generated code had minor discrepancies in styling and functionality; AI tools are not yet advanced enough to fully replace developers for complex projects. The reported research gaps are: Insufficient exploration of AI performance in multi-language systems; Limited research on long-term code maintenance and security. The critical assessment is: The study underscores the potential of AI tools but also highlights their current limitations, such as bug generation and

security risks. This source is relevant to the thesis because this paper compares ChatGPT and GitHub Copilot in web development, focusing on the accuracy, ease of use, and maintainability of AI-generated code. The study's use of SonarQube to assess code quality provides insights into how ChatGPT can be applied to improve code security and performance, making it relevant to this research.

2.2 Methodology for Code Synthesis Evaluation of LLMs Presented by a Case Study of ChatGPT and Copilot

This study explores the methodology for evaluating large language models (LLMs) like ChatGPT and Copilot. It discusses the significance of understanding how developers choose tools for code generation. The principal themes are: Functional validity and technical quality in code synthesis; Impact of prompt engineering on LLM performance; Role of static analysis in measuring non-functional qualities like code security. The methods are described as follows: Benchmarked against 25 programming tasks using C++ and Java; Combined human review and static analysis for quality assessment. The reported findings are: ChatGPT performed better on average, generating more correct solutions than Copilot; Both tools displayed recurring code smells and vulnerabilities; Prompt engineering emerged as a critical factor influencing code quality. The reported research gaps are: Lack of research on real-world deployment challenges for AI-generated code; Limited studies exploring how complex tasks affect AI-generated code accuracy. The critical assessment is: Provides a robust methodology for evaluating LLM-generated code but suggests the need for dynamic testing and deployment-specific evaluations. This source is relevant to the thesis because this paper explores how ChatGPT improves software

development by generating code, detecting bugs, and automating tests. The focus on how ChatGPT enhances traditional development processes supports the research's aim to optimize API development using AI.

2.3 Artificial Intelligence-Based Tools

This study highlights the evolving role of AI in automating traditional software development processes. It reviews how tools like ChatGPT enhance workflows across design, coding, and testing. The principal themes are: Efficiency improvements through AI in software development cycles; The potential for AI tools to accelerate error detection and debugging; Ethical concerns, such as over-reliance on AI and security implications. The methods are described as follows: AI-driven processes were benchmarked against traditional methodologies; Observations from simulated projects and user feedback. The reported findings are: ChatGPT was effective in automating repetitive tasks and reducing development time; Simplified processes for non-specialist developers to engage in software projects. The reported research gaps are: Limited case studies on how AI integrates with advanced frameworks; Lack of large-scale evaluations across diverse industries. The critical assessment is: While demonstrating efficiency, the study underlines the risks of over-dependency on AI for critical functions, emphasizing the need for human oversight. This source is relevant to the thesis because this paper explores how ChatGPT improves software development by generating code, detecting

bugs, and automating tests. The focus on how ChatGPT enhances traditional development processes supports the research's aim to optimize API development using AI.

2.4 GPTutor

This study examines GPTutor, a plugin leveraging ChatGPT for code explanation and debugging. It highlights its focus on student and developer education. The principal themes are: Enhancing learning with AI-driven code explanation tools; Integration of natural language processing (NLP) into programming environments; Comparison of GPTutor's effectiveness with existing tools like Copilot. The methods are described as follows: Implementation as a Visual Studio Code extension using OpenAI's GPT-3.5 API; User interviews and experimental evaluations. The reported findings are: GPTutor provided concise and context-aware explanations of code; Developers found it intuitive and useful for understanding unfamiliar codebases. The reported research gaps are: Lack of real-world deployment data to validate GPTutor's performance in professional settings; Minimal studies on its integration with other educational platforms. The critical assessment is: Shows promise in improving developer education but requires further studies to explore its long-term applicability. This source is relevant to the thesis because this paper is highly relevant to this research on using ChatGPT to

generate and improve code, particularly in the context of explaining programming logic. GPTutor leverages ChatGPT to assist developers with real-time code explanations, which aligns with your objective of improving API development using ChatGPT for better security and performance.

2.5 Web APIs Features, Issues, and Expectations – A Large-Scale Empirical Study of Web

This study analyzes features, usability issues, and user expectations for web APIs based on empirical studies. The principal themes are: Factors influencing API adoption, such as documentation and SDK quality; Issues like outdated components and incomplete documentation; Developers' expectations for better error handling and performance optimization. The methods are described as follows: Survey responses from developers and analysis of Stack Overflow discussions; Evaluation of APIs from registries like Programmable Web. The reported findings are: Well-organized documentation is critical for API adoption; Security issues and limited functionality were common concerns. The reported research gaps are: Limited exploration of API usage in large-scale applications; Minimal studies on machine-learning-driven API enhancements. The critical assessment is: Demonstrates the importance of improving API usability but lacks insights into ML applications for automated API management. This source is relevant to the thesis because this empirical study provides a large-scale analysis of common issues and expectations in Web APIs, including security vulnerabilities, performance

bottlenecks, and developer expectations. These findings directly support this research on addressing similar API challenges using ChatGPT-generated improvements.

2.6 An Investigation into Misuse of Java Security APIs by Large Language Models

This study evaluates how LLMs like ChatGPT handle Java security APIs, focusing on misuse risks. The principal themes are: Common misuse patterns in security APIs; ChatGPT's limitations in implementing secure code due to its reliance on outdated examples. The methods are described as follows: Manual review and CryptoGuard for identifying misuse in 48 Java tasks. The reported findings are: Around 70% of ChatGPT-generated solutions had security API misuse; Developers need to provide highly specific prompts to mitigate misuse. The reported research gaps are: Limited studies on real-world usage of AI tools for secure coding; Absence of standardized datasets for API security evaluation. The critical assessment is: Highlights the potential of AI in secure development but stresses the importance of training on updated datasets. This source is relevant to the thesis because this paper assesses ChatGPT's reliability in generating secure code for Java security APIs, highlighting common misuse patterns. Its findings

on API misuse and limitations in automated detection align closely with my research goal of improving ASP.NET Core API security with ChatGPT-guided improvements, offering valuable insights into potential vulnerabilities and evaluation methods.

2.7 A New Approach to Web Application Security Utilizing GPT Language Models for Source Code Inspection

This study focuses on using GPT language models for static code analysis to detect vulnerabilities, specifically targeting CWE-653 (improper isolation of sensitive data). The principal themes are: Use of GPT models for identifying security vulnerabilities in web frameworks like Angular; Integration of AI for automating sensitive data protection and isolation checks; Challenges in using GPT models for context-specific vulnerability detection. The methods are described as follows: Analysis of open-source Angular applications using static code inspection; Categorization of sensitive data based on damage potential from leaks; Comparison of GPT-3.5 and GPT-4 for detecting and addressing vulnerabilities. The reported findings are: GPT models achieved an 88.76% detection success rate for CWE-653 vulnerabilities; Static code analysis combined with few-shot learning and chain-of-thought techniques enhanced detection accuracy; The models proved effective in mapping sensitive data paths and categorizing protection levels. The reported research gaps are: Insufficient real-world applications of the proposed methodology; Limited comparative studies on the performance of GPT against other advanced vulnerability detection tools. The critical assessment is: The study presents a compelling case for using GPT models in vulnerability detection, but it underscores the necessity of augmenting GPT outputs with human expertise for broader security scenarios. This source is

relevant to the thesis because this paper explores using GPT models for security inspection in web applications, like this study focuses on ChatGPT for enhancing RESTful API security. Its findings on detecting vulnerabilities like CWE-653 and categorizing sensitive data in web applications align well with research, providing insights into leveraging GPT models for automated code review, vulnerability detection, and the practical challenges of AI-assisted security improvements. This context helps justify the value of ChatGPT in identifying security flaws in ASP.NET Core APIs within this research.

2.8 Evaluating the Code Quality of AI-Assisted Code Generation Tools

This study compares GitHub Copilot, Amazon CodeWhisperer, and ChatGPT to assess their performance in generating reliable, secure, and maintainable code. The principal themes are: Analysis of AI-generated code quality metrics: correctness, security, maintainability, and reliability; Exploration of developer productivity and technical debt reduction using AI tools; Effects of docstrings and function signatures on AI-generated code quality. The methods are described as follows: Utilized the HumanEval dataset for benchmarking; Static analysis was performed using SonarQube for bugs, code smells, and security vulnerabilities. The reported findings are: ChatGPT excelled in correctness (65.2%) and maintainability, while Copilot had better IDE integration; Amazon CodeWhisperer performed best for tasks involving cloud service APIs; The average technical debt was lowest for Amazon CodeWhisperer but ChatGPT's explanations were more user-friendly. The reported research gaps are: Absence of comprehensive studies involving multi-language or highly complex codebases; Limited exploration of adaptive learning and feedback loops in AI systems. The critical assessment is: While AI tools show promise, the findings highlight challenges in scalability and real-world deployment, calling for

further research in enhancing AI's adaptive learning. This source is relevant to the thesis because this paper evaluates the code quality of AI-assisted generation tools, including ChatGPT, focusing on essential metrics such as code validity, correctness, security, reliability, and maintainability. Since my research involves using ChatGPT to improve security and performance in ASP.NET Core RESTful APIs, this study provides a valuable framework for assessing ChatGPT's code quality. The paper's empirical approach and use of SonarQube align with my methodology, offering insights into common issues with AI-generated code and suggesting best practices for achieving secure, maintainable, and efficient code with AI assistance.

2.9 Evaluation of Common Security Vulnerabilities of State Universities and Colleges Websites Based on OWASP

This study analyzes the security vulnerabilities in academic institution websites using OWASP's Top 10 guidelines, emphasizing the importance of web application security in digitalized educational services. The principal themes are: Frequent vulnerabilities in web applications, including SQL injection, misconfiguration, and broken access control; Using OWASP ZAP to identify and analyze security gaps; Importance of adopting OWASP standards to enhance website security. The methods are described as follows: Automated scanning of 17 academic websites using OWASP ZAP; Qualitative analysis of scan results based on the OWASP Top 10 categories. The reported findings are: 94.12% of websites were vulnerable to broken access control, and 88.24% showed security misconfigurations; Vulnerabilities often stem from outdated components and poor system design; ZAP proved effective in identifying critical issues,

including injection flaws and insecure designs. The reported research gaps are: Lack of studies on integrating AI-based tools to complement traditional scanners like ZAP; Minimal exploration of user training for maintaining secure web applications. The critical assessment is:

Demonstrates the utility of OWASP ZAP but underlines the need for proactive measures and advanced AI-driven solutions to mitigate vulnerabilities. This source is relevant to the thesis because this paper examines real-world security vulnerabilities in web systems using OWASP ZAP, aligning closely with this study focuses on securing RESTful APIs. The study provides insights into common security flaws (e.g., injection vulnerabilities, broken access control) in academic web platforms, which can parallel the types of vulnerabilities found in RESTful APIs. Additionally, their methodology using OWASP's Top 10 framework offers a structured approach to vulnerability assessment that I can apply to evaluate ChatGPT-driven security improvements in my APIs. This context supports the need for systematic, tool-assisted security evaluation in API development.

2.10 The Impact of AI on Developer Productivity Evidence from GitHub Copilot

This study evaluates GitHub Copilot's impact on developer productivity through a controlled experiment involving a task to build an HTTP server. The principal themes are: Productivity enhancements from AI pair programming; Heterogeneous effects of Copilot across skill levels and demographics; Comparison of traditional development workflows versus AI-assisted programming. The methods are described as follows: Controlled experiment using GitHub Classroom to track task completion times and correctness; Analysis of heterogeneous

effects based on participant demographics and experience. The reported findings are: Developers using Copilot completed tasks 55.8% faster on average than those in the control group; The tool benefitted less experienced developers the most, showcasing its potential for supporting novice programmers; Participants rated Copilot as significantly improving their productivity and willingness to adopt it in daily workflows. The reported research gaps are: Limited insights into the long-term adoption effects of AI tools on collaborative and large-scale software projects; Lack of focus on the ethical and licensing implications of using AI for code generation. The critical assessment is: Highlights Copilot's potential to accelerate software development but emphasizes the need for addressing ethical concerns and improving support for team-based projects. This source is relevant to the thesis because this paper is relevant to my research because it provides empirical evidence on the productivity gains achieved through AI-assisted coding tools, specifically GitHub Copilot, which is like ChatGPT in functionality. By highlighting the productivity boost and its impact on code development speed, the study offers a comparison point for evaluating ChatGPT's potential in improving API performance and security, supporting your investigation into the effectiveness of AI-driven development tools.

2.11 Asleep at the Keyboard? Assessing the Security of GitHub Copilot's Code Contributions

This study audits GitHub Copilot's code suggestions against security-relevant scenarios drawn from MITRE's list of the 25 most dangerous Common Weakness Enumerations (CWEs), focusing on whether AI-generated code introduces exploitable vulnerabilities rather than on functional correctness alone. The principal themes are: Security risks of AI pair-programming tools in everyday development workflows; Mapping of AI-generated vulnerabilities to standardised CWE categories; Trade-offs between generation diversity, prompt context, and

security outcomes. The methods are described as follows: 89 scenarios covering diversity of weaknesses, prompts, and application domains; CodeQL and manual inspection used to triage generated code against CWE criteria. The reported findings are: Roughly 40% of Copilot's generated programs across the evaluation scenarios contained security weaknesses; Copilot's output varied by language and weakness class, with C programs exhibiting a higher proportion of vulnerabilities than Python; Prompt wording and surrounding context materially influenced whether Copilot produced vulnerable or safe code. The reported research gaps are: Restricted to Copilot at a single point in time and to two languages (Python and C); behaviour on ASP.NET Core / C# is not characterised; No empirical link between flagged weaknesses and downstream exploitability in running applications. The critical assessment is: Provides one of the earliest systematic security audits of an AI code assistant and establishes that AI suggestions must be treated as untrusted input to a security-review process, not as trusted code. This source is relevant to the thesis because this paper directly motivates why the present study layers an independent security scanner (OWASP ZAP) on top of ChatGPT-generated recommendations. If AI-assistant output is empirically vulnerable in roughly 40% of cases on Copilot, a symmetric security-scan gate is necessary when evaluating ChatGPT-guided improvements on an ASP.NET Core financial API.

2.12 How Secure is Code Generated by ChatGPT?

This study evaluates the security properties of code produced by ChatGPT across several programming languages and realistic security-relevant tasks, extending the Copilot-centric security audits of Section 2.11 to the specific model family used in this thesis. The principal themes are: Security-aware prompt engineering versus default prompting; ChatGPT's awareness of vulnerabilities it has itself produced; Effect of follow-up prompts in driving ChatGPT to repair

unsafe code. The methods are described as follows: Prompt-driven generation across 21 tasks in five languages; Manual security inspection of each generated output. The reported findings are: Only a small minority of the generated programs were secure on the first attempt across the evaluated tasks; When explicitly challenged, ChatGPT was often capable of recognising and remediating the weakness, but did not proactively produce secure code by default; Security quality depended strongly on language and on whether the prompt explicitly asked for secure code. The reported research gaps are: Evaluation targets generation tasks and does not assess ChatGPT acting as an advisor on an already-existing code base; Limited coverage of web-framework-specific vulnerability classes such as missing security headers, broken RBAC, and JWT handling. The critical assessment is: Provides direct evidence that unfiltered ChatGPT output cannot be assumed secure, while also showing that iterative dialog with the model can materially raise the security bar. This is a key assumption behind the advisor-loop methodology used in this study. This source is relevant to the thesis because the present study uses ChatGPT (Codex 5.4) specifically as a remediation advisor on scanner findings. Khoury et al.'s finding that ChatGPT improves under follow-up prompting supports the four-phase workflow in Chapter 3, in which ZAP and SonarQube results are fed back to ChatGPT as structured prompts rather than open-ended requests to write secure code.

2.13 Lost at C: A User Study on the Security Implications of Large Language Model Code Assistants

This study conducts a controlled user study on whether access to an LLM-based code assistant causes developers to introduce more security vulnerabilities into their code than they would without one, complementing tool-only evaluations (Sections 2.11 and 2.12) with a human-factors perspective. The principal themes are: Participant-introduced vulnerabilities under LLM

assistance; Effect of AI suggestions on developer confidence and code-review effort; Interaction between developer experience level and AI-assistant outcomes. The methods are described as follows: Between-subjects user study with a programming task and AI assistant access as the treatment; Manual code-review coding of introduced vulnerabilities across participant submissions. The reported findings are: Access to an LLM code assistant did not produce a statistically significant increase in the number of security bugs relative to the unassisted control group in the tasks studied; Participants sometimes accepted AI suggestions uncritically but also rejected insecure suggestions, so the net security effect was small in this study design; The finding contrasts with simpler narratives that AI-generated code is inherently insecure, and highlights the role of the human in the loop. The reported research gaps are: Focuses on short, well-scoped C programming tasks rather than on maintaining a non-trivial production code base; Does not evaluate how developers interact with scanner output and an LLM assistant simultaneously, which is the specific workflow used in this thesis. The critical assessment is: Indicates that LLM assistants are neither an automatic security win nor an automatic security loss. Outcomes depend on task, developer, and review process, which supports using LLMs as advisors gated by automated measurement tools rather than as autonomous agents. This source is relevant to the thesis because this paper justifies the methodological choice in Chapter 3 to use ChatGPT only as an advisor whose recommendations are applied on an isolated Git branch and re-validated by the same scanner that surfaced the finding. This arrangement directly addresses the risk that a developer may accept an insecure AI suggestion, as flagged by Sandoval et al.

2.14 Large Language Models for Software Engineering: A Systematic

Literature Review

This study provides a broad Systematic Literature Review of the use of Large Language Models across the software-engineering life-cycle, synthesising a large corpus of primary studies spanning requirements, design, code generation, testing, and maintenance. The principal themes are: Taxonomy of LLM applications in software engineering by task, covering generation, review, repair, documentation, and testing; Model-family coverage, prompt-engineering practices, and dataset curation strategies; Reported strengths, weaknesses, and open research questions across the SE tasks surveyed. The methods are described as follows: Standard SLR protocol covering search-string design across major digital libraries, inclusion and exclusion criteria, quality assessment, and thematic synthesis. The reported findings are: The literature is dominated by code-generation studies, while code review, repair, and quality-advisory use cases are comparatively under-represented; Evaluation methodologies are heterogeneous, which makes cross-study comparison difficult; Security, performance, and maintainability are often studied in isolation rather than jointly. The reported research gaps are: Few primary studies evaluate LLMs as improvement advisors on an existing code base under combined static-analysis, security-scan, and load-test gates; Limited empirical work uses enterprise-style REST APIs as the unit of analysis. The critical assessment is: Positions the present thesis within the broader LLM-for-SE landscape and substantiates the claim in Chapter 1 that the existing literature emphasises generation quality while this study focuses on advisory quality on a fixed, pre-existing API. This source is relevant to the thesis because this study's combination of an existing non-trivial API, three independent quality dimensions measured with standard tools, and an LLM-as-advisor

framing addresses an empirically under-represented quadrant of the LLM-for-SE research space identified by Hou et al.

2.15 Are SonarQube Rules Inducing Bugs?

This study empirically investigates whether violations flagged by SonarQube rules are associated with bug-inducing code changes in real software projects, directly interrogating the validity of SonarQube-derived quality metrics as proxies for true software quality. The principal themes are: Distinction between rule violations and bug-inducing changes in version-controlled projects; Statistical association between SonarQube severity levels and defect rates; Implications for using static-analysis counts as quality-improvement evidence. The methods are described as follows: SZZ-style bug-linking analysis on 21 Apache projects; SonarQube scans combined with statistical correlation of rule violations to bug-inducing commits. The reported findings are: Only a minority of SonarQube rules show a statistically significant relationship with induced bugs, while many rules flag issues with little observed defect impact; Severity classifications assigned by SonarQube do not consistently align with empirical defect-inducing behaviour; Interpreting fewer SonarQube violations as fewer real bugs is therefore only partly warranted without corroborating evidence. The reported research gaps are: Analysis is restricted to a sample of open-source Apache projects; generalisation to proprietary enterprise code bases is not demonstrated; Does not evaluate SonarQube in combination with independent security scanners or load-test results, which is precisely the multi-instrument setting used in this thesis. The critical assessment is: Provides an important methodological caution: absolute SonarQube counts cannot, on their own, establish that code quality has improved. Cross-validation against independent tools such as dynamic scanners and load tests materially strengthens quality claims. This source is relevant to the thesis because this paper motivates the deliberately multi-

instrument design in Chapters 3 and 4. Reductions in SonarQube findings on the SonarQube remediation branch are interpreted alongside ZAP security outcomes (OWASP ZAP remediation branch) and JMeter performance results (JMeter remediation branch), explicitly acknowledging the Lenarduzzi et al. critique that SonarQube counts alone are a limited proxy for real-world quality.

Chapter 3: Proposed Methodology

This full report focuses on improving the security, performance, and code quality of one ASP.NET Core financial accounting RESTful API by using ChatGPT (Codex 5.4) as a code-improvement advisor. The API surface evaluated in the report includes authentication, user profile access, chart of accounts, journal entries, accounting periods, financial reports, and audit logs. The study compares common baseline branch with three isolated improvement branches: SonarQube remediation branch for code quality, OWASP ZAP remediation branch for security, and JMeter remediation branch for performance. The toolchain consists of SonarQube, OWASP ZAP, Apache JMeter, dotnet test, and Git branch-based comparison.

Why is it important?

This work is important because RESTful APIs are critical components in modern software systems, yet they often suffer from vulnerabilities such as SQL injection, missing security headers, weak authorization, and performance bottlenecks under load. Securing and optimizing these APIs is essential for protecting sensitive data and maintaining reliable service. This report demonstrates how ChatGPT can assist developers by interpreting tool findings and suggesting fixes, while the final acceptance decision remains based on repeatable measurements rather than trust in AI output alone.

Chapter overview. This chapter is organized into six subsections that together describe how the study will be carried out. Section 3.1 outlines the four-phase research workflow (baseline, ChatGPT-guided improvement, post-improvement testing, comparative analysis) and the per-tool branch isolation that ties every measured delta to a single tool. Section 3.2 describes the dataset

used as the test bed for security and performance evaluation. Section 3.3 lists the three measurement tools (SonarQube, Apache JMeter, OWASP ZAP) and the AI assistant (ChatGPT, Codex 5.4) that the study selects. Section 3.4 describes how ChatGPT-guided improvements are implemented on each branch. Section 3.5 details the testing phases applied before and after the improvements. Section 3.6 contrasts this study with related work along two axes: a single-API focus and a multi-tool combined evaluation framework.

Table 3.1. Four-phase workflow for baseline capture and branch-isolated remediation evidence.

Phase	Purpose	Evidence branch
1. Baseline capture	Run the v0.1 branch against SonarQube, OWASP ZAP, and JMeter before remediation.	common baseline branch
2. Static-code remediation	Apply maintainability and code-smell fixes, then preserve rule IDs and affected files for traceability.	SonarQube remediation branch
3. Security remediation	Move security headers ahead of Swagger/OpenAPI, update vulnerable Swagger	OWASP ZAP remediation branch

Phase	Purpose	Evidence branch
	dependencies, and reduce exposed UI surface.	
4. Performance remediation	Optimize report generation, account-ledger access, database indexes, caching, and compression, then rerun JMeter profiles.	JMeter remediation branch

This chapter is organized as an evidence-based remediation workflow rather than a tool checklist. The project first records a measurable baseline, then isolates static-analysis, security, and load-test fixes on separate branches so each improvement can be compared against the same starting point.

3.1.1 Testing Environment and Reproducibility

Table 3.2. Testing environment and reproducibility configuration.

Environment item	Value	Why it matters
API runtime	ASP.NET Core 8.0 Web API in Development mode	Application under test
Database	SQL Server local database named Financial	Repeatable local test data

Environment item	Value	Why it matters
Host	Windows 11 workstation	Same host used for baseline and fix-branch runs
Load test tool	Docker image justb4/jmeter:5.5	JMeter p50, p100, p500, soak, spike profiles
Security test tool	Docker image ghcr.io/zaproxy/zaproxy:stable	OWASP ZAP baseline and authenticated API scans
Branches compared	common baseline branch, SonarQube remediation branch, OWASP ZAP remediation branch, JMeter remediation branch	Controls before/after evidence

All comparisons were executed against the same ASP.NET Core 8.0 financial-accounting API and the local SQL Server Financial database on a Windows 11 host. This matters because the performance claims depend on keeping the runtime, database, and host constant while changing only the remediation branch.

JMeter was run through the Docker image justb4/jmeter:5.5, and OWASP ZAP was run through the stable container image ghcr.io/zaproxy/zaproxy:stable. The branch sequence used for comparison was common baseline branch, SonarQube remediation branch, OWASP ZAP remediation branch, and JMeter remediation branch.

The seeded dataset used 120 accounts, 30,000 journal entries, and at least 5,000 posted entries for report-generation paths. The primary authenticated roles were Admin,

FinanceManager, User, and Auditor, which allowed the tests to exercise both normal accounting workflows and protected administrative surfaces.

API area	Representative routes	Purpose in the study
Authentication	POST /auth/login	Obtain a JWT access token
User identity	GET /users/me; POST /users	Read the current identity; create users as an administrator
Accounts	GET /accounts; GET /accounts/{accountId}; GET /accounts/{accountId}/balance; POST /accounts; PUT /accounts/{accountId}	Browse and maintain the chart of accounts and inspect balances
Journal entries	GET /journal-entries; GET /journal-entries/{id}; POST /journal-entries; POST /journal-entries/bulk; POST /journal-entries/{id}/post; POST /journal-entries/{id}/reverse; DELETE /journal-entries/{id}	Create, review, post, reverse, and delete balanced entries
Accounting periods	GET /periods; POST /periods; POST /periods/{periodId}/close	Manage period creation and closure
Reports	GET /reports/trial-balance; GET /reports/profit-loss; GET /reports/balance-sheet; GET /reports/account-ledger	Generate the principal financial statements and account ledger
Audit logs	GET /audit-logs	Review traceable system actions

Issue categories used for comparison: security issues are grouped by OWASP ZAP risk level and vulnerability class such as missing security headers, vulnerable JavaScript library exposure, CORS/header hardening, SQL injection exposure, authentication behavior, and access-control behavior. Performance issues are grouped by endpoint and load profile, using average latency, p95/p99 latency in milliseconds, throughput in transactions per second, error rate percentage, soak drift, and spike recovery drift. Code-quality issues are grouped by SonarQube category, including Bugs, Vulnerabilities, Code Smells, Security Hotspots, Quality Gate status, coverage percentage, duplicated-line density, and specific rule IDs such as S125, S6966, S107, and S1192.

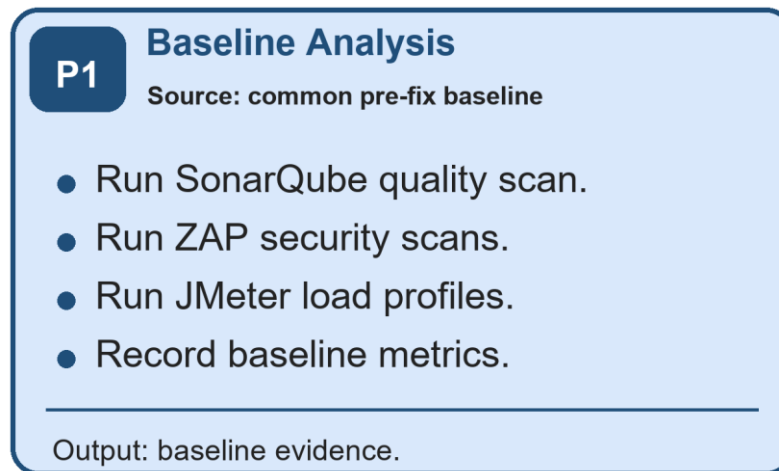


Figure 3.1. Phase 1 - Baseline analysis workflow.

- **Phase 1: Baseline Analysis**

- Initial security and performance testing are conducted on the financial accounting ASP.NET Core RESTful API project. The API includes endpoints for authentication, chart of accounts, journal entries, accounting periods, financial reports, and audit logs. These baseline metrics are captured on the common baseline branch and provide reference points for evaluating the effectiveness of improvements.
- Tools: SonarQube for code quality and static analysis, OWASP ZAP for security vulnerability scanning (baseline scan and authenticated API scan), and Apache JMeter for performance testing (load, soak, and spike test profiles at 50, 100, and 500 concurrent users).

Example:

- **Financial Accounting API: A complex RESTful API for financial accounting with multi-tier architecture (API, BAL/Services, MODEL/Entities, Tests).**

Workflow	Representative route	Example use
Accounts	GET /accounts	List the chart of accounts
Journal entries	POST /journal-entries	Create a balanced journal entry
Bulk journals	POST /journal-entries/bulk	Create a validated batch with finance-role authorization
Reports	GET /reports/trial-balance	Generate a trial-balance report

- **The API features role-based access control (Admin, FinanceManager, User, Auditor), JWT authentication, and comprehensive audit logging.**

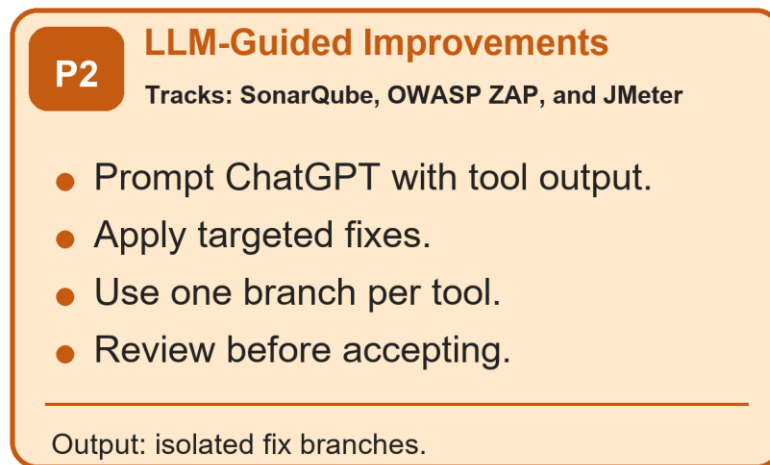


Figure 3.2. Phase 2 - LLM-guided improvements workflow.

- **Phase 2: ChatGPT-Generated Improvements**

- Code recommendations are generated using ChatGPT (Codex 5.4) through OpenAI's Codex coding environment. ChatGPT receives tool findings, relevant code snippets, and expected constraints, then suggests candidate fixes. The candidate fixes are not accepted automatically: each one is reviewed, applied on a dedicated branch, tested with dotnet test, and re-measured with the same tool that produced the baseline finding. This process explains why a recommendation is considered useful only when the after-measurement improves without breaking regression tests.
- Example Guidance from ChatGPT: Using parameterized queries to prevent SQL injection, improving loop efficiency, implementing secure session management.

Example:

Security Enhancement:

- Baseline Issue: Security and validation risk in write endpoints such as POST /journal-entries and POST /journal-entries/bulk, where untrusted input must not affect database query behavior or bypass authorization.
- ChatGPT Recommendation: preserve Entity Framework parameterization, validate DTO input, reject unauthorized roles, and keep write endpoints protected by JWT authentication and role policies.

Table 3.3. API endpoint coverage used for side-by-side security and performance evidence.

Category	Representative endpoints	Evidence source	Reviewer relevance
Authentication	/api/auth/register, /api/auth/login, /api/auth/me	ZAP authenticated scan, API smoke coverage	Role-aware access and token-protected flows
Users	/api/users, /api/users/{id}, /api/users/{id}/status	ZAP authenticated scan	Administrative user management
Accounts	/api/accounts, /api/accounts/{id}, /api/accounts/{id}/ledger	JMeter core and complex profiles	Ledger browsing and account-level reporting
Journal entries	/api/journalentries, /api/journalentries/{id}, /api/journalentries/post	JMeter bulk and query profiles	High-volume transaction workflow

Category	Representative endpoints	Evidence source	Reviewer relevance
Periods	/api/periods, /api/periods/{periodId}/close	API smoke coverage	Accounting period setup and close controls
Reports	/api/reports/trial-balance, /api/reports/profit-loss, /api/reports/balance-sheet	JMeter complex, soak, and spike profiles	Performance-critical financial reporting
Audit logs	/api/auditlogs	ZAP authenticated scan and manual role checks	Traceability for sensitive accounting actions

Performance Optimization:

- Baseline Issue: Slow p95 latency in report endpoints, especially GET /reports/trial-balance, GET /reports/profit-loss, GET /reports/balance-sheet, and GET /reports/account-ledger during spike and soak profiles.
- **ChatGPT Recommendation:** Implement caching for frequently accessed endpoints.
 - **Example Adjustment:** Use in-memory caching for the GET /reports endpoint to store results for 10 minutes:

Table 3.4. SonarQube code-quality remediation evidence by rule, file, and fix.

Rule or area	File	Before	After	Status
S107	JournalEntriesController.cs	Controller action used eight query parameters.	Introduced JournalEntryQueryDto and	Code smell removed

Rule or area	File	Before	After	Status
			passed one query model to the service.	
S2325	ServiceManager.cs	Private helper did not access instance state.	Converted helper to static.	Code smell removed
S3267/S6602	JournalEntryService.cs	Loops and LINQ operations were less maintainable.	Rewrote selected loops and lookup calls with clearer collection operations.	Code smell removed
S6966	Program.cs	Application startup used blocking Run.	Changed startup to await app.RunAsync().	Code smell removed
Fresh summary	C# project	17 unique issues; 17 legacy Code Smells.	0 issues; Quality Gate OK.	Closed

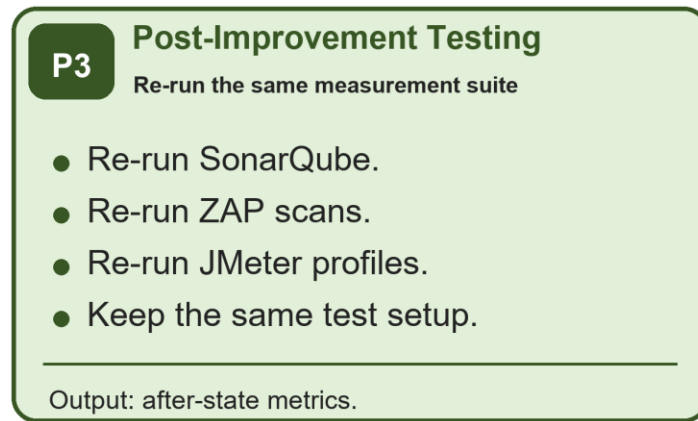


Figure 3.3. Phase 3 - Post-improvement testing workflow.

- **Phase 3: Post-Improvement Testing**

- With ChatGPT-guided changes implemented on each branch, the project undergoes a new round of testing using the same tools and configurations as the baseline. Security, performance, and code quality metrics are collected again and compared to the common baseline branch results.

Example:

- **Security: Run ZAP baseline scan and authenticated API scan against all endpoints (auth, accounts, journal-entries, periods, reports, audit-logs) on the OWASP ZAP remediation branch.**
- **Performance: Run JMeter test matrix (50, 100, 500 concurrent users + soak + spike profiles) against all API endpoints on the JMeter remediation branch.**

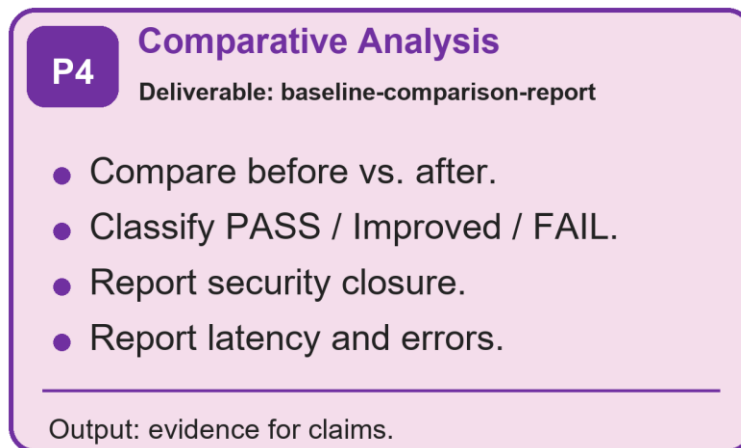


Figure 3.4. Phase 4 - Comparative analysis and reporting workflow.

• Phase 4: Comparative Analysis and Reporting

- The data collected from the baseline (common baseline branch) and post-improvement branches (SonarQube remediation branch, OWASP ZAP remediation branch, JMeter remediation branch) are analyzed and compared to draw conclusions on ChatGPT’s effectiveness in enhancing the security, performance, and code quality of the financial accounting RESTful API. Results are compiled into a baseline-comparison-report documenting improvements across all three dimensions. Appendices A-N provide the environment, exact branch and commit provenance, twenty curated source-code listings, reproduction automation, dashboards, traceability, and limitations directly in this full report.

Table 3.5. OWASP ZAP before-and-after security evidence.

Scan	Severity	Before -> After	Vulnerability class	Fix applied
Passive baseline scan	Medium	3 -> 0	Security-header and browser-facing configuration alerts.	Header middleware and Swagger hardening cleared the raw Medium alerts.
Passive baseline scan	Low	6 -> 0	Missing hardening and isolation headers.	Added and consistently applied response-security headers.
Authenticated API scan	Medium	1 -> 1	HTTP Only Site (CWE-311) on the local HTTP test transport.	Disclosed as a residual environment observation; not reported as cleared.

Scan	Severity	Before -> After	Vulnerability class	Fix applied
Authenticated API scan	Low	3 -> 0	Authenticated endpoint hardening findings.	Same middleware path protects authenticated API responses.
Configured gate	Result	PASS_CONFIGURED_RULES -> PASS_CONFIGURED_RULES	Configured business-endpoint rule set.	Gate passed, but raw Medium transport observation remains visible.

Table 3.6. JMeter before-and-after performance profile comparison.

Profile	Metric	Baseline	After fixes	Change	Status
p50	Total p95 response time	33.00 ms	199.90 ms	+505.8%	Regression
p100	Total p95 response time	255.90 ms	1146.90 ms	+348.2%	FAIL
p500	Total p95 response time	106.00 ms	1547.95 ms	+1360.3%	FAIL
soak	Total p95 response time	443.95 ms	171.00 ms	-61.5%	Improved
spike	Total p95 response time	33401.75 ms	4730.85 ms	-85.8%	Improved
Core gate	Threshold result	PASS	FAIL	p100 and p500 exceeded thresholds	NOT ACHIEVED

Table 3.7. Selected before-and-after code evidence linked to reviewer comments.

Example	Before branch	Before code	After branch	After code	Reason
SonarQu be maintain ability	common baseline branch	public async Task<IActionResult> GetPaged(DateTime? from, DateTime? to, string? status, int? accountId, string? search, int page = 1, int pageSize = 20, string? sort = "entryDate_desc")	SonarQub e remediati on branch	public async Task<IActionResult> GetPaged([FromQuery] JournalEntryQueryDto query)	Replaced eight query parameters with one DTO, directly addressing S107.
ZAP security headers	common baseline branch	app.UseSwagger(); app.UseSwaggerUI(); ... app.UseMiddleware<SecurityHeadersMiddleware>();	OWASP ZAP remediati on branch	app.UseMiddleware<SecurityHeadersMiddleware>(); ... if (enableSwaggerDocument) app.UseSwagger(); if (enableSwaggerUi) app.UseSwaggerUI();	Ensures Swagger/OpenAPI responses receive the same hardening headers and

					separates the UI switch from the JSON document.
JMeter report performance	common baseline branch	await _context.Reports.AddAsync(report); await _context.SaveChangesAsync();	JMeter remediation branch	await _auditLogService.WriteAsync(actorUserId, "GENERATE_REPO_RT", "Reports", \$"{reportType}:{periodId}", ipAddress, new { reportType, periodId, items = items.Count });	Removed report snapshot write amplification from read-heavy report generation.

3.1.2 Selected Source-Code Evidence

The following excerpts are real source-code evidence from the compared Git branches. They are intentionally selected examples rather than full-file listings, because the purpose is to show how the measured SonarQube, ZAP, and JMeter improvements map back to concrete code changes.

Source-code evidence A: SonarQube maintainability fix in API/Controllers/JournalEntriesController.cs.

Before: common baseline branch

```
[HttpGet]
public async Task<IActionResult> GetPaged(
    [FromQuery] DateTime? from,
    [FromQuery] DateTime? to,
    [FromQuery] string? status,
    [FromQuery] int? accountId,
    [FromQuery] string? search,
    [FromQuery] int page = 1,
    [FromQuery] int pageSize = 20,
    [FromQuery] string? sort = "entryDate_desc")
{
    var result = await _journalEntryService.GetPagedAsync(from, to, status,
accountId, search, page, pageSize, sort);
    return Ok(result);
}
```

After: SonarQube remediation branch

```
[HttpGet]
public async Task<IActionResult> GetPaged([FromQuery] JournalEntryQueryDto query)
{
    var result = await _journalEntryService.GetPagedAsync(query);
    return Ok(result);
}
```

This excerpt addresses the SonarQube maintainability issue by replacing a long query-parameter list with a single JournalEntryQueryDto request model.

Source-code evidence B: OWASP ZAP security-header fix in API/Program.cs.

Before: common baseline branch

```
var enableSwagger = app.Environment.IsDevelopment() ||
appSettings.EnableSwaggerInProduction;
if (enableSwagger)
{
    app.UseSwagger();
    app.UseSwaggerUI();
}

app.UseMiddleware<CorrelationIdMiddleware>();
app.UseMiddleware<GlobalExceptionMiddleware>();
app.UseMiddleware<SecurityHeadersMiddleware>();
```

After: OWASP ZAP remediation branch

```
app.UseMiddleware<CorrelationIdMiddleware>();
app.UseMiddleware<GlobalExceptionMiddleware>();
app.UseMiddleware<SecurityHeadersMiddleware>();

var enableSwaggerDocument = app.Environment.IsDevelopment() ||
appSettings.EnableSwaggerInProduction;
var enableSwaggerUi = enableSwaggerDocument && appSettings.EnableSwaggerUi;
if (enableSwaggerDocument)
{
    app.UseSwagger();
}

if (enableSwaggerUi)
{
    app.UseSwaggerUI();
}
```

This excerpt shows that the security-header middleware was moved before Swagger/OpenAPI middleware, so diagnostic responses receive the same hardening headers as API responses.

Source-code evidence C: JMeter performance fix in BAL/Services/FinancialReportService.cs.

Before: common baseline branch

```
private async Task PersistReportAsync(
    string reportType,
    int periodId,
    Guid actorUserId,
    string? ipAddress,
    List<ReportItemDto> items)
{
    var report = new FinancialReport
    {
        ReportType = reportType,
        PeriodId = periodId,
        GeneratedByUserId = actorUserId,
        GeneratedAt = DateTime.UtcNow
    };

    foreach (var item in items)
    {
        report.ReportItems.Add(new FinancialReportItem
        {
            AccountId = item.AccountId,
            DebitTotal = decimal.Round(item.DebitTotal, 2),
            CreditTotal = decimal.Round(item.CreditTotal, 2),
            Balance = decimal.Round(item.Balance, 2)
        });
    }

    await _context.Reports.AddAsync(report);
    await _context.SaveChangesAsync();
}
```

After: JMeter remediation branch

```
public async Task<AccountLedgerPayload> GetAccountLedgerPayloadAsync(int
accountId, int periodId, Guid actorUserId, string? ipAddress)
{
    var period = await GetPeriodOrThrowAsync(periodId);
    var account = await
_context.ChartOfAccounts.AsNoTracking().FirstOrDefaultAsync(x => x.AccountId ==
accountId);

    var payload = await _accountLedgerCache.GetOrCreatePayloadAsync(
        accountId,
        periodId,
        account.AccountType,
        period.StartDate,
        period.EndDate,
        () => BuildAccountLedgerPayloadAsync(accountId, period, account));

    await PersistReportAsync("Ledger", periodId, actorUserId, ipAddress, new
List<ReportItemDto> { ... });
    return payload;
}
```

```
private async Task PersistReportAsync(string reportType, int periodId, Guid
actorUserId, string? ipAddress, List<ReportItemDto> items)
{
    await _auditLogService.WriteAsync(
        actorUserId,
        "GENERATE_REPORT",
        "Reports",
        $"{reportType}:{periodId}",
        ipAddress,
        new { reportType, periodId, items = items.Count });
}
```

This excerpt shows the core performance change: report generation no longer persists full report snapshots during read-heavy paths, and account-ledger output can be served from the new cache-backed payload path while preserving audit logging.

3.1.3 Prompt-Template Evidence and Reproducibility

The remediation prompts used the same three-part structure across SonarQube, OWASP ZAP, and JMeter findings. This makes the LLM interaction auditable: the tool report states the measurable problem, the code excerpt bounds the editable context, and the instruction constrains the model to a minimal patch that must be re-tested.

Table 3.8. Prompt-template traceability used in remediation runs.

Prompt component	Content used in this study	Purpose
Context	Native tool finding: SonarQube rule id, ZAP alert metadata, or JMeter endpoint latency profile.	Anchors the model to a measured defect or hotspot.
Code excerpt	Smallest affected controller, service, middleware, configuration, or test block.	Prevents broad rewrites and keeps the proposed patch reviewable.

Prompt component	Content used in this study	Purpose
Instruction	Propose a minimal patch that keeps existing tests green, avoids new dependencies unless justified, and states how to re-measure the result.	Turns the LLM output into an auditable repair proposal rather than an accepted change.

3.1.4 Human-Effort Traceability

The following table records how much human intervention was required before a candidate fix was accepted. The important point is that ChatGPT supplied advice, but the acceptance gate was the developer review plus the same measurement tool that produced the original finding.

Table 3.9. Human-effort traceability for accepted remediation fixes.

Fix class	Evidence branch	LLM rounds	Human intervention	Acceptance evidence
SonarQube controller DTO refactor	SonarQube remediation branch	1	Reviewed route compatibility and service-layer signature.	Fresh issues reduced from 17 to 0; Quality Gate remained OK.
Security headers and Swagger hardening	OWASP ZAP remediation branch	1-2	Moved middleware order, split Swagger document/UI switches, reviewed package upgrade.	Configured gate passed; raw API HTTP Only Site Medium remained.
ARM/camelCase analyzer cleanup	SonarQube remediation branch	2-3	Manually corrected provider-specific conventions after initial model output was insufficient.	Fresh remediation scan reported 0 issues.
Report-performance remediation	JMeter remediation branch	1-2	Reviewed cache/audit tradeoff and removed read-path report snapshot writes.	Fresh p100 and p500 p95 exceeded thresholds; core gate failed.
Stress-profile interpretation	JMeter remediation branch	Human review	Separated aggregate totals from endpoint-level and core-threshold behavior.	Soak and spike aggregate p95 improved, but this did not offset the failed core gate.

3.2 Dataset Description and Preparation

This study does not use production customer records or a public financial dataset. The data used in the tests is a repo-seeded financial accounting test dataset generated by scripts/phase4/seed-test-data.ps1 and loaded into the local SQL Server Financial database. This makes the dataset repeatable and auditable from the repository while avoiding confidentiality risk.

The seed configuration is deterministic in its parameters and naming patterns, including PeriodId 202601, 120 chart-of-account records, 30,000 journal entries, and at least 5,000 posted entries. Runtime-generated values such as GUID user IDs, password salts and hashes, timestamps, and identity values may differ between database runs, so the examples below show representative records based on the repo seed rules rather than private production rows.

Table 3.10. Repo-seeded test-data configuration.

Seed item	Repo-backed value	Purpose in the study
Script	scripts/phase4/seed-test-data.ps1	Source of the repeatable test-data generation process
Database target	SQL Server database: Financial	Same local database target used for security and performance tests
Accounting period	PeriodId 202601; 2026-01-01 to 2026-12-31	Period-sensitive report endpoints use this range
Accounts	AccountCount = 120	Ensures all five account types are available for ledger and report paths

Seed item	Repo-backed value	Purpose in the study
Journal entries	JournalEntryCount = 30,000	Creates enough volume for load, soak, and spike tests
Posted entries	MinimumPostedEntries = 5,000	Ensures report endpoints have posted transactions to aggregate
Admin credential	Local demo administrator credential (value omitted)	Used by JMeter and ZAP scripts for authenticated test setup

The dataset is used to test API behavior, not to make claims about real financial performance. Its purpose is to exercise authentication, authorization, accounting-period logic, balanced journal entries, financial-report aggregation, and audit logging under repeatable security and load-test conditions.

Table 3.11. Seeded entity coverage for the API behavior under test.

Entity	Repo-backed seeded or generated data	How it is produced	API behavior tested
Roles	Admin, User, Auditor, FinanceManager	Inserted if missing	RBAC and authenticated API scans
Users	Admin user plus probe users created by test scripts	Upserted or created with GUID UserId	Login, role-boundary, and audit-log tests

Entity	Repo-backed seeded or generated data	How it is produced	API behavior tested
ChartOfAccounts	A/L/E/R/X account-code prefixes; Asset, Liability, Equity, Revenue, Expense	Generated until target account count is reached	Ledger and financial-report calculations
AccountingPeriods	PeriodId 202601	Inserted or reset to open state	Trial balance, profit/loss, balance sheet, account ledger
JournalEntries	SEED-P and SEED-D reference numbers	Generated as posted and draft entries	Posting, bulk, report, and performance paths
JournalEntryLines	Balanced debit and credit lines	Generated for every seeded journal entry	Double-entry accounting validation
AuditLogs	LOGIN, CREATE_USER, CREATE_ACCOUNT, POST_ENTRY, GENERATE_REPORT, etc.	Written by application services during tests	Traceability and Auditor role checks

Accounts sample

Financial database | 257 source rows | read-only sample query

AccountCode	AccountName	AccountType	Active
1000	Cash	Asset	Yes
2000	Accounts Payable	Liability	Yes
3000	Owner Equity	Equity	Yes
4000	Sales Revenue	Revenue	Yes
5000	Operating Expense	Expense	Yes
A000001	Seed Asset 000001	Asset	Yes

Synthetic seeded data. Credentials, password fields, IP addresses, and raw audit JSON are excluded.

Figure 3.5. Representative chart-of-accounts rows from the live seeded database.

Users and roles sample

Financial database | 30 source rows | read-only sample query

Username	RoleName	Active
admin	Admin	Yes
zap-auditor-20260219164147924	Auditor	Yes
admin	FinanceManager	Yes
zap-user-20260219163958652	User	Yes

Synthetic seeded data. Credentials, password fields, IP addresses, and raw audit JSON are excluded.

Figure 3.6. Representative users and role assignments from the live seeded database.

Journal entries and balanced lines						
Financial database 48,902 source rows read-only sample query						
EntryId	EntryDate	ReferenceNo	Status	AccountCode	Debit	Credit
145491	2026-01-15	JM-BULK-124-3000	Draft	1000	100.0	0.0
145491	2026-01-15	JM-BULK-124-3000	Draft	1000	0.0	100.0
145490	2026-01-15	JM-BULK-129-2999	Draft	1000	100.0	0.0
145490	2026-01-15	JM-BULK-129-2999	Draft	1000	0.0	100.0
145489	2026-01-15	JM-BULK-124-2998	Draft	1000	100.0	0.0
145489	2026-01-15	JM-BULK-124-2998	Draft	1000	0.0	100.0

Synthetic seeded data. Credentials, password fields, IP addresses, and raw audit JSON are excluded.

Figure 3.7. Representative journal entries and balanced debit-credit lines.

Accounting periods sample			
Financial database 3 source rows read-only sample query			
PeriodId	StartDate	EndDate	Closed
202601	2026-01-01	2026-12-31	No
202700	2027-01-01	2027-12-31	No
209258	2099-01-01	2099-01-31	Yes

Synthetic seeded data. Credentials, password fields, IP addresses, and raw audit JSON are excluded.

Figure 3.8. Representative accounting-period rows from the live seeded database.

Derived trial-balance sample				
Financial database 98,055 source rows read-only sample query				
AccountCode	AccountName	DebitTotal	CreditTotal	Balance
1000	Cash	442477.16	10.0	442467.16
2000	Accounts Payable	10.0	216446.14	-216436.14
3000	Owner Equity	0.0	226031.02	-226031.02
4000	Sales Revenue	0.0	215634.15	-215634.15
5000	Operating Expense	215634.15	0.0	215634.15
A001000	Cash - Operating Account	1524800.0	961306.92	563493.08

Synthetic seeded data. Credentials, password fields, IP addresses, and raw audit JSON are excluded.

Figure 3.9. Trial-balance sample derived from posted journal-entry lines.

Audit-log sample			
Financial database 207,813 source rows read-only sample query			
Action	EntityName	EntityId	Timestamp
GENERATE_REPORT	Reports	Ledger:202601	2026-07-19 14:26:11
GENERATE_REPORT	Reports	BalanceSheet:202601	2026-07-19 14:26:10
GENERATE_REPORT	Reports	Ledger:202601	2026-07-19 14:26:10
GENERATE_REPORT	Reports	ProfitLoss:202601	2026-07-19 14:26:10
GENERATE_REPORT	Reports	BalanceSheet:202601	2026-07-19 14:26:10
GENERATE_REPORT	Reports	TrialBalance:202601	2026-07-19 14:26:10

Synthetic seeded data. Credentials, password fields, IP addresses, and raw audit JSON are excluded.

Figure 3.10. Representative audit-log rows from report-generation workflows.

Therefore, the study evaluates the financial accounting API and its code paths using repeatable repo-backed test data. The dataset is realistic enough to trigger the same endpoint behavior as financial records, but it is not real customer data and should not be interpreted as a production financial dataset.

3.3 Model and Tool Selection

This research employs a combination of tools to evaluate different aspects of code security, performance, and quality. ChatGPT (Codex 5.4), accessed through OpenAI's Codex coding environment, serves as the AI assistant for generating code improvement recommendations

throughout this study. The model is used as an advisor, not as an unsupervised implementation authority.

- **What is SonarQube and why we focus on it?** SonarQube is an open-source static-analysis platform that scans source code for bugs (probable defects), vulnerabilities (known security weaknesses), code smells (maintainability issues), security hotspots (suspicious patterns flagged for manual review), test coverage, and code duplication. Findings are emitted with rule identifiers (e.g., S125, S6966), severity levels, and human-readable remediation guidance. This study targets the static-quality dimension because code bases of any age accumulate code smells faster than they accumulate bugs, and removing rule-by-rule findings without regressions is one of the chief reasons a quality dashboard moves from red to green. The metrics reported in later chapters (Bugs, Vulnerabilities, Code Smells, Security Hotspots, Coverage %, Duplicated lines %, and Quality Gate pass/fail) all originate from SonarQube and are interpreted in the order listed.
- **SonarQube (Community Edition):** Used for assessing code quality and security vulnerabilities by scanning the .NET codebase for bugs, code smells, and security vulnerabilities. Runs via dotnet-sonarscanner with unit and integration test coverage analysis. Because prior empirical work has questioned how closely SonarQube rule violations align with bug-inducing changes in real projects (Lenarduzzi et al., 2020), SonarQube results in this study are always interpreted jointly with independent ZAP and JMeter measurements rather than in isolation.
- **What is Apache JMeter and why we focus on it?** Apache JMeter is a load-testing tool that simulates concurrent virtual users (VUs) issuing HTTP requests according to a configurable plan. For each request it records latency (response time), throughput (transactions per second), and error rate (HTTP 4xx/5xx responses). Test plans can hold load constant, sustain it for a soak

window, or burst it for a spike, and JMeter aggregates the resulting event log into per-endpoint percentiles. This study targets the load-performance dimension because static analysis and security scanning cannot tell whether the API will keep responding under realistic load; p95 latency and error rate under load are the primary user-facing quality signals that determine whether an SLA is met. The metrics reported in later chapters (p95, p99, throughput, error rate) all come from JMeter, with the gate threshold pre-registered.

- **Apache JMeter:** Measures performance metrics such as response times, throughput, and error rates across multiple load profiles (50, 100, 500 concurrent users), soak testing, and spike testing. Test plans target all API endpoints including authentication, CRUD operations, and reporting.
- **What is OWASP ZAP and why we focus on it?** OWASP Zed Attack Proxy (ZAP) is a free, open-source dynamic application security testing (DAST) tool. It performs a passive baseline scan that observes responses to crawled requests for missing security headers, cookie problems, and known-vulnerable bundled JavaScript libraries; and an active API scan that, given an OpenAPI definition and a valid authentication token, exercises every endpoint and probes for OWASP Top-10-style flaws. Findings are emitted by risk level: High, Medium, Low, and Informational. This study targets the security dimension because APIs in financial domains are routinely targeted, and a vulnerability that survives into production can cost more than the entire engineering budget to remediate. The alert counts reported in later chapters are categorized by these four risk levels, and the pre-registered gate is that no High, Medium, or Low alert remains on a business endpoint after fixes.
- **OWASP ZAP: Provides comprehensive vulnerability scanning through baseline scans (passive analysis of all endpoints) and authenticated API scans (active testing with JWT**

tokens and role-based access). Custom rule configurations are maintained in TSV files for reproducible scan profiles.

3.4 Implementation of ChatGPT-Guided Improvements

After baseline testing, ChatGPT (Codex 5.4) is used to generate improvement suggestions. Key areas of focus include:

- **Security Enhancements**

- ChatGPT offers guidance on preventing SQL injection by implementing parameterized queries, managing session data securely, and sanitizing inputs.
- Example Adjustments: Integrating secure authentication protocols, using encryption for sensitive data, and adjusting HTTP headers to prevent common attacks like cross-site scripting (XSS).

- **Performance Optimizations**

- ChatGPT suggestions for performance optimization may include improvements to data handling, optimizing API response time by limiting unnecessary queries, and using caching mechanisms for frequently accessed resources.
- Example Adjustments: Refining data-fetching algorithms, implementing pagination, and managing connection pooling.

3.5 Testing Phases

The same financial accounting API undergoes two testing phases: initial testing on common baseline branch and post-improvement testing on the relevant improvement branch. The study does not compare many unrelated APIs; instead, it evaluates seven endpoint groups inside one API so that the before-and-after results are attributable to controlled changes.

- **Baseline Testing:** The initial state of the financial accounting API is tested for security (ZAP baseline + API scan), performance (JMeter load/soak/spike), and code quality (SonarQube). Results are captured on the common baseline branch.
- **Post-Improvement Testing:** After implementing ChatGPT's improvements on dedicated branches (SonarQube remediation branch, OWASP ZAP remediation branch, JMeter remediation branch), each branch is re-tested with the same tool and configuration to assess the efficacy of the changes. All issues and fixes are documented in per-tool fix tracking documents.

3.6 How is it different from others research?

1. **Focus on ChatGPT:** Unlike studies that compare multiple AI tools, this work focuses on ChatGPT (Codex 5.4) as an improvement advisor for one ASP.NET Core RESTful API.

The depth comes from measuring one API across security, performance, and code quality rather than from comparing many models superficially.

2. **Combination of Security and Performance Testing:** This study integrates both security (OWASP ZAP) and performance (Apache JMeter) testing in a single workflow, which is less commonly addressed together in similar research.
 3. **Realistic API Test Data:** The study uses seeded and generated financial accounting records to simulate realistic accounting operations without using live customer data. The evaluation target is the API behavior and codebase, not a public financial dataset.
 4. **Production-Complexity API Surface:** The report focuses on one API with multiple endpoint categories, role-based access control, bulk journal-entry operations, report generation, and audit logging. This provides enough complexity to test whether ChatGPT-guided changes hold across different API responsibilities.
-

3.7 Security Evaluation Plan

The security evaluation plan focuses on using OWASP ZAP for comprehensive testing.

- **Vulnerability Scanning:** OWASP ZAP performs both baseline (passive) and authenticated API (active) scans across all endpoints: /auth, /accounts, /journal-entries, /periods, /reports, and /audit-logs. Focus areas include injection flaws, broken authentication, missing security headers (CSP, X-Content-Type-Options, CORS), and vulnerable dependencies.
 - **Authentication and Authorization Testing:** OWASP ZAP authenticated API scan is used to test role-based access control (Admin, FinanceManager, User, Auditor roles) and JWT authentication. Unauthorized access attempts against protected endpoints (e.g., POST /accounts, POST /periods/{id}/close, DELETE /journal-entries/{id}) verify the robustness of the API's access control.
 - **Comparison of Pre- and Post-Improvement Results:** Security test results from common baseline branch and OWASP ZAP remediation branches are compared, analyzing how ChatGPT (Codex 5.4)'s recommendations mitigated identified vulnerabilities. Alert counts are compared by severity level (High, Medium, Low, Informational).
-

3.8 Performance Evaluation Plan

Performance testing is conducted with Apache JMeter to simulate multiple concurrent users accessing the API.

- **Response Time and Throughput:** Apache JMeter measures response times (average, p95, p99) and throughput for each API endpoint under load profiles of 50, 100, and 500 concurrent users, plus soak (sustained load) and spike (burst) test profiles.
 - **Resource Utilization:** CPU and memory usage are tracked during load tests. Error rates are monitored to identify endpoints that fail under stress.
 - **Comparison of Performance Metrics:** Results from common baseline branch and JMeter remediation branches are compared to determine the impact of ChatGPT (Codex 5.4)'s suggestions on performance, focusing on improvements in response times, error rate reduction, throughput gains, and stability under sustained and spike load conditions.
-

3.9 Code Quality Evaluation Plan

Code quality is assessed using SonarQube, focusing on key metrics such as code smells, maintainability, and cyclomatic complexity.

- **Baseline Analysis:** The initial codebase on common baseline branch is scanned with SonarQube (via dotnet-sonarscanner) to identify code smells, potential bugs, security vulnerabilities, and security hotspots across all five modules (API, BAL, MODEL, REPOSITORY, Tests).
 - **Post-Improvement Analysis:** After applying ChatGPT (Codex 5.4)'s recommendations on SonarQube remediation branch, SonarQube is run again with the same configuration to evaluate improvements. This second analysis identifies reductions in bugs, code smells, security vulnerabilities, and security hotspots. Quality gate status is compared.
 - **Clean Code Principles:** Changes are analyzed based on adherence to clean code principles like simplicity, readability, and minimized dependencies. To mitigate the known limitation that not every SonarQube rule correlates with real defects (Lenarduzzi et al., 2020), quality-gate conclusions are cross-referenced with the ZAP and JMeter outcomes on their respective branches, so that a SonarQube improvement is only claimed when at least one other independent measurement is consistent with it.
-

Chapter 4: Results and Discussion

4.1 Evaluation Criteria and Decision Rules

Decision rule. In this report, a result is judged successful rather than simply called good when the post-improvement branch meets the predefined acceptance target and shows no critical regression in the associated control metrics. An outcome is classified as Achieved when the complete target is met, Partially Achieved when the primary metric improves but a stated secondary condition or limitation remains, and Not Achieved when the target is missed or a material regression is introduced. Sections 4.2-4.5 apply this rule to the measured code-quality, security, and performance evidence.

- **Security Metrics:** The security of the API is evaluated with OWASP ZAP baseline and authenticated API scans. The endpoint groups tested include /auth, /accounts, /journal-entries, /periods, /reports, and /audit-logs. Findings are compared before and after improvement by severity level (High, Medium, Low, Informational) and by vulnerability class, including missing security headers, vulnerable dependency exposure, authentication behavior, authorization behavior, SQL injection exposure, and sensitive-data-in-URL observations.
- **Performance Metrics:** Performance is evaluated with Apache JMeter against the same endpoint groups under p50, p100, p500, soak, and spike profiles. Metrics include average response time, p95 latency, p99 latency in milliseconds, throughput in transactions per second, error rate percentage, soak drift percentage, and spike recovery drift percentage.
- **Code Quality Metrics:** Code quality is evaluated with SonarQube across the API, BAL, MODEL, REPOSITORY, and Tests modules. Metrics include Bugs, Vulnerabilities, Code

Smells, Security Hotspots, Quality Gate status, coverage percentage, duplicated-line density, cyclomatic complexity indicators, and specific issue/rule IDs before and after the ChatGPT-guided branch.

Table 4.1. Evaluation criteria used to judge full-report remediation success.

Evaluation area	Measure	Acceptance target	Result
Static analysis	SonarQube fresh issues and Quality Gate	No retained blocker/critical issues after fixes; preserve Quality Gate OK	17 unique issues reduced to 0; Quality Gate OK; coverage 74.4% -> 74.3%
Security	OWASP ZAP raw alerts and configured gate	Clear actionable configured-rule alerts and disclose residual observations	Configured gate passed; passive M3/L6 -> M0/L0; API M1/L3 -> M1/L0
Performance	JMeter p95, throughput, error rate, and gate	p50/p100/p500 pass with no material latency regression	Remediation core gate FAIL; p100 and p500 exceeded thresholds
Maintainability	Representative before/after code evidence	Selected code smells resolved with traceable branch evidence	DTO, middleware-order, and report-persistence examples documented

The evaluation compares baseline and remediated branches using the same toolchain and dataset described in Chapter 3. The purpose is not only to show that numbers improved, but also to connect each improvement to a concrete code or configuration change that can be reviewed and repeated.

Explanation: Figure (4.1) summarizes the evaluation criteria and shows that each dimension is measured twice: once on common baseline branch and once on the matching post-improvement branch.

4.2 Code-Quality Outcome

Code-quality comparison units: fresh unique issue count, legacy issue type, SonarQube MQR software-quality impacts, rule ID, affected file, Quality Gate status, coverage percentage, duplicated-line density, and complexity. Legacy Bugs/Vulnerabilities/Code Smells and MQR

Reliability/Security/Maintainability impacts are reported separately because the MQR impacts are non-exclusive and must not be summed as unique issues.

Observed fresh SonarQube result: 17 unique baseline issues decreased to 0. Under the legacy type metrics, Bugs stayed at 0, Vulnerabilities stayed at 0, Code Smells decreased from 17 to 0, and Security Hotspots stayed at 0. Under MQR impact classification, the baseline issues carried 2 Reliability, 1 Security, and 16 Maintainability impacts; these overlapping impact counts all fell to 0 after remediation. The Quality Gate remained OK, coverage changed from 74.4% to 74.3%, and duplicated-line density remained 0.0%.

Table 4.2. SonarQube before-and-after quality metrics.

Metric	Baseline	After fixes	Interpretation
Total unique issues	17	0	All fresh baseline issues closed
Code smells (legacy type)	17	0	Legacy issue-type count
Bugs (legacy type)	0	0	No legacy BUG-type issues
Vulnerabilities (legacy type)	0	0	No legacy VULNERABILITY-type issues
Reliability impacts (MQR)*	2	0	Overlapping software-quality impact
Security impacts (MQR)*	1	0	Overlapping software-quality impact
Maintainability impacts (MQR)*	16	0	Overlapping software-quality impact
Security hotspots	0	0	No hotspots reported
Coverage	74.4%	74.3%	Decreased by 0.1 percentage points
Duplicated lines	0.0%	0.0%	No change
Cyclomatic complexity	886	889	Increased by 3
Cognitive complexity	165	165	No change
Quality Gate	OK	OK	Remained OK

As shown in Table 4.2, all 17 unique fresh baseline issues were closed. Coverage decreased slightly by 0.1 percentage points and cyclomatic complexity increased by 3, so those controls are reported as small regressions rather than described as unchanged. The MQR Reliability, Security, and Maintainability impact counts overlap and therefore do not sum to the 17 unique issues.

Table 4.3. Maintainability-focused code-quality comparison.

Area	Before	After	Effect
Controller parameter complexity	Long JournalEntriesController action signature	JournalEntryQueryDto request model	Improves readability and future extension
Startup lifecycle	Blocking app.Run()	await app.RunAsync()	Matches asynchronous ASP.NET Core hosting pattern
Constants and repeated literals	Repeated journal-entry values in service logic	Named constants	Reduces magic strings and repeated values
Infrastructure templates	ARM expressions flagged by analyzer	Explicit template functions and safer defaults	Cleaner deployment artifacts

The comparison in Table 4.3 links representative maintainability problems to the implemented structural changes and their expected engineering effect.

The fresh SonarQube result remains the cleanest closure case because all 17 unique issues moved to 0 and the Quality Gate remained OK. However, the evidence does not support saying every control metric was unchanged: coverage moved from 74.4% to 74.3% and cyclomatic complexity moved from 886 to 889. The most important maintainability change remains the replacement of the long controller parameter list with a request DTO.

Outcome judgment: Achieved with minor control-metric regressions. The fresh scan reduced 17 unique issues and 17 legacy Code Smells to 0, while the Quality Gate remained OK and duplicated-line density remained 0.0%. Legacy Bugs, Vulnerabilities, and Security Hotspots remained 0. Coverage decreased from 74.4% to 74.3%, and cyclomatic complexity increased from 886 to 889; these changes are small but are not described as unchanged. The implementation excerpts and fresh SonarQube dashboard evidence are reported in Appendices E, L, and M.

4.3 Security Outcome

Security comparison units: counts by risk level, vulnerability class, affected endpoint, branch name, and resolved/remaining status. The full report compares common baseline branch with OWASP ZAP remediation branch.

Observed fresh authenticated API scan result: High alerts stayed at 0, Medium alerts stayed at 1, Low alerts decreased from 3 to 0, and Informational alerts stayed at 5. The remaining Medium alert is HTTP Only Site (CWE-311) on the local HTTP test transport. It is disclosed as a raw scanner observation and was not counted as cleared.

Observed fresh passive-scan result: High alerts stayed at 0, Medium alerts decreased from 3 to 0, Low alerts decreased from 6 to 0, and Informational alerts changed from 3 to 4. The configured-rule gate passed on both branches.

The fresh ZAP evidence shows effective header and configuration hardening, but it does not support a claim that every raw Medium alert was eliminated. The passive scan cleared all Medium and Low alerts, and the authenticated API scan cleared all Low alerts. One HTTP Only Site Medium observation remained because the local reproduction used HTTP rather than a production TLS endpoint.

Outcome judgment: Partially Achieved in raw-alert terms and Achieved for the configured gate. Both branches returned PASS_CONFIGURED_RULES for the configured business-endpoint rules. The passive scan improved from Medium 3 / Low 6 to Medium 0 / Low 0; the authenticated API scan improved from Medium 1 / Low 3 to Medium 1 / Low 0. Because one raw Medium HTTP Only Site observation remained, the report does not claim zero raw Medium alerts. The security-header implementation, scan provenance, and dashboards are provided in Appendices F, L, and M.

4.4 Performance Outcome

Performance comparison units: average latency, p95 latency, p99 latency in milliseconds, throughput in transactions per second, error rate percentage, and drift percentage. The full report compares common baseline branch with JMeter remediation branch.

Observed fresh stress-profile result: soak total p95 decreased from 443.95 ms to 171.0 ms and spike total p95 decreased from 33401.75 ms to 4730.85 ms. Spike error rate also decreased from 0.4688% to 0.00%. These aggregate improvements are reported separately from the failed core gate and do not override it.

Observed fresh JMeter core result: p50 total p95 increased from 33.0 ms to 199.9 ms, p100 increased from 255.9 ms to 1146.9 ms, and p500 increased from 106.0 ms to 1547.95 ms. Error rate remained 0.00% for the three core profiles, but the remediation gate failed because p100 exceeded 500 ms and p500 exceeded 1200 ms.

Table 4.4. Performance hotspot comparison for reviewer-visible report endpoints.

Endpoint	Profile metric	Baseline	After fixes	Fresh interpretation
GET /reports/account-ledger	Soak p95	741.95 ms	3825.70 ms	Regression under the fresh sustained-load run
GET /reports/account-ledger	Spike p95	50288.30 ms	12910.20 ms	Improved under spike, but remained the slowest report endpoint
GET /reports/trial-balance	Spike p95	31142.45 ms	2797.70 ms	Large spike-profile improvement

Endpoint	Profile metric	Baseline	After fixes	Fresh interpretation
GET /reports/profit-loss	Spike p95	31487.90 ms	2342.75 ms	Large spike-profile improvement
GET /reports/balance-sheet	Spike p95	32732.65 ms	2554.90 ms	Large spike-profile improvement
POST /journal-entries/bulk	Spike p95	12734.75 ms	2544.10 ms	Large spike-profile improvement

The fresh endpoint evidence in Table 4.4 shows that spike-profile report endpoints improved substantially, but account-ledger soak p95 regressed. Endpoint improvements under one workload therefore cannot be generalized to the failed p100 and p500 core profiles.

The fresh JMeter results are mixed. Soak and spike aggregate p95 improved, and spike errors fell to 0%, but p50, p100, and p500 aggregate p95 all worsened. Because the pre-registered core gate failed, the report treats the current performance remediation as unsuccessful for the core criterion rather than carrying forward the earlier historical success claim.

Outcome judgment: Not Achieved for the core performance criterion and Partially Achieved for stress-profile behavior. The remediation core gate failed because p100 p95 was 1146.9 ms against a 500 ms threshold and p500 p95 was 1547.95 ms against a 1200 ms threshold. Soak total p95 improved from 443.95 ms to 171.0 ms, spike total p95 improved from 33401.75 ms to 4730.85 ms, and spike error rate fell from 0.4688% to 0.00%. Those stress improvements are meaningful but do not compensate for the failed core gate. Appendices G and K-M preserve the profiles, machine-readable statistics, and dashboards.

4.5 Overall Assessment and Trade-offs

Table 4.5. Overall outcome and closure matrix.

Tool	Fresh baseline evidence	Fresh after-fix evidence	Closure status
SonarQube	17 unique issues; coverage 74.4%	0 issues; coverage 74.3%; gate OK	Achieved with minor metric regressions
ZAP passive scan	3 Medium, 6 Low	0 Medium, 0 Low	Achieved
ZAP authenticated API	1 Medium, 3 Low	1 Medium, 0 Low	Configured gate passed; raw Medium remains
JMeter core profiles	p95: 33 / 255.9 / 106 ms	p95: 199.9 / 1146.9 / 1547.95 ms	Not Achieved; remediation gate FAIL
JMeter stress profiles	Soak 443.95 ms; spike 33401.75 ms	Soak 171 ms; spike 4730.85 ms	Partially Achieved

The closure matrix in Table 4.5 applies the decision rules consistently across static analysis, security scanning, and performance testing.

Overall, the fresh evidence is mixed. The code-quality criterion was achieved with small coverage and complexity regressions. The ZAP configured gate was achieved, but one raw Medium HTTP-only transport observation remained. The JMeter core performance criterion was not achieved, although soak and spike aggregate behavior improved. The defensible conclusion is therefore that ChatGPT-guided remediation was effective for the measured static-analysis findings and selected security hardening, but performance benefits were not reproducible across the fresh core profiles.

4.6 Web Application Evidence for Current APIs

A React and Vite web application was added as a live validation artifact for the current ASP.NET Core financial accounting APIs. The application runs at <http://localhost:5173> and connects to the API at <http://localhost:5296>, matching the CORS origins already configured in the backend. It demonstrates JWT login, role-aware navigation, account balances, expandable journal-entry debit and credit lines, accounting periods, reports, audit logs, user administration, and a research-evidence dashboard.

The local seed process creates four demo accounts for reproducible role testing: admin, finance-manager, normal-user, and auditor-user, using local-only demo credentials whose values are omitted from this report. The screenshots below were captured after seeding the local SQL Server database and logging in through the web application, so they validate the user-visible path rather than only the API response layer.

Financial Accounting

API Demo

Live research web app for the ASP.NET Core financial accounting APIs.

API base URL

Username

Password

Sign in

The diagram illustrates four demo credentials arranged in a 2x2 grid. Each credential is represented by a light blue rounded rectangle with a thin border. The top-left box is labeled 'Admin' in bold, with the username 'admin / Admin@123' and the role 'Admin + FinanceManager'. The top-right box is labeled 'Finance manager' in bold, with the username 'finance-manager / Admin@123' and the role 'FinanceManager'. The bottom-left box is labeled 'Normal user' in bold, with the username 'normal-user / Admin@123' and the role 'User'. The bottom-right box is labeled 'Auditor' in bold, with the username 'auditor-user / Admin@123' and the role 'Auditor'.

Credential	Username	Role
Admin	admin / Admin@123	Admin + FinanceManager
Finance manager	finance-manager / Admin@123	FinanceManager
Normal user	normal-user / Admin@123	User
Auditor	auditor-user / Admin@123	Auditor

Figure 4.1. Web application login screen with demo role credentials.

Financial API
Research demo

Dashboard

Accounts

Journal Entries

Periods

Reports

Audit Logs

Users

Research Evidence

CONNECTED TO HTTP://LOCALHOST:5296

admin

AdminFinanceManagerLogout

Dashboard

Live API overview

Refresh

Current user
admin@local.invalid

Accounts loaded
257

Periods loaded
3

Trial balance debit
\$8,480,875.73

Research Evidence

Final report evidence for the live API workflow.

AREA	API COVERAGE	EVIDENCE VALUE
Auth	POST /auth/login and GET /users/me	JWT token, expiry, current user
RBAC	Role-aware navigation	Current roles: Admin, FinanceManager
Accounting	Accounts, journals, periods	CRUD and protected actions
Reports	Trial balance, P/L, balance sheet, ledger	Live financial report endpoints
Audit	GET /audit-logs	Admin/Auditor evidence path

Login screenshotDashboard screenshotRole-restricted navigationReports workspaceAudit logsFinal report insertion

Figure 4.2. Admin dashboard showing live API counts and report summary.

76

Financial API
Research demo

Dashboard

Accounts

Journal Entries

Periods

Reports

Audit Logs

Users

Research Evidence

CONNECTED TO HTTP://LOCALHOST:5296

admin

Admin FinanceManager Logout

Reports Workspace

Generate live financial statements from the selected period and account.

Period

202601

Account

1

Trial balance

Profit/loss

Balance sheet

Account ledger

Total debit

\$8,480,875.73

Total credit

\$8,480,875.73

ACCOUNT CODE	ACCOUNT NAME	TYPE	DEBIT	CREDIT	BALANCE
1000	Cash	Asset	\$442,477.16	\$10.00	\$442,467.16
2000	Accounts Payable	Liability	\$10.00	\$216,446.14	\$216,436.14
3000	Owner Equity	Equity	\$0.00	\$226,031.02	\$226,031.02
4000	Sales Revenue	Revenue	\$0.00	\$215,634.15	\$215,634.15
5000	Operating Expense	Expense	\$215,634.15	\$0.00	\$215,634.15
A001000	Cash - Operating Account	Asset	\$1,524,800.00	\$961,306.92	\$563,493.08
A001010	Cash - Payroll Account	Asset	\$45,000.00	\$1,309,938.00	-\$1,264,938.00
A001020	Petty Cash	Asset	\$500.00	\$0.00	\$500.00
A001100	Accounts Receivable	Asset	\$349,290.00	\$334,080.00	\$15,210.00
A001110	Accounts Receivable - Trade	Asset	\$1,448,359.50	\$836,820.00	\$611,539.50
A001200	Inventory - Raw Materials	Asset	\$467,100.00	\$365,640.00	\$101,460.00
A001220	Inventory - Finished Goods	Asset	\$68,000.00	\$0.00	\$68,000.00
A001620	Machinerv and EQUIPMENT	Asset	\$225,000.00	\$0.00	\$225,000.00

Figure 4.3. Trial balance report generated from the live reports API.

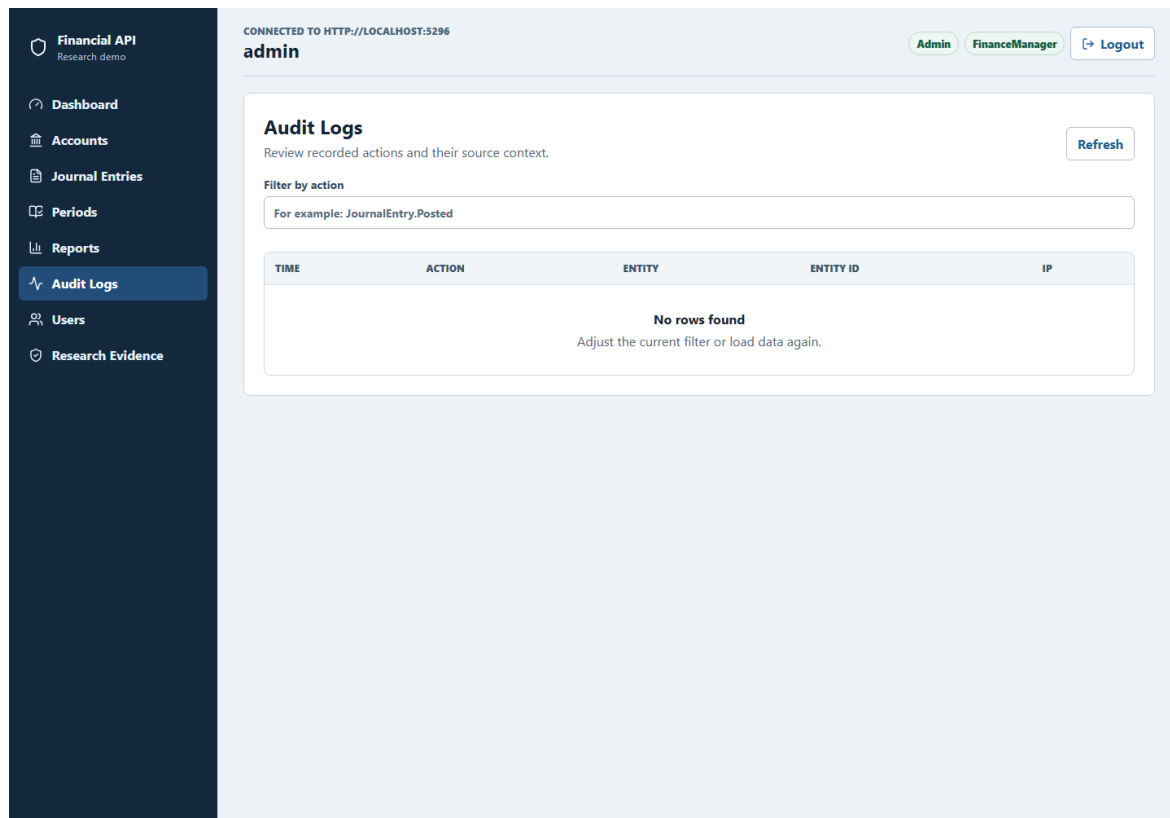


Figure 4.4. Audit-log screen available to Admin and Auditor roles.

Financial API
Research demo

Dashboard

Accounts

Periods

Reports

Audit Logs

Research Evidence

CONNECTED TO HTTP://LOCALHOST:5296

auditor-user

AuditorLogout

Accounts

Search the chart of accounts and inspect current ledger balances.

Search

Search accounts

Account code or name

Read-only access: account maintenance is restricted for this role.

CODE	NAME	TYPE	ACTIVE	LEDGER BALANCE
1000	Cash	Asset	Yes	View balance for 1000
2000	Accounts Payable	Liability	Yes	View balance for 2000
3000	Owner Equity	Equity	Yes	View balance for 3000
4000	Sales Revenue	Revenue	Yes	View balance for 4000
5000	Operating Expense	Expense	Yes	View balance for 5000
A000001	Seed Asset 000001	Asset	Yes	View balance for A000001
A000006	Seed Asset 000006	Asset	Yes	View balance for A000006
A000011	Seed Asset 000011	Asset	Yes	View balance for A000011
A000016	Seed Asset 000016	Asset	Yes	View balance for A000016
A000021	Seed Asset 000021	Asset	Yes	View balance for A000021

Figure 4.5. Auditor role view with restricted navigation.

Financial API
Research demo

Dashboard

Accounts

Journal Entries

Periods

Reports

Audit Logs

Users

Research Evidence

CONNECTED TO HTTP://LOCALHOST:5296

admin

AdminFinanceManagerLogout

Research Evidence

Final report evidence for the live API workflow.

AREA	API COVERAGE	EVIDENCE VALUE
Auth	POST /auth/login and GET /users/me	JWT token, expiry, current user
RBAC	Role-aware navigation	Current roles: Admin, FinanceManager
Accounting	Accounts, journals, periods	CRUD and protected actions
Reports	Trial balance, P/L, balance sheet, ledger	Live financial report endpoints
Audit	GET /audit-logs	Admin/Auditor evidence path

Login screenshotDashboard screenshotRole-restricted navigationReports workspaceAudit logsFinal report insertion

Figure 4.6. Research-evidence page mapping screens to API coverage.

80

Financial API
Research demo

Dashboard

Accounts

Journal Entries

Periods

Reports

Audit Logs

Users

Research Evidence

CONNECTED TO HTTP://LOCALHOST:5296

admin

Admin FinanceManager Logout

Journal Entries

Review balanced entries and their posting status.

Refresh

Entry amount

25

Create balanced draft

Bulk create

ID	DATE	REFERENCE	STATUS	DEBIT	CREDIT	DETAIL	ACTIONS
68082	Dec 31, 2026	SEED-D-00008761-202601	Posted	\$690.82	\$690.82	Hide lines for SEED-D-00008761-202601	Post Reverse Delete
Journal lines							2 lines
Account		Description			Line debit		Line credit
1000		Seed debit line			\$690.82		\$0.00
Cash							
Account		Description			Line debit		Line credit
2000		Seed credit line			\$0.00		\$690.82
Accounts Payable							
67717	Dec 31, 2026	SEED-D-00008396-202601	Draft	\$687.17	\$687.17	Show lines for SEED-D-00008396-202601	Post Reverse Delete
67352	Dec 31, 2026	SEED-D-00008031-202601	Draft	\$683.52	\$683.52	Show lines for SEED-D-00008031-202601	Post Reverse Delete
66987	Dec 31, 2026	SEED-D-00007666-202601	Draft	\$679.87	\$679.87	Show lines for SEED-D-00007666-202601	Post Reverse Delete
66622	Dec 31, 2026	SEED-D-00007301-202601	Draft	\$676.22	\$676.22	Show lines for SEED-D-00007301-202601	Post Reverse

Figure 4.7. Expanded journal-entry lines showing account-level debit and credit evidence.

Chapter 5: Conclusion

This full report presented a systematic, branch-based evaluation of ChatGPT (Codex 5.4) as an improvement advisor for a financial accounting ASP.NET Core RESTful API. The work moved beyond the planning stage by executing the baseline measurement, applying selected ChatGPT-guided fixes on isolated branches, and comparing the measured outcomes across security, performance, and code quality.

5.1 Summary of the Completed Study

The study evaluated one production-complexity RESTful API with endpoint groups for authentication, users, accounts, journal entries, accounting periods, reports, and audit logs. Baseline results were captured on common baseline branch. Post-improvement results were captured on SonarQube remediation branch, OWASP ZAP remediation branch, and JMeter remediation branch. This branch structure made it possible to attribute each measured change to one improvement stream.

5.2 Main Findings

Fresh reproduction showed that the SonarQube branch reduced 17 unique issues to 0 while the Quality Gate remained OK; coverage changed from 74.4% to 74.3%. The OWASP ZAP configured gate passed: the passive scan cleared 3 Medium and 6 Low alerts, while the authenticated API scan retained one Medium HTTP Only Site observation and cleared all 3 Low alerts. The JMeter remediation branch did not reproduce the earlier core-profile improvements: p50 p95 increased from 33.0 ms to 199.9 ms, p100 from 255.9 ms to 1146.9 ms, and p500 from 106.0 ms to 1547.95 ms, causing the core gate to fail. Soak and spike aggregate p95 improved, but the performance conclusion remains Not Achieved for the core criterion.

5.3 Contributions

The report contributes empirical evidence that ChatGPT can be useful as an advisor when its suggestions are constrained by existing code, applied on isolated branches, and validated with repeatable tools. It also contributes a reusable evaluation framework combining SonarQube, OWASP ZAP, Apache JMeter, dotnet test, and branch-based before/after comparison for RESTful API improvement studies.

5.4 Limitations and Future Work

The findings are limited to one ASP.NET Core API, one language (C#), one database-backed financial accounting domain, one AI assistant configuration, and one fresh reproduction per evidence branch. Tool versions, host load, database state, and workload composition can materially change measured values. The fresh JMeter run demonstrates this limitation directly: stress aggregates improved while core p95 thresholds failed. Repeated runs with controlled host utilization and confidence intervals are required before claiming general performance improvement. Historical measurements remain in the appendices for provenance, but Chapters 4 and 5 use the September 22, 2026 fresh reproduction as the current result. Future work should compare multiple LLMs, repeat each measurement, and test production-like HTTPS deployment so the remaining ZAP HTTP Only Site observation can be evaluated under the intended transport.

REFERENCES

- Chen, E., Huang, R., Chen, H.-S., Tseng, Y.-H., & Li, L.-Y. (2023). *GPTutor: A ChatGPT-powered programming tool for code explanation* [Preprint]. arXiv. <https://doi.org/10.48550/arXiv.2305.01863>
- Fajkovic, E., & Rundberg, E. (2023). *The impact of AI-generated code on web development: A comparative study of ChatGPT and GitHub Copilot* [Bachelor's thesis, Blekinge Institute of Technology]. DiVA. <https://www.diva-portal.org/smash/record.jsf?pid=diva2:1769082>
- Flores, C. P., Jr., & Monreal, R. N. (2024). Evaluation of common security vulnerabilities of state universities and colleges websites based on OWASP. *Journal of Electrical Systems*, 20(5s), 1396-1404. <https://doi.org/10.52783/jes.2471>
- Hou, X., Zhao, Y., Liu, Y., Yang, Z., Wang, K., Li, L., Luo, X., Lo, D., Grundy, J., & Wang, H. (2024). Large language models for software engineering: A systematic literature review. *ACM Transactions on Software Engineering and Methodology*, 33(8), Article 220, 1-79. <https://doi.org/10.1145/3695988>
- Khoury, R., Avila, A. R., Brunelle, J., & Camara, B. M. (2023). How secure is code generated by ChatGPT? In *2023 IEEE International Conference on Systems, Man, and Cybernetics (SMC)* (pp. 2445-2451). IEEE. <https://doi.org/10.1109/SMC53992.2023.10394237>
- Lenarduzzi, V., Lomio, F., Huttunen, H., & Taibi, D. (2020). Are SonarQube rules inducing bugs? In *2020 IEEE 27th International Conference on Software Analysis, Evolution and Reengineering (SANER)* (pp. 501-511). IEEE. <https://doi.org/10.1109/SANER48275.2020.9054821>

- Mousavi, Z., Islam, C., Moore, K., Abuadbbba, A., & Babar, M. A. (2024). An investigation into misuse of Java security APIs by large language models. In *Proceedings of the 19th ACM Asia Conference on Computer and Communications Security* (pp. 1299-1315). ACM.
<https://doi.org/10.1145/3634737.3661134>
- Özpolat, Z., Yıldırım, Ö., & Karabatak, M. (2023). Artificial intelligence-based tools in software development processes: Application of ChatGPT. *European Journal of Technic*, 13(2).
<https://doi.org/10.36222/ejt.1330631>
- Pearce, H., Ahmad, B., Tan, B., Dolan-Gavitt, B., & Karri, R. (2022). Asleep at the keyboard? Assessing the security of GitHub Copilot's code contributions. In *2022 IEEE Symposium on Security and Privacy (SP)* (pp. 754-768). IEEE.
<https://doi.org/10.1109/SP46214.2022.9833571>
- Peng, S., Kalliamvakou, E., Cihon, P., & Demirer, M. (2023). *The impact of AI on developer productivity: Evidence from GitHub Copilot* [Preprint]. arXiv.
<https://doi.org/10.48550/arXiv.2302.06590>
- Ságodi, Z., Siket, I., & Ferenc, R. (2024). Methodology for code synthesis evaluation of LLMs presented by a case study of ChatGPT and Copilot. *IEEE Access*, 12, 72303-72316.
<https://doi.org/10.1109/ACCESS.2024.3403858>
- Sandoval, G., Pearce, H., Nys, T., Karri, R., Garg, S., & Dolan-Gavitt, B. (2023). Lost at C: A user study on the security implications of large language model code assistants. In *32nd USENIX Security Symposium (USENIX Security 23)* (pp. 2205-2222). USENIX Association. <https://www.usenix.org/conference/usenixsecurity23/presentation/sandoval>

Szabó, Z., & Bilicki, V. (2023). A new approach to web application security: Utilizing GPT language models for source code inspection. *Future Internet*, 15(10), Article 326.

<https://doi.org/10.3390/fi15100326>

Yetiştiren, B., Özsoy, I., Ayerdem, M., & Tüzün, E. (2023). *Evaluating the code quality of AI-assisted code generation tools: An empirical study on GitHub Copilot, Amazon CodeWhisperer, and ChatGPT* [Preprint]. arXiv.

<https://doi.org/10.48550/arXiv.2304.10778>

Zhang, N., Zou, Y., Xia, X., Huang, Q., Lo, D., & Li, S. (2023). Web APIs: Features, issues, and expectations - A large-scale empirical study of Web APIs from two publicly accessible registries using Stack Overflow and a user survey. *IEEE Transactions on Software Engineering*, 49(2), 498-528. <https://doi.org/10.1109/TSE.2022.3154769>

APPENDICES

These appendices are self-contained. They reproduce the essential implementation excerpts, explanations, commands, dashboards, and result provenance required to assess the study. The repository remains the authoritative complete source, but no external Markdown appendix is required to understand the evidence presented here.

Appendix A - Environment and Repository Provenance

The study evaluates ChatGPT (Codex 5.4) against one ASP.NET Core financial-accounting API using branch-isolated baseline and remediation evidence. Exact refs prevent later branch movement from changing the evaluated source.

Evidence role	Reference	Exact commit	Purpose
Baseline	origin/baseline-v0.1	7a0469d9401a3061941b44fcd46b3beca1c9c729	Common pre-remediation source
SonarQube remediation	origin/baseline-sonarqube-v1	a2279bcbdc20751529335cf72f8baac1bc6f994b	Static-analysis changes
ZAP remediation	origin/baseline-zap-v1	5f3bd3ccd9e0d460f52cac6a8a0d5fdceff1ce3d	Security-hardening changes
JMeter remediation	origin/baseline-jmeter-v1	78b08b62570dcf6fe436354e8e6b770ab2074445	Performance changes
Reproducibility package	origin/codex/thesis-reproducibility-v1	efa19cea58c7746f88d1efd83fa34719673d1881	Evidence automation and dashboard capture

- Platform: Windows 11; PowerShell; .NET 8; Node.js/npm; local SQL Server; Docker for SonarQube, OWASP ZAP, and JMeter.
- Dataset: 120 accounts; 30,000 journal entries; at least 5,000 posted entries; accounting period 202601.
- Fresh reproduction date: September 22, 2026. Historical values are retained only for comparison and provenance.

Appendix B - Authentication, JWT, and RBAC Source Code

B.1 JWT Authentication Configuration

Purpose. Configures JWT bearer validation at the API boundary so issuer, audience, signing key, and token lifetime are checked by ASP.NET Core.

Source. Remediated authentication registration; file API/Program.cs; branch origin/baseline-sonarqube-v1; commit a2279bcb; lines 77-104.

```
77     .AddAuthentication(options =>
78     {
79         options.DefaultAuthenticateScheme = JwtBearerDefaults.AuthenticationScheme;
80         options.DefaultChallengeScheme = JwtBearerDefaults.AuthenticationScheme;
81         options.DefaultScheme = JwtBearerDefaults.AuthenticationScheme;
82     })
83     .AddJwtBearer(options =>
84     {
85         options.SaveToken = true;
86         options.RequireHttpsMetadata = !builder.Environment.IsDevelopment();
87         options.TokenValidationParameters = new TokenValidationParameters
88         {
89             ValidateIssuerSigningKey = true,
90             IssuerSigningKey = signingKey,
91             ValidateLifetime = true,
92             ValidateIssuer = true,
93             ValidateAudience = true,
94             ValidIssuer = appSettings.JwtIssuer,
95             ValidAudience = appSettings.JwtAudience,
96             ClockSkew = TimeSpan.FromMinutes(1)
97         };
98     });
99
100 builder.Services.AddAuthorization();
101
102 builder.Services.AddSwaggerGen(options =>
103 {
104     options.SwaggerDoc("v1", new OpenApiInfo { Title = "Financial Accounting API", Version = "v1"
105     });
106 });
```

Verification. Related evidence: authenticated API scans, role-aware browser demonstration, and token unit tests.

B.2 Controller-Level Role Enforcement

Purpose. Requires authentication for the journal-entry controller and narrows posting and reversal operations to Admin and FinanceManager roles.

Source. Controller and draft-creation authorization; file
API/Controllers/JournalEntriesController.cs; branch origin/baseline-sonarqube-v1; commit
a2279bcb; lines 9-32.

```
9      [ApiController]
10     [Route("journal-entries")]
11     [Authorize]
12     public class JournalEntriesController : ControllerBase
13     {
14         private readonly IJournalEntryService _journalEntryService;
15
16         public JournalEntriesController(IJournalEntryService journalEntryService)
17         {
18             _journalEntryService = journalEntryService;
19         }
20
21         [Authorize(Roles = "Admin,User,FinanceManager")]
22         [HttpPost]
23         public async Task<IActionResult> Create([FromBody] CreateJournalEntryRequestDto request)
24         {
25             var actorId = UserClaimsHelper.GetUserId(User);
26             if (!actorId.HasValue)
27             {
28                 return Unauthorized();
29             }
30
31             var result = await _journalEntryService.CreateDraftAsync(request, actorId.Value,
32                 HttpContext.Connection.RemoteIpAddress?.ToString());
33             return CreatedAtAction(nameof(GetById), new { id = result.JournalEntryId }, result);
```

Source. Posting authorization and actor propagation; file
API/Controllers/JournalEntriesController.cs; branch origin/baseline-sonarqube-v1; commit
a2279bcb; lines 68-87.

```
68     [Authorize(Roles = "Admin,FinanceManager")]
69     [HttpPost("{id:long}/post")]
70     public async Task<IActionResult> Post([FromRoute] long id)
71     {
72         var actorId = UserClaimsHelper.GetUserId(User);
73         if (!actorId.HasValue)
74         {
75             return Unauthorized();
76         }
77
78         var posted = await _journalEntryService.PostAsync(id, actorId.Value,
79             HttpContext.Connection.RemoteIpAddress?.ToString());
80         if (!posted)
81         {
82             return Problem(
83                 statusCode: StatusCodes.Status404NotFound,
84                 title: "Journal entry not found",
85                 detail: "Draft journal entry was not found.");
86         }
87         return NoContent();
```

Verification. Related evidence: RBAC integration matrix and browser role-restriction workflow.

Appendix C - Journal-Entry Accounting Source Code

C.1 Balanced Journal-Entry Posting

Purpose. Prevents posting into a closed period, enforces debit-credit equality to two decimal places, persists the state transition, and records the actor and totals.

Source. Posting invariant and audit write; file BAL/Services/JournalEntryService.cs; branch origin/baseline-sonarqube-v1; commit a2279bcb; lines 198-240.

```
198     public async Task<bool> PostAsync(long journalEntryId, Guid actorUserId, string? ipAddress)
199     {
200         var entry = await _context.JournalEntries
201             .Include(x => x.Lines)
202             .FirstOrDefaultAsync(x => x.JournalEntryId == journalEntryId);
203
204         if (entry == null || !string.Equals(entry.Status, DraftStatus,
205             StringComparison.OrdinalIgnoreCase))
206         {
207             return false;
208         }
209
210         var period = await GetPeriodForDateAsync(entry.EntryDate);
211         if (period != null && period.IsClosed)
212         {
213             throw new InvalidOperationException("Cannot post journal entry in a closed
214                 accounting period.");
215         }
216
217         var debitTotal = entry.Lines.Sum(x => x.Debit);
218         var creditTotal = entry.Lines.Sum(x => x.Credit);
219         if (decimal.Round(debitTotal, 2) != decimal.Round(creditTotal, 2) || debitTotal <= 0m)
220         {
221             throw new InvalidOperationException("Journal entry must be balanced before
222                 posting.");
223         }
224
225         entry.Status = PostedStatus;
226         entry.PostedAt = DateTime.UtcNow;
227
228         await _context.SaveChangesAsync();
229
230         if (period != null)
231         {
232             await RefreshLedgerBalancesForPeriodAsync(period.PeriodId);
233         }
234
235         await _auditLogService.WriteAsync(
236             actorUserId,
237             "POST_ENTRY",
238             JournalEntriesEntityName,
239             journalEntryId.ToString(),
240             ipAddress,
241             new { debitTotal, creditTotal });
242
243         return true;
244     }
```

Verification. Related evidence: posted-entry seed data, journal-line browser evidence, and audit-log output.

C.2 Journal-Entry Reversal

Purpose. Creates a reversing draft by swapping debit and credit values, prevents duplicate reversal, and writes the resulting relationship to the audit trail.

Source. Reversal workflow; file BAL/Services/JournalEntryService.cs; branch origin/baseline-sonarqube-v1; commit a2279bcb; lines 243-310.

```
243     public async Task<long> ReverseAsync(long journalEntryId, Guid actorUserId, string?
244         ipAddress)
245     {
246         var original = await _context.JournalEntries
247             .Include(x => x.Lines)
248             .FirstOrDefaultAsync(x => x.JournalEntryId == journalEntryId);
249
250         if (original == null)
251         {
252             throw new InvalidOperationException("Journal entry was not found.");
253         }
254
255         if (!string.Equals(original.Status, PostedStatus, StringComparison.OrdinalIgnoreCase))
256         {
257             throw new InvalidOperationException("Only posted journal entries can be reversed.");
258         }
259
260         if (original.ReversedAt.HasValue)
261         {
262             throw new InvalidOperationException("This journal entry has already been
263                 reversed.");
264         }
265
266         var period = await GetPeriodForDateAsync(original.EntryDate);
267         if (period != null && period.IsClosed)
268         {
269             throw new InvalidOperationException("Cannot reverse entry in a closed accounting
270                 period.");
271         }
272
273         var reversal = new JournalEntry
274         {
275             EntryDate = original.EntryDate,
276             Description = $"Reversal of #{original.JournalEntryId}: {original.Description}",
277             ReferenceNo = string.IsNullOrEmpty(original.ReferenceNo) ?
278                 $"REV-{original.JournalEntryId}" : $"REV-{original.ReferenceNo}",
279             Status = PostedStatus,
280             CreatedByUserId = actorUserId,
281             CreatedAt = DateTime.UtcNow,
282             PostedAt = DateTime.UtcNow
283         };
284
285         foreach (var line in original.Lines)
286         {
287             reversal.Lines.Add(new JournalEntryLine
288             {
289                 AccountId = line.AccountId,
290                 LineDescription = line.LineDescription,
291                 Debit = line.Credit,
292                 Credit = line.Debit
293             });
294         }
295
296         original.Status = ReversedStatus;
297         original.ReversedAt = DateTime.UtcNow;
298
299         await _context.JournalEntries.AddAsync(reversal);
300         await _context.SaveChangesAsync();
301
302         if (period != null)
303         {
304             await RefreshLedgerBalancesForPeriodAsync(period.PeriodId);
305         }
306     }
```

```
302
303     await _auditLogService.WriteAsync(
304         actorUserId,
305         "REVERSE_ENTRY",
306         JournalEntriesEntityName,
307         journalEntryId.ToString(),
308         ipAddress,
309         new { reversingEntryId = reversal.JournalEntryId });
310
```

Verification. Related evidence: journal-entry service behavior and double-entry database constraints.

Appendix D - Audit Logging and Traceability Source Code

D.1 Structured Audit-Log Writer

Purpose. Serializes structured details and records the user, action, entity, identifier, timestamp, and network address for sensitive operations.

Source. Audit service; file BAL/Services/AuditLogService.cs; branch origin/baseline-sonarqube-v1; commit a2279bcb; lines 10-45.

```
10     internal class AuditLogService : IAuditLogService
11     {
12         private readonly DataContext _context;
13
14         public AuditLogService(DataContext context)
15         {
16             _context = context;
17         }
18
19         public async Task WriteAsync(Guid? userId, string action, string? entityName, string?
            entityId, string? ipAddress, object? details = null)
20         {
21             var model = new AuditLog
22             {
23                 UserId = userId,
24                 Action = action,
25                 EntityName = entityName,
26                 EntityId = entityId,
27                 IpAddress = ipAddress,
28                 DetailsJson = details == null ? null : JsonSerializer.Serialize(details),
29                 Timestamp = DateTime.UtcNow
30             };
31
32             await _context.AuditLogs.AddAsync(model);
33             await _context.SaveChangesAsync();
34         }
35
36         public async Task<PagedResultDto<AuditLogResponseDto>> GetPagedAsync(
37             DateTime? from,
38             DateTime? to,
39             Guid? userId,
40             string? action,
41             int page,
42             int pageSize)
43         {
44             page = page < 1 ? 1 : page;
45             pageSize = pageSize < 1 ? 50 : pageSize;
```

Verification. Related evidence: audit-log API/browser screenshots and GENERATE_REPORT/POST_ENTRY audit records.

D.2 Auditor-Role Read Boundary

Purpose. Restricts audit-log retrieval to Admin and Auditor roles while keeping filtering and paging in the service layer.

Source. Audit-log controller; file API/Controllers/AuditLogsController.cs; branch origin/baseline-sonarqube-v1; commit a2279bcb; lines 7-32.

```
7  [ApiController]
8  [Route("audit-logs")]
9  [Authorize(Roles = "Admin,Auditor")]
10 public class AuditLogsController : ControllerBase
11 {
12     private readonly IAuditLogService _auditLogService;
13
14     public AuditLogsController(IAuditLogService auditLogService)
15     {
16         _auditLogService = auditLogService;
17     }
18
19     [HttpGet]
20     public async Task<IActionResult> GetAuditLogs(
21         [FromQuery] DateTime? from,
22         [FromQuery] DateTime? to,
23         [FromQuery] Guid? userId,
24         [FromQuery] string? action,
25         [FromQuery] int page = 1,
26         [FromQuery] int pageSize = 50)
27     {
28         var result = await _auditLogService.GetPagedAsync(from, to, userId, action, page,
29             pageSize);
30         return Ok(result);
31     }
32 }
```

Verification. Related evidence: auditor navigation screenshot and RBAC matrix.

Appendix E - SonarQube Remediation Source Code

E.1 S107 Controller-Parameter Remediation

Purpose. Replaces eight query parameters with one request DTO, directly addressing the SonarQube S107 maintainability finding without changing the route.

Source. Before: long action signature; file API/Controllers/JournalEntriesController.cs; branch origin/baseline-v0.1; commit 7a0469d9; lines 61-74.

```
61     [HttpGet]
62     public async Task<IActionResult> GetPaged(
63         [FromQuery] DateTime? from,
64         [FromQuery] DateTime? to,
65         [FromQuery] string? status,
66         [FromQuery] int? accountId,
67         [FromQuery] string? search,
68         [FromQuery] int page = 1,
69         [FromQuery] int pageSize = 20,
70         [FromQuery] string? sort = "entryDate_desc")
71     {
72         var result = await _journalEntryService.GetPagedAsync(from, to, status, accountId,
73             search, page, pageSize, sort);
74         return Ok(result);
75     }
```

Source. After: DTO-bound action; file API/Controllers/JournalEntriesController.cs; branch origin/baseline-sonarqube-v1; commit a2279bcb; lines 61-67.

```
61     [HttpGet]
62     public async Task<IActionResult> GetPaged([FromQuery] JournalEntryQueryDto query)
63     {
64         var result = await _journalEntryService.GetPagedAsync(query);
65         return Ok(result);
66     }
67 }
```

Source. Query DTO; file MODEL/DTOs/FinancialAccountingDTOs.cs; branch origin/baseline-sonarqube-v1; commit a2279bcb; lines 148-166.

```
148     public class JournalEntryQueryDto
149     {
150         public DateTime? From { get; set; }
151         public DateTime? To { get; set; }
152         public string? Status { get; set; }
153         public int? AccountId { get; set; }
154         public string? Search { get; set; }
155         public int Page { get; set; } = 1;
156         public int PageSize { get; set; } = 20;
157         public string? Sort { get; set; } = "entryDate_desc";
158     }
159
160     public class JournalEntryLineResponseDto
161     {
162         public long JournalEntryLineId { get; set; }
163         public int AccountId { get; set; }
164         public string AccountCode { get; set; } = string.Empty;
165         public string AccountName { get; set; } = string.Empty;
166         public string? LineDescription { get; set; }
```

Verification. Fresh SonarQube result: 17 unique issues reduced to 0; Quality Gate remained OK.

E.2 S6966 Asynchronous Host Shutdown

Purpose. Uses `await app.RunAsync()` instead of the blocking host call identified by the analyzer.

Source. Before: blocking host call; file `API/Program.cs`; branch `origin/baseline-v0.1`; commit `7a0469d9`; lines 176-188.

```
176
177 if (enableSwagger)
178 {
179     app.MapGet("/", () => Results.Redirect("/swagger")).ExcludeFromDescription();
180 }
181 else
182 {
183     app.MapGet("/", () => Results.Redirect("/health/live")).ExcludeFromDescription();
184 }
185
186 app.MapFallback(() => Results.NotFound()).ExcludeFromDescription();
187 app.MapControllers();
188 app.Run();
```

Source. After: asynchronous host call; file `API/Program.cs`; branch `origin/baseline-sonarqube-v1`; commit `a2279bcb`; lines 180-190.

```
180 }
181 else
182 {
183     app.MapGet("/", () => Results.Redirect("/health/live")).ExcludeFromDescription();
184 }
185
186 app.MapFallback(() => Results.NotFound()).ExcludeFromDescription();
187 app.MapControllers();
188 await app.RunAsync();
189
190 public partial class Program
```

Verification. Fresh remediation scan reported zero remaining issues.

Appendix F - OWASP ZAP Security-Hardening Source Code

F.1 Response Security-Headers Middleware

Purpose. Applies CSP, framing, MIME-sniffing, permissions, and cross-origin policies immediately before each response is sent.

Source. Security-header middleware; file API/Middleware/SecurityHeadersMiddleware.cs; branch origin/baseline-zap-v1; commit 5f3bd3cc; lines 17-63.

```
17     public async Task InvokeAsync(HttpContext context)
18     {
19         if (_options.Enabled)
20         {
21             context.Response.OnStarting(() =>
22             {
23                 SetHeaderIfMissing(context, "Content-Security-Policy",
24                                     GetContentSecurityPolicy(context.Request.Path));
25                 SetHeaderIfMissing(context, "X-Frame-Options", _options.XFrameOptions);
26                 SetHeaderIfMissing(context, "X-Content-Type-Options",
27                                     _options.XContentTypeOptions);
28                 SetHeaderIfMissing(context, "Permissions-Policy", _options.PermissionsPolicy);
29                 SetHeaderIfMissing(context, "Cross-Origin-Opener-Policy",
30                                     _options.CrossOriginOpenerPolicy);
31                 SetHeaderIfMissing(context, "Cross-Origin-Embedder-Policy",
32                                     _options.CrossOriginEmbedderPolicy);
33                 SetHeaderIfMissing(context, "Cross-Origin-Resource-Policy",
34                                     _options.CrossOriginResourcePolicy);
35                 return Task.CompletedTask;
36             });
37         }
38         await _next(context);
39     }
40
41     private string GetContentSecurityPolicy(PathString requestPath)
42     {
43         return IsSwaggerUiRequest(requestPath)
44             ? _options.SwaggerContentSecurityPolicy
45             : _options.ContentSecurityPolicy;
46     }
47
48     private static bool IsSwaggerUiRequest(PathString requestPath)
49     {
50         if (!requestPath.StartsWithSegments("/swagger", out var remainingPath))
51         {
52             return false;
53         }
54
55         return remainingPath == PathString.Empty
56             || remainingPath == "/"
57             || remainingPath == "/index.html"
58             || remainingPath.Value?.EndsWith(".js", StringComparison.OrdinalIgnoreCase) == true
59             || remainingPath.Value?.EndsWith(".css", StringComparison.OrdinalIgnoreCase) == true
60             || remainingPath.Value?.EndsWith(".png", StringComparison.OrdinalIgnoreCase) ==
61                 true;
62     }
63
64     private static void SetHeaderIfMissing(HttpContext context, string headerName, string
65         headerValue)
66     {
67         if (!string.IsNullOrEmpty(headerValue) &&
68             !context.Response.Headers.ContainsKey(headerName))
69         {
70             context.Response.Headers[headerName] = headerValue;
71         }
72     }
```

Verification. Fresh passive ZAP scan: Medium 3 to 0 and Low 6 to 0.

F.2 Middleware Ordering and Swagger Exposure

Purpose. Places response hardening before Swagger/OpenAPI and separates the Swagger document switch from the browser UI switch.

Source. Before: baseline pipeline; file API/Program.cs; branch origin/baseline-v0.1; commit 7a0469d9; lines 135-166.

```
135 });
136
137 var app = builder.Build();
138
139 using (var scope = app.Services.CreateScope())
140 {
141     var roleSeeder = scope.ServiceProvider.GetRequiredService<FinancialRoleStartupSeeder>();
142     await roleSeeder.SeedAsync();
143 }
144
145 var enableSwagger = app.Environment.IsDevelopment() || appSettings.EnableSwaggerInProduction;
146 if (enableSwagger)
147 {
148     app.UseSwagger();
149     app.UseSwaggerUI();
150 }
151
152 app.UseMiddleware<CorrelationIdMiddleware>();
153 app.UseMiddleware<GlobalExceptionHandler>();
154 app.UseMiddleware<SecurityHeadersMiddleware>();
155
156 app.UseHttpsRedirection();
157 app.UseCors("AppCors");
158 app.UseCookiePolicy(new CookiePolicyOptions
159 {
160     HttpOnly = Microsoft.AspNetCore.CookiePolicy.HttpOnlyPolicy.Always,
161     Secure = CookieSecurePolicy.Always,
162     MinimumSameSitePolicy = Microsoft.AspNetCore.Http.SameSiteMode.Lax
163 });
164 app.UseAuthentication();
165 app.UseAuthorization();
166
```

Source. After: hardened pipeline; file API/Program.cs; branch origin/baseline-zap-v1; commit 5f3bd3cc; lines 135-166.

```
135 {
136     var roleSeeder = scope.ServiceProvider.GetRequiredService<FinancialRoleStartupSeeder>();
137     await roleSeeder.SeedAsync();
138 }
139
140 app.UseMiddleware<CorrelationIdMiddleware>();
141 app.UseMiddleware<GlobalExceptionHandler>();
142 app.UseMiddleware<SecurityHeadersMiddleware>();
143
144 var enableSwaggerDocument = app.Environment.IsDevelopment() ||
    appSettings.EnableSwaggerInProduction;
145 var enableSwaggerUi = enableSwaggerDocument && appSettings.EnableSwaggerUi;
146 if (enableSwaggerDocument)
147 {
148     app.UseSwagger();
149 }
150
151 if (enableSwaggerUi)
152 {
153     app.UseSwaggerUI();
154 }
155
156 app.UseHttpsRedirection();
157 app.UseCors("AppCors");
158 app.UseCookiePolicy(new CookiePolicyOptions
159 {
160     HttpOnly = Microsoft.AspNetCore.CookiePolicy.HttpOnlyPolicy.Always,
```

```
161     Secure = CookieSecurePolicy.Always,  
162     MinimumSameSitePolicy = Microsoft.AspNetCore.Http.SameSiteMode.Lax  
163 });  
164 app.UseAuthentication();  
165 app.UseAuthorization();  
166
```

Verification. Configured ZAP rules passed; one raw HTTP Only Site Medium observation remains disclosed for local HTTP transport.

Appendix G - JMeter Performance and Query-Optimization Source Code

G.1 Concurrency-Safe Account-Ledger Cache

Purpose. Uses a concurrent dictionary and Lazy<Task<T>> so simultaneous requests share one in-flight calculation and failed entries can be retried.

Source. Cache implementation; file BAL/Shared/AccountLedgerCache.cs; branch origin/baseline-jmeter-v1; commit 78b08b62; lines 8-37.

```
8     public sealed class AccountLedgerCache : IAccountLedgerCache
9     {
10         private readonly ConcurrentDictionary<string, Lazy<Task<AccountLedgerSnapshot>>> _entries =
            new();
11         private readonly ConcurrentDictionary<string, Lazy<Task<AccountLedgerPayload>>> _payloads =
            new();
12
13         public async Task<AccountLedgerSnapshot> GetOrCreateAsync(
14             int accountId,
15             int periodId,
16             string accountType,
17             DateTime startDate,
18             DateTime endDate,
19             Func<Task<AccountLedgerSnapshot>> factory)
20         {
21             var key = BuildKey(accountId, periodId, accountType, startDate, endDate);
22             var lazy = _entries.GetOrAdd(
23                 key,
24                 _ => new Lazy<Task<AccountLedgerSnapshot>>(factory,
25                     LazyThreadSafetyMode.ExecutionAndPublication));
26
27             try
28             {
29                 return await lazy.Value;
30             }
31             catch
32             {
33                 _entries.TryRemove(new KeyValuePair<string, Lazy<Task<AccountLedgerSnapshot>>>(key,
34                     lazy));
35                 throw;
36             }
37         }
38
39         public void Invalidate(int accountId, int periodId)
```

Verification. Fresh performance evidence is mixed: spike improved, account-ledger soak regressed, and the core gate failed.

G.2 Read-Only Ledger Query and Running Balance

Purpose. Aggregates the opening balance in SQL, retrieves the period lines without tracking, and computes a deterministic running balance.

Source. Ledger payload query; file BAL/Services/FinancialReportService.cs; branch origin/baseline-jmeter-v1; commit 78b08b62; lines 154-215.

```
154     private async Task<AccountLedgerPayload> BuildAccountLedgerPayloadAsync(int accountId,
155                                     AccountingPeriod period, ChartOfAccount account)
156     {
157         var openingSums = await (
158             from entry in _context.JournalEntries
159             join line in _context.JournalEntryLines on entry.JournalEntryId equals
160                 line.JournalEntryId
161             where entry.Status == "Posted" &&
162                   line.AccountId == accountId &&
163                   entry.EntryDate < period.StartDate
164             group line by 1
165             into grouped
166             select new
167             {
168                 DebitTotal = grouped.Sum(x => (double)x.Debit),
169                 CreditTotal = grouped.Sum(x => (double)x.Credit)
170             })
171             .FirstOrDefaultAsync();
172
173         var openingBalance = NormalizeBalance(
174             account.AccountType,
175             decimal.Round(Convert.ToDecimal(openingSums?.DebitTotal ?? 0d), 2),
176             decimal.Round(Convert.ToDecimal(openingSums?.CreditTotal ?? 0d), 2));
177
178         var lines = await (
179             from entry in _context.JournalEntries.AsNoTracking()
180             join line in _context.JournalEntryLines.AsNoTracking() on entry.JournalEntryId
181                 equals line.JournalEntryId
182             where entry.Status == "Posted" &&
183                   line.AccountId == accountId &&
184                   entry.EntryDate >= period.StartDate &&
185                   entry.EntryDate <= period.EndDate
186             orderby entry.EntryDate, entry.JournalEntryId, line.JournalEntryLineId
187             select new
188             {
189                 entry.EntryDate,
190                 entry.JournalEntryId,
191                 entry.ReferenceNo,
192                 EntryDescription = entry.Description,
193                 line.LineDescription,
194                 line.Debit,
195                 line.Credit
196             })
197             .ToListAsync();
198
199         var runningBalance = openingBalance;
200         var ledgerLines = new List<AccountLedgerLineDto>(lines.Count);
201         foreach (var line in lines)
202         {
203             runningBalance += NormalizeBalance(account.AccountType, line.Debit, line.Credit);
204             ledgerLines.Add(new AccountLedgerLineDto
205             {
206                 EntryDate = line.EntryDate,
207                 JournalEntryId = line.JournalEntryId,
208                 ReferenceNo = line.ReferenceNo,
209                 EntryDescription = line.EntryDescription,
210                 LineDescription = line.LineDescription,
211                 Debit = line.Debit,
212                 Credit = line.Credit,
213                 RunningBalance = runningBalance
214             });
215     }
```

```
214         var debitTotal = ledgerLines.Sum(x => x.Debit);  
215         var creditTotal = ledgerLines.Sum(x => x.Credit);
```

Verification. Table 4.4 reports the fresh endpoint-level soak and spike behavior rather than assuming universal improvement.

G.3 Idempotent SQL Server Performance Indexes

Purpose. Creates the composite indexes required by report and journal-entry access paths only when SQL Server is the active provider.

Source. Index startup component; file BAL/Shared/SqlServerPerformanceIndexStartup.cs; branch origin/baseline-jmeter-v1; commit 78b08b62; lines 1-53.

```
1 using Microsoft.EntityFrameworkCore;
2 using MODEL;
3
4 namespace BAL.Shared
5 {
6     public sealed class SqlServerPerformanceIndexStartup
7     {
8         private readonly DataContext _context;
9
10        public SqlServerPerformanceIndexStartup(DataContext context)
11        {
12            _context = context;
13        }
14
15        public async Task EnsureAsync(CancellationToken cancellationToken = default)
16        {
17            if (!_context.Database.IsSqlServer())
18            {
19                return;
20            }
21
22            const string sql = ""
23                IF OBJECT_ID(N'[dbo].[JournalEntries]', N'U') IS NOT NULL
24                AND NOT EXISTS (
25                    SELECT 1
26                    FROM sys.indexes
27                    WHERE name = N'IX_JournalEntries_Status_EntryDate_JournalEntryId'
28                        AND object_id = OBJECT_ID(N'[dbo].[JournalEntries]')
29                )
30            BEGIN
31                CREATE NONCLUSTERED INDEX [IX_JournalEntries_Status_EntryDate_JournalEntryId]
32                ON [dbo].[JournalEntries] ([Status], [EntryDate], [JournalEntryId])
33                INCLUDE ([ReferenceNo], [Description]);
34            END;
35
36            IF OBJECT_ID(N'[dbo].[JournalEntryLines]', N'U') IS NOT NULL
37            AND NOT EXISTS (
38                SELECT 1
39                FROM sys.indexes
40                WHERE name =
41                    N'IX_JournalEntryLines_AccountId_JournalEntryId_JournalEntryLineId'
42                    AND object_id = OBJECT_ID(N'[dbo].[JournalEntryLines]')
43            )
44            BEGIN
45                CREATE NONCLUSTERED INDEX
46                [IX_JournalEntryLines_AccountId_JournalEntryId_JournalEntryLineId]
47                ON [dbo].[JournalEntryLines] ([AccountId], [JournalEntryId],
48                [JournalEntryLineId])
49                INCLUDE ([Debit], [Credit], [LineDescription]);
50            END;
51        }
52    }
53 }
```

Verification. Related evidence: deterministic database initialization and JMeter branch provenance.

Appendix H - Database Schema and Deterministic Seed Source Code

H.1 Deterministic Dataset Parameters

Purpose. Pins the accounting period and dataset sizes while intentionally omitting credential values from the thesis listing.

Source. Seed profile without credential parameters; file scripts/phase4/seed-test-data.ps1; branch origin/baseline-v0.1; commit 7a0469d9; lines 1-2, 5-10, 13-27.

```
1 param(
2     [string]$ConnectionString,
3     // ... unrelated lines omitted ...
4     [int]$PeriodId = 202601,
5     [string]$PeriodStart = "2026-01-01",
6     [string]$PeriodEnd = "2026-12-31",
7     [int]$AccountCount = 120,
8     [int]$JournalEntryCount = 30000,
9     [int]$MinimumPostedEntries = 5000
10    // ... unrelated lines omitted ...
11    $ErrorActionPreference = "Stop"
12
13    if ([string]::IsNullOrEmpty($ConnectionString)) {
14        $appSettingsPath = Join-Path $PSScriptRoot "..\..\API\appsettings.json"
15        $fullAppSettingsPath = [System.IO.Path]::GetFullPath($appSettingsPath)
16        if (-not (Test-Path $fullAppSettingsPath)) {
17            throw "ConnectionString was not provided and appsettings was not found:
18                $fullAppSettingsPath"
19        }
20    }
21
22    $json = Get-Content -Path $fullAppSettingsPath -Raw | ConvertFrom-Json
23    $ConnectionString = $json.AppSettings.ConnectionStrings
24    if ([string]::IsNullOrEmpty($ConnectionString)) {
25        throw "ConnectionString was not provided and AppSettings.ConnectionStrings is empty."
26    }
27 }
```

Verification. Fresh runs used 120 accounts, 30,000 journal entries, and at least 5,000 posted entries.

H.2 Double-Entry Schema Constraints and Indexes

Purpose. Defines journal headers and lines, enforces one-sided debit/credit values, and indexes the transaction access paths.

Source. Journal schema; file Document/sql/financial_accounting_schema.sql; branch origin/baseline-v0.1; commit 7a0469d9; lines 363-424.

```
363 IF OBJECT_ID(N'dbo.JournalEntries', N'U') IS NULL
364 BEGIN
365     CREATE TABLE dbo.JournalEntries
366     (
367         JournalEntryId bigint IDENTITY(1,1) NOT NULL CONSTRAINT PK_JournalEntries PRIMARY KEY,
368         EntryDate date NOT NULL,
369         Description nvarchar(500) NULL,
370         ReferenceNo nvarchar(100) NULL,
371         Status nvarchar(20) NOT NULL CONSTRAINT DF_JournalEntries_Status DEFAULT (N'Draft'),
372         CreatedByUserId uniqueidentifier NOT NULL,
373         CreatedAt datetime2 NOT NULL CONSTRAINT DF_JournalEntries_CreatedAt DEFAULT
            SYSUTCDATETIME(),
374         PostedAt datetime2 NULL,
375         ReversedAt datetime2 NULL,
376         CONSTRAINT FK_JournalEntries_Users FOREIGN KEY (CreatedByUserId) REFERENCES
            dbo.Users(UserId)
377     );
378 END;
379 GO
380
381 IF NOT EXISTS (SELECT 1 FROM sys.indexes WHERE object_id = OBJECT_ID(N'dbo.JournalEntries') AND name
    = N'IX_JournalEntries_EntryDate')
382 BEGIN
383     CREATE INDEX IX_JournalEntries_EntryDate ON dbo.JournalEntries(EntryDate);
384 END;
385 GO
386
387 IF NOT EXISTS (SELECT 1 FROM sys.indexes WHERE object_id = OBJECT_ID(N'dbo.JournalEntries') AND name
    = N'IX_JournalEntries_ReferenceNo')
388 BEGIN
389     CREATE INDEX IX_JournalEntries_ReferenceNo ON dbo.JournalEntries(ReferenceNo);
390 END;
391 GO
392
393 IF NOT EXISTS (SELECT 1 FROM sys.indexes WHERE object_id = OBJECT_ID(N'dbo.JournalEntries') AND name
    = N'IX_JournalEntries_Status')
394 BEGIN
395     CREATE INDEX IX_JournalEntries_Status ON dbo.JournalEntries(Status);
396 END;
397 GO
398
399 IF OBJECT_ID(N'dbo.JournalEntryLines', N'U') IS NULL
400 BEGIN
401     CREATE TABLE dbo.JournalEntryLines
402     (
403         JournalEntryLineId bigint IDENTITY(1,1) NOT NULL CONSTRAINT PK_JournalEntryLines PRIMARY
            KEY,
404         JournalEntryId bigint NOT NULL,
405         AccountId int NOT NULL,
406         LineDescription nvarchar(500) NULL,
407         Debit decimal(18,2) NOT NULL CONSTRAINT DF_JournalEntryLines_Debit DEFAULT (0),
408         Credit decimal(18,2) NOT NULL CONSTRAINT DF_JournalEntryLines_Credit DEFAULT (0),
409         CONSTRAINT FK_JournalEntryLines_JournalEntries FOREIGN KEY (JournalEntryId) REFERENCES
            dbo.JournalEntries(JournalEntryId) ON DELETE CASCADE,
410         CONSTRAINT FK_JournalEntryLines_ChartOfAccounts FOREIGN KEY (AccountId) REFERENCES
            dbo.ChartOfAccounts(AccountId),
411         CONSTRAINT CK_JournalEntryLines_DebitCredit CHECK ((Debit >= 0 AND Credit >= 0) AND ((CASE
            WHEN Debit > 0 THEN 1 ELSE 0 END + CASE WHEN Credit > 0 THEN 1 ELSE 0 END) = 1))
412     );
413 END;
414 GO
415
416 IF NOT EXISTS (SELECT 1 FROM sys.indexes WHERE object_id = OBJECT_ID(N'dbo.JournalEntryLines') AND
```

```
        name = N'IX_JournalEntryLines_JournalEntryId')
417 BEGIN
418     CREATE INDEX IX_JournalEntryLines_JournalEntryId ON dbo.JournalEntryLines(JournalEntryId);
419 END;
420 GO
421
422 IF NOT EXISTS (SELECT 1 FROM sys.indexes WHERE object_id = OBJECT_ID(N'dbo.JournalEntryLines') AND
        name = N'IX_JournalEntryLines_AccountId')
423 BEGIN
424     CREATE INDEX IX_JournalEntryLines_AccountId ON dbo.JournalEntryLines(AccountId);
```

Verification. Related evidence: balanced journal lines and report-generation database records.

Appendix I - Automated Test Source Code

I.1 Role-by-Endpoint Integration Matrix

Purpose. Generates test cases across every protected endpoint and role, authenticates the caller, and asserts the expected HTTP status.

Source. RBAC matrix test; file tests/FinancialAccounting.IntegrationTests/RbacMatrixTests.cs; branch origin/baseline-v0.1; commit 7a0469d9; lines 23-71.

```
23     public static IEnumerable<object[]> Cases()
24     {
25         foreach (var endpoint in ExpectedStatusMatrix.EndpointRoleStatus.Keys)
26         {
27             foreach (var role in Roles)
28             {
29                 yield return new object[] { endpoint, role };
30             }
31         }
32     }
33
34     [Theory]
35     [MemberData(nameof(Cases))]
36     public async Task EndpointRoleMatrix_MatchesExpectedStatus(string endpointKey, string role)
37     {
38         await ApplyRoleAsync(role);
39
40         using var response = await SendAsync(endpointKey, role);
41         var expectedStatus = ExpectedStatusMatrix.EndpointRoleStatus[endpointKey][role];
42
43         var actual = (int)response.StatusCode;
44         if (endpointKey == "POST /periods/{id}/close" && (role == "Admin" || role ==
45             "FinanceManager"))
46         {
47             new[] { 204, 404 }.Should().Contain(actual);
48             return;
49         }
50         actual.Should().Be(expectedStatus, $"endpoint '{endpointKey}' role '{role}' should map to
51             expected status");
52     }
53     private async Task ApplyRoleAsync(string role)
54     {
55         _client.ClearAuth();
56         if (role == "Anonymous")
57         {
58             return;
59         }
60
61         var token = role switch
62         {
63             "Admin" => await _tokens.GetAdminTokenAsync(),
64             "FinanceManager" => await _tokens.GetFinanceManagerTokenAsync(),
65             "User" => await _tokens.GetUserTokenAsync(),
66             "Auditor" => await _tokens.GetAuditorTokenAsync(),
67             _ => throw new InvalidOperationException($"Unknown role {role}")
68         };
69
70         _client.SetBearer(token);
71     }
```

Verification. The matrix covers Admin, FinanceManager, User, Auditor, and Anonymous callers.

I.2 Security and Performance Configuration Defaults Test

Purpose. Locks down the expected security-header defaults and the p50/p500 gate thresholds used by the application configuration.

Source. Configuration defaults test; file tests/FinancialAccounting.UnitTests/AppSettingsTests.cs; branch origin/baseline-v0.1; commit 7a0469d9; lines 7-19.

```
7 public class AppSettingsTests
8 {
9     [Fact]
10    public void Defaults_ShouldProvideSecurityAndPerformanceOptions()
11    {
12        var settings = new AppSettings();
13
14        settings.SecurityHeaders.Should().NotBeNull();
15        settings.SecurityHeaders.Enabled.Should().BeTrue();
16        settings.PerformanceGates.Should().NotBeNull();
17        settings.PerformanceGates.Profile50.MaxErrorPct.Should().Be(0.5);
18        settings.PerformanceGates.Profile500.MaxP95Ms.Should().Be(1200);
19    }
```

Verification. Related evidence: fresh JMeter remediation failure against the configured p100 and p500 thresholds.

Appendix J - React Web Application and API Integration Source Code

J.1 Authenticated API Client

Purpose. Adds the bearer token only when present, centralizes JSON headers and error parsing, and keeps the API base URL configurable.

Source. API request implementation; file WEB/src/lib/api.ts; branch origin/codex/thesis-reproducibility-v1; commit efa19cea; lines 238-270.

```
238 export class ApiClient {
239   private readonly baseUrl: string;
240   private readonly getToken: () => string | null;
241   private readonly fetchImpl: FetchLike;
242
243   constructor(baseUrl: string, getToken: () => string | null, fetchImpl: FetchLike =
     globalThis.fetch.bind(globalThis)) {
244     this.baseUrl = baseUrl.replace(/\/$/, "");
245     this.getToken = getToken;
246     this.fetchImpl = fetchImpl;
247   }
248
249   private async request<T>(path: string, init: RequestInit = {}): Promise<T> {
250     const token = this.getToken();
251     const headers: Record<string, string> = {
252       Accept: "application/json",
253       ...(init.headers as Record<string, string> | undefined),
254     };
255     if (init.body && !headers["Content-Type"]) {
256       headers["Content-Type"] = "application/json";
257     }
258     if (token) {
259       headers.Authorization = `Bearer ${token}`;
260     }
261
262     const response = await this.fetchImpl(`${this.baseUrl}${path}`, { ...init, headers });
263     const body = await parseResponse(response);
264     if (!response.ok) {
265       throw new ApiError(response.status, resolveMessage(body, response.statusText), body);
266     }
267     return body as T;
268   }
269
270   getHealth(): Promise<string> {
```

Verification. Related evidence: browser login, report, audit-log, and journal-line demonstrations.

J.2 Role-Aware Navigation and Mutation Rules

Purpose. Maps server roles to visible routes and mutation permissions so the user interface mirrors, but does not replace, server-side authorization.

Source. Client permission map; file WEB/src/lib/permissions.ts; branch origin/codex/thesis-reproducibility-v1; commit efa19cea; lines 13-56.

```
13 export type Role = "Admin" | "FinanceManager" | "User" | "Auditor";
14
15 export type NavItem = {
16   path: string;
17   label: string;
18   roles: Role[];
19   icon: ComponentType<{ size?: number }>;
20 };
21
22 export const navigation: NavItem[] = [
23   { path: "/dashboard", label: "Dashboard", roles: ["Admin", "FinanceManager", "User", "Auditor"],
24     icon: Gauge },
25   { path: "/accounts", label: "Accounts", roles: ["Admin", "FinanceManager", "User", "Auditor"],
26     icon: Landmark },
27   { path: "/journal-entries", label: "Journal Entries", roles: ["Admin", "FinanceManager", "User"],
28     icon: FileText },
29   { path: "/periods", label: "Periods", roles: ["Admin", "FinanceManager", "User", "Auditor"], icon:
30     BookOpenCheck },
31   { path: "/reports", label: "Reports", roles: ["Admin", "FinanceManager", "Auditor"], icon:
32     BarChart3 },
33   { path: "/audit-logs", label: "Audit Logs", roles: ["Admin", "Auditor"], icon: Activity },
34   { path: "/users", label: "Users", roles: ["Admin"], icon: Users },
35   { path: "/research-evidence", label: "Research Evidence", roles: ["Admin", "FinanceManager",
36     "User", "Auditor"], icon: ShieldCheck },
37 ];
38
39 export function hasAnyRole(userRoles: string[], allowedRoles: Role[]): boolean {
40   return allowedRoles.some((role) => userRoles.includes(role));
41 }
42
43 export function getAllowedNavigation(userRoles: string[]): NavItem[] {
44   return navigation.filter((item) => hasAnyRole(userRoles, item.roles));
45 }
46
47 export function canAccessRoute(userRoles: string[], routePath: string): boolean {
48   const navItem = navigation.find((item) => item.path === routePath);
49   return navItem ? hasAnyRole(userRoles, navItem.roles) : true;
50 }
51
52 export function canMutate(userRoles: string[], area: "accounts" | "journals" | "periods" | "users"):
53   boolean {
54   if (area === "users" || area === "accounts") {
55     return userRoles.includes("Admin");
56   }
57   if (area === "periods") {
58     return userRoles.includes("Admin") || userRoles.includes("FinanceManager");
59   }
60   return userRoles.includes("Admin") || userRoles.includes("FinanceManager") ||
61     userRoles.includes("User");
62 }
```

Verification. Related evidence: Admin and Auditor browser screenshots plus server-side RBAC tests.

Appendix K - Reproduction and Evidence-Automation Source Code

K.1 Exact-Commit Research Verification

Purpose. Rejects the wrong commit or a dirty measurement checkout, binds runtime evidence to the live process, and dispatches only the tool appropriate to the evidence role.

Source. Research verification guardrails; file scripts/thesis/Invoke-ResearchVerification.ps1; branch origin/codex/thesis-reproducibility-v1; commit efa19cea; lines 1-75.

```
1 [CmdletBinding()]
2 param(
3     [Parameter(Mandatory = $true)]
4     [ValidateSet('baseline', 'sonarqube-remediation', 'zap-remediation', 'jmeter-remediation')]
5     [string]$Role,
6     [Parameter(Mandatory = $true)][string]$WorkingDirectory,
7     [Parameter(Mandatory = $true)][ValidatePattern('^[0-9a-fA-F]{40}$')][string]$ExpectedCommit,
8     [string]$Phase4Root,
9     [string]$OutputDirectory = 'docs/appendix/verification-runs/research',
10    [string]$BaseUrl = 'http://localhost:5296',
11    [string]$OpenApiUrl = 'http://localhost:5296/swagger/v1/swagger.json',
12    [string]$Username = 'admin',
13    [string]$Password = '',
14    [int]$PeriodId = 202601,
15    [int]$AccountId = 1,
16    [string]$RuntimeEvidencePath,
17    [switch]$AllowDirty,
18    [switch]$ReturnFailureRecord,
19    [switch]$DryRun
20 )
21
22 $ErrorActionPreference = 'Stop'
23 Import-Module (Join-Path $PSScriptRoot 'Thesis.Common.psm1') -Force
24 Import-Module (Join-Path $PSScriptRoot 'Thesis.Research.psm1') -Force
25 $canonicalRoot = Get-ThesisRepositoryRoot -StartPath $PSScriptRoot
26 $workingDirectoryFull = [System.IO.Path]::GetFullPath($WorkingDirectory)
27 if (-not (Test-Path -LiteralPath $workingDirectoryFull)) { throw "Working directory does not exist:
    $workingDirectoryFull" }
28 $actualCommit = (& git -C $workingDirectoryFull rev-parse HEAD).Trim()
29 if ($LASTEXITCODE -ne 0) { throw "Unable to resolve Git commit in the working directory." }
30 if ($actualCommit -ne $ExpectedCommit.ToLowerInvariant()) {
31     throw "Expected $ExpectedCommit but found $actualCommit."
32 }
33 $dirtyEntries = @(& git -C $workingDirectoryFull status --porcelain --untracked-files=all)
34 if ($dirtyEntries.Count -gt 0 -and -not $AllowDirty) { throw 'Measurement checkout must be clean.' }
35
36 if ([string]::IsNullOrEmpty($Phase4Root)) {
37     $Phase4Root = Join-Path $workingDirectoryFull 'scripts/phase4'
38 }
39 $phase4RootFull = [System.IO.Path]::GetFullPath($Phase4Root)
40 $outputDirectoryFull = if ([System.IO.Path]::IsPathRooted($OutputDirectory)) {
41     [System.IO.Path]::GetFullPath($OutputDirectory)
42 } else {
43     [System.IO.Path]::GetFullPath((Join-Path $canonicalRoot $OutputDirectory))
44 }
45 $runId = Get-Date -Format 'yyyyMMdd-HHmssfff'
46 $commitPrefix = $actualCommit.Substring(0, 8)
47 $sonarKeys = @{
48     baseline = 'financial-accounting-thesis-baseline-v01'
49     'sonarqube-remediation' = 'financial-accounting-thesis-sonarqube-v1'
50     'zap-remediation' = 'financial-accounting-thesis-zap-v1'
51     'jmeter-remediation' = 'financial-accounting-thesis-jmeter-v1'
52 }
53 $usesSonar = $Role -in @('baseline', 'sonarqube-remediation')
54 $usesZap = $Role -in @('baseline', 'zap-remediation')
55 $usesJMeter = $Role -in @('baseline', 'jmeter-remediation')
56 $runtimeEvidence = $null
57 if ($usesZap -or $usesJMeter) {
58     if ([string]::IsNullOrEmpty($RuntimeEvidencePath) -or -not (Test-Path -LiteralPath
        $RuntimeEvidencePath)) {
```

```

59     throw 'Runtime evidence is required for ZAP and JMeter measurement roles.'
60 }
61 $runtimeEvidence = Get-Content -LiteralPath $RuntimeEvidencePath -Raw | ConvertFrom-Json
62 $null = Test-RuntimeEvidence -Evidence $runtimeEvidence -ExpectedCommit $actualCommit
        -ExpectedBaseUrl $BaseUrl -ExpectedWorkingDirectory $workingDirectoryFull
63 }
64
65 $result = [pscustomobject]@{
66     SchemaVersion = 1
67     RunId = $runId
68     Role = $Role
69     Commit = $actualCommit
70     EvidenceClassification = 'fresh-reproduction'
71     Status = if ($DryRun) { 'DRY_RUN' } else { 'PENDING' }
72     Failure = $null
73     Docker = [pscustomobject]@{ Status = if ($DryRun) { 'DRY_RUN' } else { 'PENDING' } };
        ServerVersion = $null }
74     Sonar = [pscustomobject]@{
75         Status = if ($usesSonar) { if ($DryRun) { 'DRY_RUN' } else { 'PENDING' } } else {
            'NOT_APPLICABLE' }

```

Verification. The thesis-script suite verifies exact-ref, clean-checkout, runtime-evidence, and failure-propagation behavior.

K.2 Environment and Tool Readiness Checks

Purpose. Checks required files and tools, treats Docker as optional in Fast mode, and blocks Full mode when the research-tool environment is unavailable.

Source. Environment audit; file scripts/thesis/Test-ThesisEnvironment.ps1; branch origin/codex/thesis-reproducibility-v1; commit efa19cea; lines 1-25, 44-70.

```
1 [CmdletBinding()]
2 param(
3     [ValidateSet('Fast', 'Demo', 'Full')]
4     [string]$Mode = 'Fast',
5     [string]$OutputPath
6 )
7
8 $ErrorActionPreference = 'Stop'
9 $modulePath = Join-Path $PSScriptRoot 'Thesis.Common.psm1'
10 Import-Module $modulePath -Force
11
12 $repositoryRoot = Get-ThesisRepositoryRoot -StartPath $PSScriptRoot
13 $git = Get-GitProvenance -WorkingDirectory $repositoryRoot
14 $blockingReasons = New-Object System.Collections.Generic.List[string]
15
16 function Get-CommandVersion {
17     param([string]$Name, [string[]]$Arguments)
18
19     $command = Get-Command $Name -ErrorAction SilentlyContinue
20     if (-not $command) {
21         return [pscustomobject]@{ Present = $false; Version = $null; Path = $null }
22     }
23
24     $result = Invoke-ThesisCommand -FilePath $command.Source -ArgumentList $Arguments
25         -WorkingDirectory $repositoryRoot
26     [pscustomobject]@{
27         // ... unrelated lines omitted ...
28         $blockingReasons.Add("$(Get-Command $Name) is unavailable.")
29     }
30 }
31
32 $dockerCommand = Get-Command docker -ErrorAction SilentlyContinue
33 $dockerClientVersion = $null
34 $dockerServerVersion = $null
35 $dockerServerAvailable = $false
36 if ($dockerCommand) {
37     $clientProbe = Invoke-ThesisCommand -FilePath $dockerCommand.Source -ArgumentList @('version',
38         '--format', '{{.Client.Version}}') -WorkingDirectory $repositoryRoot
39     if ($clientProbe.ExitCode -eq 0) { $dockerClientVersion = ($clientProbe.Output -join ' ').Trim() }
40
41     $serverProbe = Invoke-ThesisCommand -FilePath $dockerCommand.Source -ArgumentList @('version',
42         '--format', '{{.Server.Version}}') -WorkingDirectory $repositoryRoot
43     if ($serverProbe.ExitCode -eq 0 -and -not [string]::IsNullOrEmpty($serverProbe.Output
44         -join ' ')) {
45         $dockerServerAvailable = $true
46         $dockerServerVersion = ($serverProbe.Output -join ' ').Trim()
47     }
48 }
49
50 $docker = [pscustomobject]@{
51     ClientPresent = $null -ne $dockerCommand
52     ClientVersion = $dockerClientVersion
53     ServerAvailable = $dockerServerAvailable
54     ServerVersion = $dockerServerVersion
55 }
56
57 $sqlServices = @(Get-Service -ErrorAction SilentlyContinue | Where-Object { $_.Name -match '^MSSQL'
58     } | ForEach-Object {
59         [pscustomobject]@{ Name = $_.Name; Status = [string]$_.Status }
60     })
```

Verification. The thesis-script suite verifies Fast/Full mode behavior and portable run records.

K.3 Reproduction Command Sequence

The following commands execute the self-contained fast verification and local demonstration workflow. Secrets are supplied through process-local environment variables and are not printed in this report.

```
.\scripts\thesis\Test-ThesisEnvironment.ps1 -Mode Fast
.\scripts\thesis\Initialize-ThesisDatabase.ps1
.\scripts\thesis\Invoke-ThesisVerification.ps1 -Mode Fast
.\scripts\thesis\Invoke-ThesisDemo.ps1 -KeepRunning
.\scripts\thesis\New-DashboardCaptureCases.ps1 -OutputPath '.tmp/dashboard-cases.json'
$env:THESIS_DASHBOARD_CASES = '.tmp/dashboard-cases.json'
npm run capture:appendix --prefix WEB
```

Appendix L - SonarQube, OWASP ZAP, and JMeter Dashboards

L.1 SonarQube baseline overview

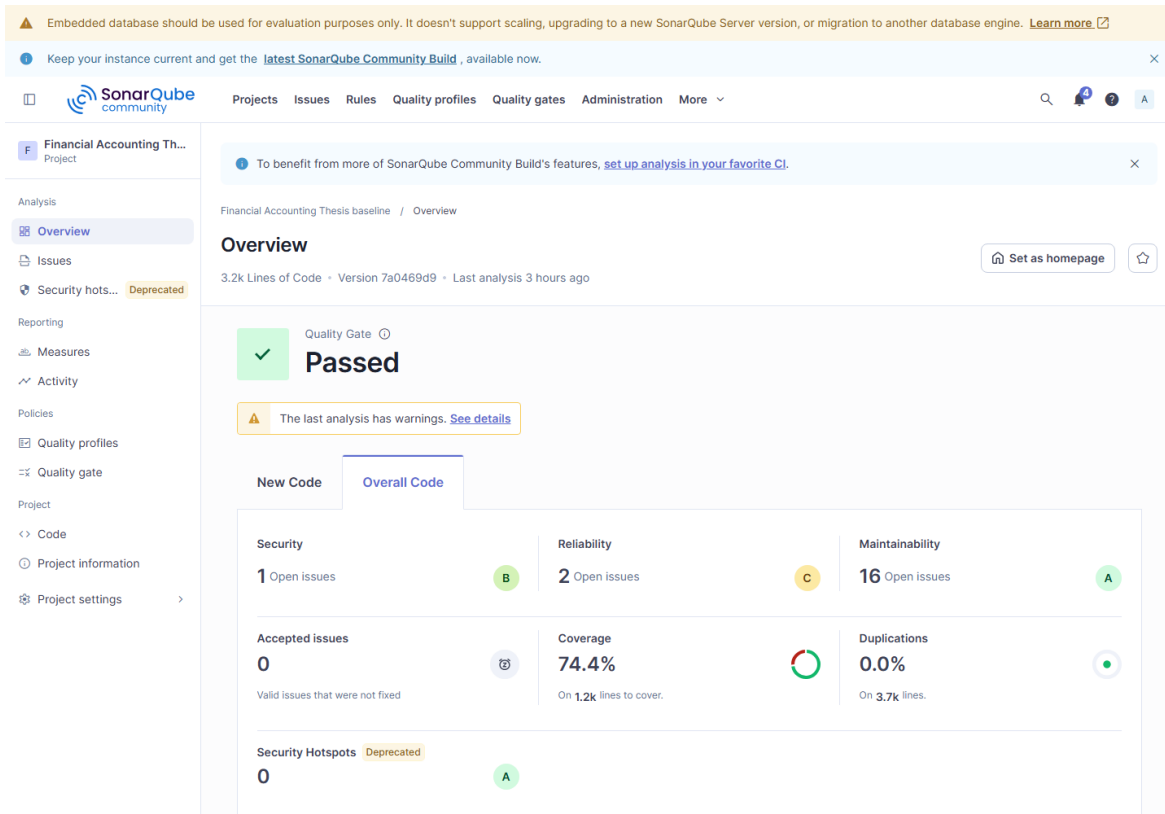


Figure L.1. SonarQube baseline overview dashboard.

Classification: fresh-reproduction; role: baseline; branch: origin/baseline-v0.1; commit: 7a0469d9; run: 20260922-183352; tool version: 26.7.0.124771; machine-readable source: docs/appendix/verification-runs/research/sonar/baseline/summary.json.

L.2 SonarQube baseline issues

⚠ Embedded database should be used for evaluation purposes only. It doesn't support scaling, upgrading to a new SonarQube Server version, or migration to another database engine. [Learn more](#)

🔔 Keep your instance current and get the [latest SonarQube Community Build](#), available now.

🏠 SonarQube community Projects Issues Rules Quality profiles Quality gates Administration More

Financial Accounting Thesis baseline / Issues

Issues

My Issues All

Filters

Looking for Bugs, Vulnerabilities, or Code Smells? If your team prefers working with these types, change it in the [settings](#)

Issues in new code

- Software Quality
 - Security 1
 - Reliability 2
 - Maintainability 16
- Severity
 - Blocker 0
 - High 1
 - Medium 7
 - Low 7
 - Info 4

API/Controllers/JournalEntriesController.cs

Method has 8 parameters, which is greater than the 7 authorized.

Maintainability Medium

Open Not assigned

L62 • 20min effort • 7 months ago

API/Program.cs

Await RunAsync instead.

Reliability Medium

Open Not assigned

L188 • 5min effort • 1 year ago

Add a 'protected' constructor or the 'static' keyword to the class declaration.

Maintainability Medium

Open Not assigned

L190 • 10min effort • 7 months ago

API/.../crc-api-test - Web Deploy/profile.arm.json

Rename this variable "appServicePlan_name" to match the regular expression "[a-z][a-zA-Z0-9]*\$".

Maintainability Low

Consistency convention

Figure L.2. SonarQube baseline issues dashboard.

Classification: fresh-reproduction; role: baseline; branch: origin/baseline-v0.1; commit: 7a0469d9; run: 20260922-183352; tool version: 26.7.0.124771; machine-readable source: docs/appendix/verification-runs/research/sonar/baseline/summary.json.

L.3 SonarQube remediation overview

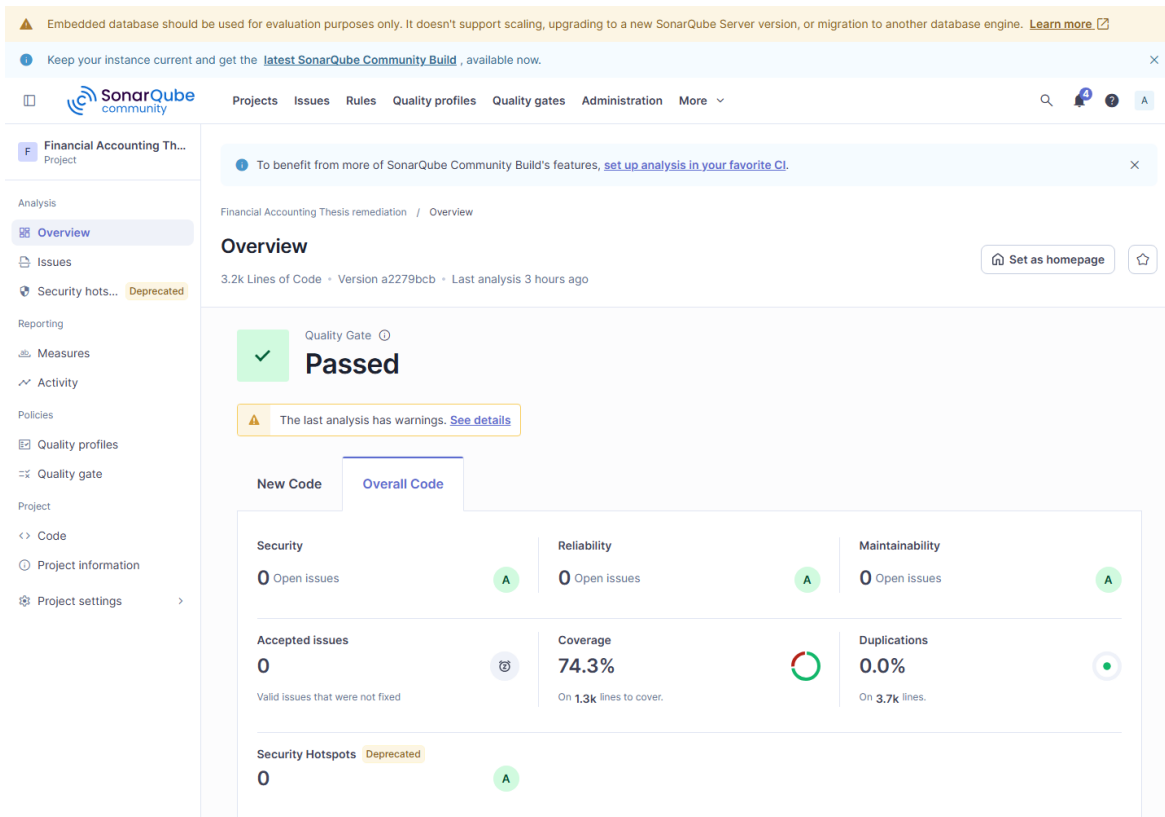


Figure L.3. SonarQube remediation overview dashboard.

Classification: fresh-reproduction; role: remediation; branch: origin/baseline-sonarqube-v1; commit: a2279bcb; run: 20260922-183352; tool version: 26.7.0.124771; machine-readable source: docs/appendix/verification-runs/research/sonar/remediation/summary.json.

L.4 SonarQube remediation issues

The screenshot shows the SonarQube web interface. At the top, there are two banners: a yellow one about the embedded database and a blue one about keeping the instance current. The navigation bar includes links for Projects, Issues, Rules, Quality profiles, Quality gates, Administration, and More. The left sidebar shows the project 'Financial Accounting Thesis remediation' and various analysis and reporting options. The main content area is titled 'Issues' and shows a summary of issues in the code. A filter box is open, showing options for 'Software Quality' and 'Severity'. The main area displays 'No Issues. Hooray!' and a table of issues with columns for 'Security', 'Reliability', and 'Maintainability'. The footer contains information about the SonarQube technology and the version of the Community Build.

Embedded database should be used for evaluation purposes only. It doesn't support scaling, upgrading to a new SonarQube Server version, or migration to another database engine. [Learn more](#)

Keep your instance current and get the [latest SonarQube Community Build](#), available now.

Financial Accounting Thesis remediation / Issues

Issues

My Issues All

Bulk Change

Select Issues ▲ ▼ Navigate to issue ◀ ▶ 0 issues 0 effort

No Issues. Hooray!

Looking for Bugs, Vulnerabilities, or Code Smells? If your team prefers working with these types, change it in the [settings](#)

Issues in new code

Software Quality

Security	0
Reliability	0
Maintainability	0

Severity

Blocker	0
High	0
Medium	0
Low	0
Info	0

SonarQube™ technology is powered by SonarSource Sàrl

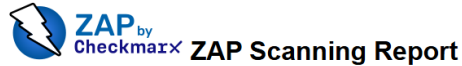
Community Build v26.7.0.124771 MQR MODE

LGPL v3 Community Documentation Plugins Web API

Figure L.4. SonarQube remediation issues dashboard.

Classification: fresh-reproduction; role: remediation; branch: origin/baseline-sonarqube-v1; commit: a2279bcb; run: 20260922-183352; tool version: 26.7.0.124771; machine-readable source: docs/appendix/verification-runs/research/sonar/remediation/summary.json.

L.5 OWASP ZAP passive baseline before remediation



Site: <http://host.docker.internal:5296>

Generated on Sun, 22 Feb 2026 16:02:52

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	2
Low	1
Informational	3
False Positives	0

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP warnings logged - see the zap.log file for details	1
Info	Informational	http://host.docker.internal:5296	Percentage of responses with status code 2xx	68 %
Info	Informational	http://host.docker.internal:5296	Percentage of responses with status code 3xx	12 %
Info	Informational	http://host.docker.internal:5296	Percentage of responses with status code 4xx	18 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with content type application/javascript	7 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with content type image/png	14 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with content type text/css	14 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with content type text/html	14 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with content type text/javascript	14 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with content type text/plain	7 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with method GET	100 %
Info	Informational	http://host.docker.internal:5296	Count of total endpoints	14

Summary of Sequences

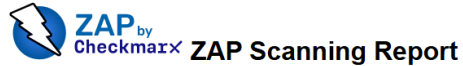
For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Figure L.5. OWASP ZAP passive baseline before remediation dashboard.

Classification: rendered-historical; role: baseline; branch: origin/baseline-v0.1; commit: 7a0469d9; run: 20260222-230133; tool version: 2.17.0; machine-readable source: Document/security/zap-baseline-20260222-230133.json.

L.6 OWASP ZAP passive baseline after remediation



Site: <http://host.docker.internal:5296>

Generated on Mon, 23 Mar 2026 17:08:38

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	0
Low	0
Informational	4
False Positives	0

Insights

Level	Reason	Site	Description	Statistic
Info	Informational	http://host.docker.internal:5296	Percentage of responses with status code 2xx	7 %
Info	Informational	http://host.docker.internal:5296	Percentage of responses with status code 3xx	3 %
Info	Informational	http://host.docker.internal:5296	Percentage of responses with status code 4xx	89 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with content type application/json	3 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with method DELETE	3 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with method GET	57 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with method POST	34 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with method PUT	3 %
Info	Informational	http://host.docker.internal:5296	Count of total endpoints	26

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

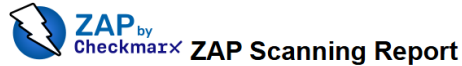
Alerts

Name	Risk Level	Number of Instances
Authentication Request Identified	Informational	2
Information Disclosure - Sensitive Information in URL	Informational	1

Figure L.6. OWASP ZAP passive baseline after remediation dashboard.

Classification: rendered-historical; role: remediation; branch: origin/baseline-zap-v1; commit: 5f3bd3cc; run: 20260324-000724; tool version: 2.17.0; machine-readable source: Document/security/zap-baseline-20260324-000724.json.

L.7 OWASP ZAP authenticated API before remediation



Site: <http://host.docker.internal:5296>

Generated on Sun, 22 Feb 2026 16:06:17

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	0
Low	1
Informational	5
False Positives	0

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP warnings logged - see the zap.log file for details	5
Low	Exceeded High	http://host.docker.internal:5296	Percentage of responses with status code 4xx	98 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with content type application/json	1 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with content type application/problem+json	1 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with content type text/html	1 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with method DELETE	1 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with method GET	66 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with method POST	31 %
Info	Informational	http://host.docker.internal:5296	Percentage of endpoints with method PUT	1 %
Info	Informational	http://host.docker.internal:5296	Count of total endpoints	305

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
Unexpected Content-Type was returned	Low	6

Figure L.7. OWASP ZAP authenticated API before remediation dashboard.

Classification: rendered-historical; role: baseline; branch: origin/baseline-v0.1; commit: 7a0469d9; run: 20260222-230133; tool version: 2.17.0; machine-readable source: Document/security/zap-api-20260222-230133.json.

L.8 OWASP ZAP authenticated API after remediation

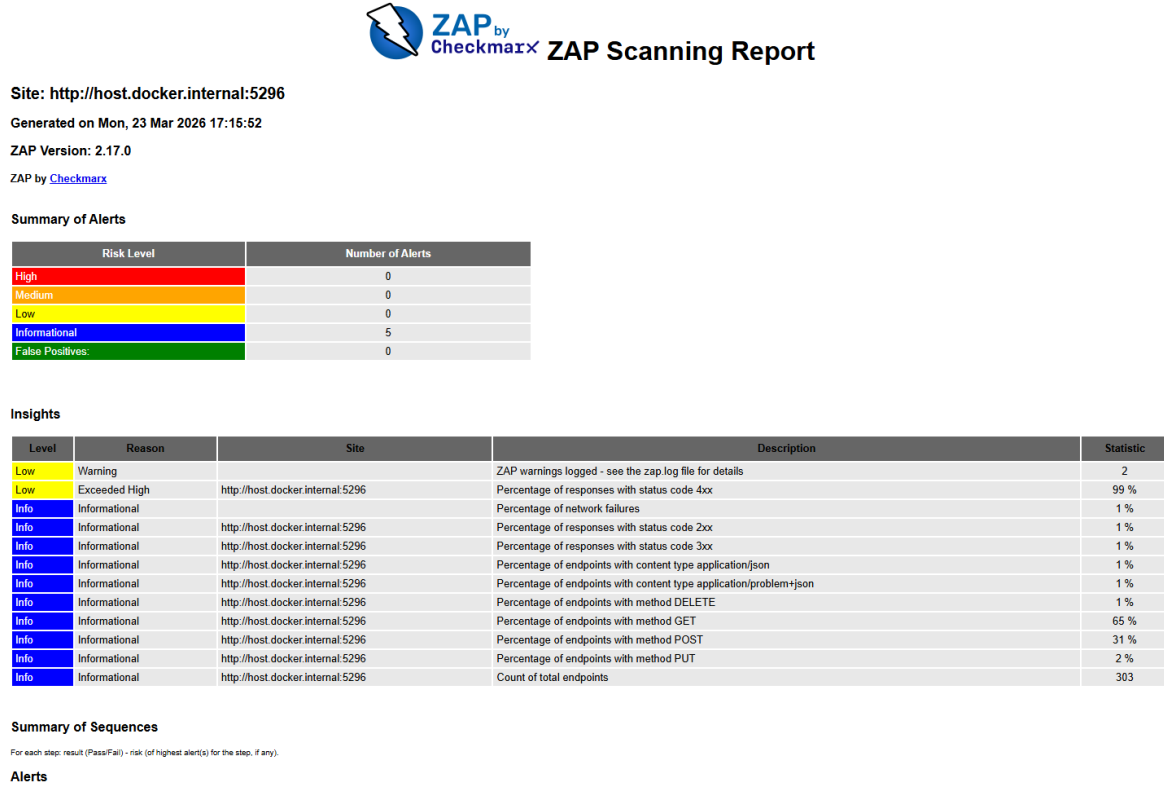


Figure L.8. OWASP ZAP authenticated API after remediation dashboard.

Classification: rendered-historical; role: remediation; branch: origin/baseline-zap-v1; commit: 5f3bd3cc; run: 20260324-000856; tool version: 2.17.0; machine-readable source: Document/security/zap-api-20260324-000856.json.

L.9 Apache JMeter baseline p50

Requests	Executions			Response Times (ms)							Throughput	Network (KB/sec)	
Label	#Samples	FAIL	Error %	Average	Min	Max	Median	90th pct	95th pct	99th pct	Transactions/s	Received	Sent
Total	2050	0	0.00%	16.57	2	1591	10.00	26.00	33.00	103.45	54.80	524.82	52.87
GET /accounts	500	0	0.00%	13.68	3	120	10.00	22.00	36.95	108.99	14.46	345.12	14.17
GET /journal-entries	500	0	0.00%	25.34	8	533	17.00	33.00	42.95	444.58	14.52	200.61	14.34
GET /periods	500	0	0.00%	7.58	2	64	6.00	11.90	14.00	47.99	14.50	10.37	14.21
GET /users/me	500	0	0.00%	11.39	3	184	8.00	18.00	23.95	91.53	14.38	10.38	14.10
POST /auth/login	50	0	0.00%	99.70	9	1591	19.50	74.00	1062.75	1591.00	1.72	2.47	0.47

Figure L.9. Apache JMeter baseline p50 dashboard.

Classification: fresh-reproduction; role: baseline; branch: origin/baseline-v0.1; commit: 7a0469d9; run: baseline-20260922-192730; tool version: 5.5; machine-readable source: docs/appendix/verification-runs/research/jmeter/baseline/report-baseline-20260922-192730-p50/statistics.json.

L.10 Apache JMeter baseline p100

Requests	Executions			Response Times (ms)							Throughput	Network (KB/sec)	
Label	#Samples	FAIL	Error %	Average	Min	Max	Median	90th pct	95th pct	99th pct	Transactions/s	Received	Sent
Total	4700	0	0.00%	60.92	2	1476	19.00	155.00	255.90	505.99	58.23	3154.38	57.88
GET /accounts	700	0	0.00%	23.43	4	297	13.00	45.00	76.95	190.88	10.53	251.33	10.32
GET /journal-entries	700	0	0.00%	36.29	9	377	24.00	68.00	94.80	206.94	10.53	145.43	10.39
GET /periods	700	0	0.00%	11.48	2	109	8.00	21.00	33.00	81.99	10.53	7.53	10.31
GET /reports/account-ledger	300	0	0.00%	268.68	61	1112	205.50	545.80	734.65	936.45	3.97	2986.51	4.06
GET /reports/balance-sheet	300	0	0.00%	139.29	37	753	109.50	272.00	339.60	502.82	3.97	4.78	4.01
GET /reports/profit-loss	300	0	0.00%	146.68	36	1476	105.50	287.90	353.80	768.15	3.97	4.13	4.00
GET /reports/trial-balance	300	0	0.00%	139.57	34	931	116.50	262.50	315.80	547.54	3.96	5.87	3.99
GET /users/me	1000	0	0.00%	14.91	3	196	9.00	30.00	42.00	80.96	12.75	9.20	12.51
POST /auth/login	100	0	0.00%	32.64	9	250	20.00	62.70	118.95	248.79	1.70	2.43	0.47
POST /journal-entries/bulk	300	0	0.00%	33.52	7	311	19.50	66.00	104.55	222.97	3.95	2.33	5.09

Figure L.10. Apache JMeter baseline p100 dashboard.

Classification: fresh-reproduction; role: baseline; branch: origin/baseline-v0.1; commit: 7a0469d9; run: baseline-20260922-192730; tool version: 5.5; machine-readable source: docs/appendix/verification-runs/research/jmeter/baseline/report-baseline-20260922-192730-p100/statistics.json.

L.11 Apache JMeter baseline p500

Requests	Executions			Response Times (ms)							Throughput	Network (KB/sec)	
Label	#Samples	FAIL	Error %	Average	Min	Max	Median	90th pct	95th pct	99th pct	Transactions/s	Received	Sent
Total	12000	0	0.00%	28.72	1	1625	10.00	77.00	106.00	197.00	63.20	3353.68	61.87
GET /accounts	1750	0	0.00%	9.43	2	591	6.00	13.00	19.45	66.49	9.62	229.55	9.43
GET /journal-entries	1750	0	0.00%	17.02	5	571	13.00	27.00	37.00	85.00	9.62	132.83	9.49
GET /periods	1750	0	0.00%	6.27	1	525	4.00	9.00	12.00	40.49	9.62	6.87	9.42
GET /reports/account-ledger	750	0	0.00%	125.36	51	1625	96.00	186.00	216.00	842.38	4.05	3047.34	4.14
GET /reports/balance-sheet	750	0	0.00%	66.74	29	339	54.00	111.90	142.80	236.45	4.05	4.88	4.09
GET /reports/profit-loss	750	0	0.00%	71.45	27	955	56.00	113.90	149.80	329.54	4.05	4.22	4.08
GET /reports/trial-balance	750	0	0.00%	68.40	29	730	56.00	112.00	134.00	290.49	4.05	6.01	4.09
GET /users/me	2500	0	0.00%	8.01	1	566	5.00	11.00	15.00	46.00	13.36	9.64	13.10
POST /auth/login	500	0	0.00%	16.68	5	308	11.00	23.00	31.00	144.98	2.79	3.99	0.77
POST /journal-entries/bulk	750	0	0.00%	13.40	5	169	10.00	22.00	33.45	65.98	4.06	2.39	5.24

Figure L.11. Apache JMeter baseline p500 dashboard.

Classification: fresh-reproduction; role: baseline; branch: origin/baseline-v0.1; commit: 7a0469d9; run: baseline-20260922-192730; tool version: 5.5; machine-readable source: docs/appendix/verification-runs/research/jmeter/baseline/report-baseline-20260922-192730-p500/statistics.json.

L.12 Apache JMeter baseline soak

Requests	Executions			Response Times (ms)							Throughput	Network (KB/sec)	
Label	#Samples	FAIL	Error %	Average	Min	Max	Median	90th pct	95th pct	99th pct	Transactions/s	Received	Sent
Total	104530	0	0.00%	63.94	1	5412	103.00	319.00	443.95	875.96	185.51	8503.55	186.08
GET /accounts	18000	0	0.00%	18.96	2	686	13.00	34.00	47.95	117.00	82.82	1977.19	81.21
GET /journal-entries	18000	0	0.00%	41.79	6	791	34.00	75.00	95.00	160.00	82.82	1144.01	81.77
GET /periods	18000	0	0.00%	10.81	1	511	8.00	20.00	27.00	60.00	82.83	59.21	81.13
GET /reports/account-ledger	5400	0	0.00%	332.33	58	5412	262.00	581.00	741.95	1565.63	9.66	7266.22	9.87
GET /reports/balance-sheet	5400	0	0.00%	191.29	33	2349	151.00	356.00	443.00	767.99	9.68	11.65	9.77
GET /reports/profit-loss	5400	0	0.00%	186.90	35	2429	148.00	341.90	437.95	734.98	9.70	10.09	9.77
GET /reports/trial-balance	5400	0	0.00%	184.58	31	2031	147.00	341.00	442.00	696.96	9.70	14.38	9.79
GET /users/me	23400	0	0.00%	15.73	2	703	12.00	29.00	36.00	68.00	41.91	30.25	41.09
POST /auth/login	130	0	0.00%	31.35	5	206	18.00	74.40	119.30	204.76	2.20	3.15	0.61
POST /journal-entries/bulk	5400	0	0.00%	35.15	5	852	25.00	68.00	90.00	168.98	9.70	5.72	12.52

Figure L.12. Apache JMeter baseline soak dashboard.

Classification: fresh-reproduction; role: baseline; branch: origin/baseline-v0.1; commit: 7a0469d9; run: baseline-20260922-192730; tool version: 5.5; machine-readable source: docs/appendix/verification-runs/research/jmeter/baseline/report-baseline-20260922-192730-soak/statistics.json.

L.13 Apache JMeter baseline spike

Requests	Executions			Response Times (ms)							Throughput	Network (KB/sec)	
Label	#Samples	FAIL	Error %	Average	Min	Max	Median	90th pct	95th pct	99th pct	Transactions/s	Received	Sent
Total	46500	218	0.47%	5419.41	4	97061	4295.50	24103.80	33401.75	46460.28	38.28	2078.63	38.35
GET /accounts	7000	0	0.00%	4171.18	6	62667	1194.50	12356.40	18515.45	32851.48	16.19	386.58	15.88
GET /journal-entries	7000	0	0.00%	3562.18	14	57826	1651.00	9427.80	15215.85	26758.75	16.08	222.15	15.88
GET /periods	7000	1	0.01%	2291.33	4	46479	770.00	6593.20	9585.70	19199.99	16.17	11.56	15.84
GET /reports/account-ledger	3000	27	0.90%	22131.93	578	97061	18747.50	43387.70	50288.30	70394.38	2.49	1855.23	2.54
GET /reports/balance-sheet	3000	69	2.30%	8070.57	146	45053	4041.00	21796.60	32732.65	38828.96	2.49	2.97	2.51
GET /reports/profit-loss	3000	69	2.30%	8070.66	116	46290	4043.50	22211.90	31487.90	38968.75	2.49	2.58	2.51
GET /reports/trial-balance	3000	51	1.70%	7835.42	144	45891	3784.00	21992.80	31142.45	37479.49	2.49	3.66	2.51
GET /users/me	10000	1	0.01%	3019.92	6	49671	1398.00	8118.00	12125.90	22139.39	8.26	5.96	8.10
POST /auth/login	500	0	0.00%	1242.30	15	7300	355.50	3568.60	4110.45	6463.44	13.97	19.99	3.85
POST /journal-entries/bulk	3000	0	0.00%	4227.89	34	35288	2824.50	9892.60	12734.75	21415.67	2.49	1.47	3.21

Figure L.13. Apache JMeter baseline spike dashboard.

Classification: fresh-reproduction; role: baseline; branch: origin/baseline-v0.1; commit: 7a0469d9; run: baseline-20260922-192730; tool version: 5.5; machine-readable source: docs/appendix/verification-runs/research/jmeter/baseline/report-baseline-20260922-192730-spike/statistics.json.

L.14 Apache JMeter remediation p50

Requests	Executions			Response Times (ms)							Throughput	Network (KB/sec)	
Label ^	#Samples ↕	FAIL ↕	Error % ↕	Average ↕	Min ↕	Max ↕	Median ↕	90th pct ↕	95th pct ↕	99th pct ↕	Transactions/s ↕	Received ↕	Sent ↕
Total	2050	0	0.00%	77.49	5	1678	57.00	146.90	199.90	322.47	52.64	504.14	50.78
GET /accounts	500	0	0.00%	80.46	7	366	64.00	155.60	221.95	307.88	13.87	331.03	13.60
GET /journal-entries	500	0	0.00%	112.29	16	648	90.00	196.90	279.45	633.39	13.90	192.02	13.72
GET /periods	500	0	0.00%	44.70	5	283	36.50	82.00	114.95	209.95	13.90	9.93	13.61
GET /users/me	500	0	0.00%	59.86	8	256	48.00	113.00	150.70	226.94	13.82	9.98	13.55
POST /auth/login	50	0	0.00%	204.14	46	1678	106.00	315.00	1224.65	1678.00	1.72	2.46	0.47

Figure L.14. Apache JMeter remediation p50 dashboard.

Classification: fresh-reproduction; role: remediation; branch: origin/baseline-jmeter-v1; commit: 78b08b62; run: remediation-20260922-200712; tool version: 5.5; machine-readable source: docs/appendix/verification-runs/research/jmeter/remediation/report-remediation-20260922-200712-p50/statistics.json.

L.15 Apache JMeter remediation p100

Requests	Executions			Response Times (ms)							Throughput	Network (KB/sec)	
Label	#Samples	FAIL	Error %	Average	Min	Max	Median	90th pct	95th pct	99th pct	Transactions/s	Received	Sent
Total	4700	0	0.00%	241.56	8	5547	81.00	628.90	1146.90	2482.88	54.11	2929.63	53.78
GET /accounts	700	0	0.00%	230.65	12	4757	101.00	526.50	934.80	2385.91	9.82	234.35	9.63
GET /journal-entries	700	0	0.00%	184.84	23	2804	115.00	352.70	605.00	1409.99	9.82	135.67	9.70
GET /periods	700	0	0.00%	92.60	8	1881	41.00	156.20	427.30	1075.91	9.82	7.02	9.62
GET /reports/account-ledger	300	0	0.00%	1431.80	48	5547	1205.00	2681.50	3565.90	5122.15	3.82	2870.66	3.90
GET /reports/balance-sheet	300	0	0.00%	154.59	9	1685	70.50	396.70	681.70	1563.28	3.84	4.65	3.87
GET /reports/profit-loss	300	0	0.00%	152.17	8	1759	75.50	345.50	538.85	1697.72	3.84	4.01	3.86
GET /reports/trial-balance	300	0	0.00%	157.71	11	1953	76.00	384.90	804.95	1243.92	3.79	5.68	3.83
GET /users/me	1000	0	0.00%	120.27	8	2453	49.00	248.90	508.45	1480.00	11.89	8.58	11.66
POST /auth/login	100	0	0.00%	216.31	35	2046	116.50	492.80	811.00	2039.88	1.70	2.43	0.47
POST /journal-entries/bulk	300	0	0.00%	229.54	10	2618	109.50	641.90	949.35	1831.87	3.77	2.23	4.87

Figure L.15. Apache JMeter remediation p100 dashboard.

Classification: fresh-reproduction; role: remediation; branch: origin/baseline-jmeter-v1; commit: 78b08b62; run: remediation-20260922-200712; tool version: 5.5; machine-readable source: docs/appendix/verification-runs/research/jmeter/remediation/report-remediation-20260922-200712-p100/statistics.json.

L.16 Apache JMeter remediation p500

Requests	Executions			Response Times (ms)							Throughput	Network (KB/sec)	
Label	#Samples	FAIL	Error %	Average	Min	Max	Median	90th pct	95th pct	99th pct	Transactions/s	Received	Sent
Total	12000	0	0.00%	336.23	2	11676	91.00	852.00	1547.95	3862.80	62.44	3312.13	61.13
GET /accounts	1750	0	0.00%	323.11	5	7738	98.00	831.80	1575.60	3612.20	9.64	230.09	9.45
GET /journal-entries	1750	0	0.00%	277.88	12	6077	117.00	621.80	1125.35	2497.13	9.65	133.31	9.53
GET /periods	1750	0	0.00%	148.97	2	3801	49.00	360.00	743.25	1572.11	9.64	6.89	9.44
GET /reports/account-ledger	750	0	0.00%	1725.54	50	11676	995.50	4233.20	5996.30	9040.01	4.11	3086.66	4.20
GET /reports/balance-sheet	750	0	0.00%	240.36	5	3966	89.00	600.80	1023.05	2701.17	4.11	4.98	4.15
GET /reports/profit-loss	750	0	0.00%	256.07	6	2982	85.00	731.10	1336.50	2376.22	4.11	4.30	4.14
GET /reports/trial-balance	750	0	0.00%	234.36	6	4312	90.00	631.40	1049.80	1756.25	4.11	6.15	4.14
GET /users/me	2500	0	0.00%	188.17	3	4028	60.00	479.80	855.85	1898.94	13.28	9.59	13.02
POST /auth/login	500	0	0.00%	404.73	8	5174	149.50	1157.60	1736.00	3513.98	2.79	3.99	0.77
POST /journal-entries/bulk	750	0	0.00%	276.33	8	4301	123.00	708.90	1177.50	2026.85	4.11	2.42	5.30

Figure L.16. Apache JMeter remediation p500 dashboard.

Classification: fresh-reproduction; role: remediation; branch: origin/baseline-jmeter-v1; commit: 78b08b62; run: remediation-20260922-200712; tool version: 5.5; machine-readable source: docs/appendix/verification-runs/research/jmeter/remediation/report-remediation-20260922-200712-p500/statistics.json.

L.17 Apache JMeter remediation soak

Requests	Executions			Response Times (ms)							Throughput	Network (KB/sec)	
Label	#Samples	FAIL	Error %	Average	Min	Max	Median	90th pct	95th pct	99th pct	Transactions/s	Received	Sent
Total	104530	0	0.00%	236.41	2	16829	12.00	94.00	171.00	462.00	170.98	7833.59	171.49
GET /accounts	18000	0	0.00%	317.64	4	11737	114.00	749.90	1360.85	3111.91	45.57	1087.79	44.68
GET /journal-entries	18000	0	0.00%	341.71	10	7654	152.00	799.90	1321.00	2933.98	45.60	629.86	45.02
GET /periods	18000	0	0.00%	142.18	2	4735	43.00	330.00	625.95	1618.00	45.59	32.59	44.65
GET /reports/account-ledger	5400	0	0.00%	792.56	21	16829	203.00	2222.00	3825.70	7183.53	8.94	6718.74	9.13
GET /reports/balance-sheet	5400	0	0.00%	100.08	2	4236	17.50	218.00	487.85	1443.95	8.94	10.83	9.02
GET /reports/profit-loss	5400	0	0.00%	96.59	2	4028	18.00	215.90	427.85	1363.90	8.94	9.35	9.00
GET /reports/trial-balance	5400	0	0.00%	103.13	3	4474	18.00	230.00	446.95	1664.99	8.94	13.38	9.02
GET /users/me	23400	0	0.00%	154.91	2	6425	37.00	297.00	586.00	1425.00	38.43	27.73	37.68
POST /auth/login	130	0	0.00%	556.62	59	4081	295.00	1384.90	1831.90	4041.94	2.18	3.12	0.60
POST /journal-entries/bulk	5400	0	0.00%	127.58	5	6014	25.00	311.90	597.85	1763.86	8.94	5.27	11.53

Figure L.17. Apache JMeter remediation soak dashboard.

Classification: fresh-reproduction; role: remediation; branch: origin/baseline-jmeter-v1; commit: 78b08b62; run: remediation-20260922-200712; tool version: 5.5; machine-readable source: docs/appendix/verification-runs/research/jmeter/remediation/report-remediation-20260922-200712-soak/statistics.json.

L.18 Apache JMeter remediation spike

Requests	Executions			Response Times (ms)							Throughput	Network (KB/sec)	
Label	#Samples	FAIL	Error %	Average	Min	Max	Median	90th pct	95th pct	99th pct	Transactions/s	Received	Sent
Total	46500	0	0.00%	1105.66	3	61870	771.50	3203.00	4730.85	11193.92	149.90	8200.83	150.17
GET /accounts	7000	0	0.00%	1049.45	6	10027	805.00	2317.80	3083.00	4749.83	50.18	1197.95	49.20
GET /journal-entries	7000	0	0.00%	880.65	15	8426	640.00	1865.70	2609.95	4534.92	49.88	688.99	49.24
GET /periods	7000	0	0.00%	660.51	3	5677	556.00	1433.90	1734.00	2592.98	50.09	35.80	49.06
GET /reports/account-ledger	3000	0	0.00%	4689.35	420	61870	3484.50	8472.70	12910.20	25445.84	9.86	7408.66	10.07
GET /reports/balance-sheet	3000	0	0.00%	841.63	11	12026	581.50	1733.60	2554.90	6307.29	9.90	12.00	9.99
GET /reports/profit-loss	3000	0	0.00%	834.23	14	10415	597.50	1747.70	2342.75	5889.29	9.91	10.36	9.97
GET /reports/trial-balance	3000	0	0.00%	914.92	10	12109	621.50	1900.00	2797.70	5978.76	9.91	14.83	10.00
GET /users/me	10000	0	0.00%	842.45	4	18198	633.00	1752.90	2386.00	4643.86	32.96	23.79	32.32
POST /auth/login	500	0	0.00%	1086.01	11	4446	843.00	2632.30	3107.15	3933.82	15.22	21.77	4.19
POST /journal-entries/bulk	3000	0	0.00%	823.72	15	13629	558.50	1753.20	2544.10	5511.05	9.99	5.89	12.89

Figure L.18. Apache JMeter remediation spike dashboard.

Classification: fresh-reproduction; role: remediation; branch: origin/baseline-jmeter-v1; commit: 78b08b62; run: remediation-20260922-200712; tool version: 5.5; machine-readable source: docs/appendix/verification-runs/research/jmeter/remediation/report-remediation-20260922-200712-spike/statistics.json.

Appendix M - Result Traceability

Current conclusions use the fresh September 22 reproduction. Historical measurements are retained in the comparison column so the evolution of the study remains auditable.

Tool	Current fresh result	Historical comparison	Machine-readable evidence
SonarQube	17 unique issues to 0; coverage 74.4% to 74.3%; gates OK/OK	28 retained findings to 0; coverage reported as 74.3%	docs/appendix/verification-runs/research/sonar/*
OWASP ZAP	Passive M3/L6 to M0/L0; API M1/L3 to M1/L0; configured gate passed	Earlier scans reported all gated Medium/Low alerts cleared	docs/appendix/verification-runs/research/zap/*
Apache JMeter	Core gate FAIL; p50 33 to 199.9 ms; p100 255.9 to 1146.9 ms; p500 106 to 1547.95 ms; soak/spike aggregates improved	Earlier run reported core and stress p95 improvements	docs/appendix/verification-runs/research/jmeter/*
Application demonstration	API health, frontend smoke, and browser role workflow PASS	Role-aware React client added as a validation artifact	docs/appendix/verification-runs/demo-*.json

Appendix N - Limitations and Complete Source Index

- The study covers one ASP.NET Core application, one dataset profile, one AI assistant configuration, and one fresh measurement run per evidence branch.
- SonarQube MQR Reliability, Security, and Maintainability impacts overlap and must not be added together as unique issues.
- The fresh authenticated ZAP scan retains one raw Medium HTTP Only Site observation because the local reproduction uses HTTP instead of a production TLS endpoint.
- The fresh JMeter remediation core gate fails even though soak and spike aggregate p95 improve; this prevents a general performance-improvement claim.
- Tool versions, host load, database state, and workload composition can change results. Repeated controlled runs and confidence intervals are future work.
- The listings below are deliberately curated. The complete repository at the pinned commits remains authoritative for files not reproduced in full.

Listing	Purpose	File	Branch/ref	Commit
B.1	JWT Authentication Configuration	API/Program.cs	origin/baseline-sonarqube-v1	a2279bcb
B.2	Controller-Level Role Enforcement	API/Controllers/JournalEntriesController.cs	origin/baseline-sonarqube-v1	a2279bcb
C.1	Balanced Journal-Entry Posting	BAL/Services/JournalEntryService.cs	origin/baseline-sonarqube-v1	a2279bcb
C.2	Journal-Entry Reversal	BAL/Services/JournalEntryService.cs	origin/baseline-sonarqube-v1	a2279bcb
D.1	Structured Audit-Log Writer	BAL/Services/AuditLogService.cs	origin/baseline-sonarqube-v1	a2279bcb
D.2	Auditor-Role Read Boundary	API/Controllers/AuditLogsController.cs	origin/baseline-sonarqube-v1	a2279bcb
E.1	S107 Controller-Parameter Remediation	API/Controllers/JournalEntriesController.cs	origin/baseline-v0.1	7a0469d9
E.1	S107 Controller-Parameter Remediation	API/Controllers/JournalEntriesController.cs	origin/baseline-sonarqube-v1	a2279bcb
E.1	S107 Controller-Parameter Remediation	MODEL/DTOs/FinancialAccountingDTOs.cs	origin/baseline-sonarqube-v1	a2279bcb
E.2	S6966 Asynchronous Host Shutdown	API/Program.cs	origin/baseline-v0.1	7a0469d9
E.2	S6966 Asynchronous Host Shutdown	API/Program.cs	origin/baseline-sonarqube-v1	a2279bcb
F.1	Response Security-Headers Middleware	API/Middleware/SecurityHeadersMiddleware.cs	origin/baseline-zap-v1	5f3bd3cc
F.2	Middleware Ordering and Swagger Exposure	API/Program.cs	origin/baseline-v0.1	7a0469d9
F.2	Middleware Ordering and Swagger Exposure	API/Program.cs	origin/baseline-zap-v1	5f3bd3cc
G.1	Concurrency-Safe Account-Ledger Cache	BAL/Shared/AccountLedgerCache.cs	origin/baseline-jmeter-v1	78b08b62
G.2	Read-Only Ledger Query and Running Balance	BAL/Services/FinancialReportService.cs	origin/baseline-jmeter-v1	78b08b62
G.3	Idempotent SQL Server Performance Indexes	BAL/Shared/SqlServerPerformanceIndexStartup.cs	origin/baseline-jmeter-v1	78b08b62
H.1	Deterministic Dataset Parameters	scripts/phase4/seed-test-data.ps1	origin/baseline-v0.1	7a0469d9
H.2	Double-Entry Schema Constraints and Indexes	Document/sql/financial_accounting_schema.sql	origin/baseline-v0.1	7a0469d9
I.1	Role-by-Endpoint Integration Matrix	tests/FinancialAccounting.IntegrationTests/RbacMatrixTests.cs	origin/baseline-v0.1	7a0469d9

I.2	Security and Performance Configuration Defaults Test	tests/FinancialAccounting.UnitTests/AppSettingsTests.cs	origin/baseline-v0.1	7a0469d9
J.1	Authenticated API Client	WEB/src/lib/api.ts	origin/codex/thesis-reproducibility-v1	efa19cea
J.2	Role-Aware Navigation and Mutation Rules	WEB/src/lib/permissions.ts	origin/codex/thesis-reproducibility-v1	efa19cea
K.1	Exact-Commit Research Verification	scripts/thesis/Invoke-ResearchVerification.ps1	origin/codex/thesis-reproducibility-v1	efa19cea
K.2	Environment and Tool Readiness Checks	scripts/thesis/Test-ThesisEnvironment.ps1	origin/codex/thesis-reproducibility-v1	efa19cea